

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b0bf6d9fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.1	Management criteria	The management criteria establish criteria for establishing, implementing, operating, monitoring, maintaining, and improving information security management, which is an activity coordinated to direct and control the organization with respect to information security, based on JIS Q 27001:2014. In principle, the management criteria needs to be all be implemented.	Functional	No Relationship	N/A	N/A	N/A	0	
4.2	Contents of description	The same as "Management Criteria" in "Information Security Management Standard". In cloud services, it is necessary to consider and implement the controls, etc. of cloud service providers in consideration of the environment of cloud service users. For this reason, it is extremely important to exchange information among cloud service users and cloud service providers regarding the information security risks in cloud services and their measures. The information security risk communication is specified in Chapter 4.9 as a matter to be especially considered in cloud services.	Functional	No Relationship	N/A	N/A	N/A	0	
4.3	Legend	Chapter 4.4 and subsequent chapters have the following structure. 4.4 Establishment of information security management [27001-4] 4.4.1 Roles, responsibilities, and authorities of the organization [27001-5.3 / 5.1] 4.4.1.1 Top management demonstrate leadership and commitment to information security management. [27001-5.1b) / 5.1e) / 5.1f)] In doing so, the following are performed. • Integrate the information security management requirements required by the organization into the organization's processes : [27001-X.X.X] indicates the relevant clause (X.X.X) in JIS Q 27001:2014.	Functional	No Relationship	N/A	N/A	N/A	0	
4.4	Establishment of information security management [27001-4.4]	The scope of application as the foundation is determined and the policy is established in order to establish information security management. Conduct information security risk assessment, and plan and implement response based on this. As a result, create a foundation for the implementation of effective information security management by the organization.	Functional	No Relationship	N/A	N/A	N/A	0	
4.4.1	Roles, responsibilities, and authorities of the organization [27001-5.3 / 5.1]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.4.1.1	N/A	Top management demonstrate leadership and commitment to information security management. [27001-5.1b) / 5.1e) / 5.1f)] • Integrate the information security management requirements required by the organization into the organization's processes. • Ensure that information security management achieves its intended results. • Lead and support people to contribute to the effectiveness of information security management. In addition, the leadership and commitment of top management are confirmed as follows • The intentions, judgments and instructions of the top management concerning information security management are recorded in the minutes of the management meetings, etc. • The intentions, judgments, and instructions of the top management are included in the formulation of the information security policy, information security objectives, and plans to achieve them. • Top management determines the risk level as the level of security to be achieved. • The intentions, judgments, and instructions of top management are included in the implementation of the security control measures selected according to the risk level. • The items to be checked in the internal assessment include the information security requirements, etc. required by the top management. • The intentions, judgments, and instructions of top management are included in the internal assessment reports, corrective actions based on the reports, and minutes of the management review.	Functional	Subset Of	Security, Compliance & Resilience Program (SCRp)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
4.4.1.1	N/A	Top management demonstrate leadership and commitment to information security management. [27001-5.1b) / 5.1e) / 5.1f)] • Integrate the information security management requirements required by the organization into the organization's processes. • Ensure that information security management achieves its intended results. • Lead and support people to contribute to the effectiveness of information security management. In addition, the leadership and commitment of top management are confirmed as follows • The intentions, judgments and instructions of the top management concerning information security management are recorded in the minutes of the management meetings, etc. • The intentions, judgments, and instructions of the top management are included in the formulation of the information security policy, information security objectives, and plans to achieve them. • Top management determines the risk level as the level of security to be achieved. • The intentions, judgments, and instructions of top management are included in the implementation of the security control measures selected according to the risk level. • The items to be checked in the internal assessment include the information security requirements, etc. required by the top management. • The intentions, judgments, and instructions of top management are included in the internal assessment reports, corrective actions based on the reports, and minutes of the management review.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	8	
4.4.1.2	N/A	Top management assign and communicate the following responsibilities and authorities for the organization's roles. [27001-5.3] • Conform the information security management as the requirements of the Control Criteria. • Report the performance assessment of information security management to the top management. In addition, confirm that the following responsibilities and authorities are assigned to ensure that information security management conforms to the requirements of the Control Criteria. • Responsibilities and authorities to formulate documents such as information security policies that include security requirements • Risk owners who have the responsibility and authority to operate and manage the risks in the risk assessment • Responsibility and authority to educate and disseminate controls that meet security requirements • Responsibility and authority to assess whether security requirements are being met • Responsibility and authority to report the results and effects of each process to top management • Responsibility and authority to disseminate the results and effects of each process within the organization	Functional	Subset Of	Security, Compliance & Resilience Program (SCRp)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.4.1.2	N/A	Top management assign and communicate the following responsibilities and authorities for the organization's roles. [27001-5.3] - Conform the information security management as the requirements of the Control Criteria. - Report the performance assessment of information security management to the top management. In addition, confirm that the following responsibilities and authorities are assigned to ensure that information security management conforms to the requirements of the Control Criteria. - Responsibilities and authorities to formulate documents such as information security policies that include security requirements - Risk owners who have the responsibility and authority to operate and manage the risks in the risk assessment - Responsibility and authority to educate and disseminate controls that meet security requirements - Responsibility and authority to assess whether security requirements are being met - Responsibility and authority to report the results and effects of each process to top management - Responsibility and authority to disseminate the results and effects of each process within the organization.	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPP).	5	
4.4.1.3	N/A	Top management support the role of management team to enable them to exercise leadership in their areas of responsibility. [27001-5.1h] Top management confirms that the necessary authority is delegated to the management team so that the management team can exercise leadership in its area of responsibility, organization, etc.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	8	
4.4.2	Understanding of the organization and its situation [27001-4.1]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.4.2.1	N/A	The organization determines the following issues that are relevant to the organization's objectives and that affect the organization's ability to achieve the intended outcomes of information security management. [27001-4.1] - External issues - Internal issues Determination of these issues refers to the determination of the external and internal conditions of the organization. External and internal conditions include the following. a) External conditions - Cultural, social, political, legal, regulatory, financial, technological, economic, natural, and competitive environment, whether international, national, regional, or concerning neighboring regions - Key drivers and trends that influence the organization's objectives - Relationships with external stakeholders and the perceptions and values of external stakeholders b) Internal conditions - Governance, organizational structure, roles, and accountability - Policies, objectives, and strategies developed to achieve them - Capabilities in terms of resources and knowledge (for example, capital, time, personnel, processes, systems, and technologies) - Information systems, information flows, and decision-making processes (including both formal and informal) - Relationships with internal stakeholders and the perceptions and values of internal stakeholders - Organizational culture - Standards, guidelines, and models adopted by the organization - Form and scope of the contractual relationship	Functional	Subset Of	Security, Compliance & Resilience Program (SCRPP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
4.4.2.1	N/A	The organization determines the following issues that are relevant to the organization's objectives and that affect the organization's ability to achieve the intended outcomes of information security management. [27001-4.1] - External issues - Internal issues Determination of these issues refers to the determination of the external and internal conditions of the organization. External and internal conditions include the following. a) External conditions - Cultural, social, political, legal, regulatory, financial, technological, economic, natural, and competitive environment, whether international, national, regional, or concerning neighboring regions - Key drivers and trends that influence the organization's objectives - Relationships with external stakeholders and the perceptions and values of external stakeholders b) Internal conditions - Governance, organizational structure, roles, and accountability - Policies, objectives, and strategies developed to achieve them - Capabilities in terms of resources and knowledge (for example, capital, time, personnel, processes, systems, and technologies) - Information systems, information flows, and decision-making processes (including both formal and informal) - Relationships with internal stakeholders and the perceptions and values of internal stakeholders - Organizational culture - Standards, guidelines, and models adopted by the organization - Form and scope of the contractual relationship	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	8	
4.4.3	Understanding stakeholder needs and expectations [27001-4.2]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.4.3.1	N/A	The organization determines the following to understand the needs and expectations of stakeholders. [27001-4.2] - Stakeholders relevant to information security management - Requirements of stakeholders related to information security Stakeholder requirements can include legal and regulatory requirements as well as contractual obligations, and stakeholders can include the following. - A person or organization that has the role and authority to drive the information security management process within the organization. For example, this includes the following. - A person or organization that formulates the policy concerning information security (top management, etc.) - A person or organization (general affairs department, information system department, etc.) that ensures that the security control measures are thoroughly implemented in all organizations - A person or organization (assessment office, etc.) that conducts information security assessments - Information security experts in the organization - Business partners, suppliers, and other stakeholders in the supply chain - Parent company and group companies - Ministries and government agencies that supervise the security of the organization - Security organizations and associations to which the organization belongs	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and (2) Performing a criticality analysis at predefined decision points in the Secure Development Life Cycle (SDLC).	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.4.3.1	N/A	The organization determines the following to understand the needs and expectations of stakeholders. [27001-4.2] - Stakeholders relevant to information security management - Requirements of stakeholders related to information security Stakeholder requirements can include legal and regulatory requirements as well as contractual obligations, and stakeholders can include the following. - A person or organization that has the role and authority to drive the information security management process within the organization. For example, this includes the following. - A person or organization that formulates the policy concerning information security (top management, etc.) - A person or organization (general affairs department, information system department, etc.) that ensures that the security control measures are thoroughly implemented in all organizations - A person or organization (assessment office, etc.) that conducts information security assessments - Information security experts in the organization - Business partners, suppliers, and other stakeholders in the supply chain - Parent company and group companies - Ministries and government agencies that supervise the security of the organization - Security organizations and associations to which the organization belongs	Functional	Intersects With	Business Process Definition	PRM-06	Mechanisms exist to define business processes with consideration for security, compliance and resilience that determines: (1) The resulting risk to organizational operations, assets, individuals and other organizations; and (2) Information protection needs arising from the defined business processes and revises the processes as necessary, until an achievable set of protection needs is obtained.	5	
4.4.4	Determine the scope of application [27001-4.3]	In order to establish, implement, operate, monitor, review, maintain, and improve information security management, first clarify the scope of application, and establish a foundation for building an information security management system that suits the organization.	Functional	Intersects With	Network Diagrams & Data Flow Diagrams (DFDs)	AST-04	Mechanisms exist to maintain network architecture diagrams that: (1) Contain sufficient detail to assess the security of the network's architecture; (2) Reflect the current architecture of the network environment; and (3) Document all sensitive and/or regulated data flows.	5	
4.4.4	Determine the scope of application [27001-4.3]	In order to establish, implement, operate, monitor, review, maintain, and improve information security management, first clarify the scope of application, and establish a foundation for building an information security management system that suits the organization.	Functional	Subset Of	Asset Scope Classification	AST-04.1	Mechanisms exist to determine security, compliance and resilience control applicability by identifying, assigning and documenting the appropriate asset scope categorization for all Technology Assets, Applications and/or Services (TAAS) and personnel (internal and third-parties).	10	
4.4.4	Determine the scope of application [27001-4.3]	In order to establish, implement, operate, monitor, review, maintain, and improve information security management, first clarify the scope of application, and establish a foundation for building an information security management system that suits the organization.	Functional	Intersects With	Compliance Scope	CPL-01.2	Mechanisms exist to document and validate the scope of security, compliance and resilience controls that are determined to meet statutory, regulatory and/or contractual compliance obligations.	5	
4.4.4	Determine the scope of application [27001-4.3]	In order to establish, implement, operate, monitor, review, maintain, and improve information security management, first clarify the scope of application, and establish a foundation for building an information security management system that suits the organization.	Functional	Intersects With	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	8	
4.4.4.1	N/A	The organization clarifies the boundaries and applicability of information security management and determine the scope of application. [27001-4.3] a) The organization defines the scope and boundary of application, taking into account the following points. - Its own business - Structure - Location - Assets - Technology characteristics - External and internal issues - Stakeholder requirements related to information security - Interfaces and dependencies between activities performed by the organization and those performed by other organizations b) The objectives and goals of information security management vary depending on the characteristics of the organization.	Functional	Subset Of	Asset Scope Classification	AST-04.1	Mechanisms exist to determine security, compliance and resilience control applicability by identifying, assigning and documenting the appropriate asset scope categorization for all Technology Assets, Applications and/or Services (TAAS) and personnel (internal and third-parties).	10	
4.4.4.1	N/A	The organization clarifies the boundaries and applicability of information security management and determine the scope of application. [27001-4.3] a) The organization defines the scope and boundary of application, taking into account the following points. - Its own business - Structure - Location - Assets - Technology characteristics - External and internal issues - Stakeholder requirements related to information security - Interfaces and dependencies between activities performed by the organization and those performed by other organizations b) The objectives and goals of information security management vary depending on the characteristics of the organization. c) The requirements for information security management include both external and internal conditions depending on the business of each organization, and the scope of application is defined in consideration of these. - External conditions include the following. — Cultural, social, political, legal, regulatory, financial, technological, economic, natural, and competitive environment, whether international, national, regional, or concerning neighboring regions — Key drivers and trends that influence the organization's objectives — Relationships with external stakeholders and the perceptions and values of external stakeholders - Internal conditions include the following — Governance, organizational structure, roles, and accountability — Policies, objectives, and strategies developed to achieve them — Capabilities in terms of resources and knowledge (for example, capital,	Functional	Intersects With	Compliance Scope	CPL-01.2	Mechanisms exist to document and validate the scope of security, compliance and resilience controls that are determined to meet statutory, regulatory and/or contractual compliance obligations.	5	

Secure Controls Framework (SCF)

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b0bf6d69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.4.5.2	N/A	The organization formulates information security objectives and a plan to achieve them. [27001-6.2] a) The information security objectives fulfill the following. • They are consistent with the information security policy. • They are measurable (where feasible). • They take into account applicable information security requirements and the results of risk assessment and risk response. b) Information security objectives are communicated to relevant stakeholders and updated as necessary, and the following are determined in plans to achieve the objectives. • Implementation items • Necessary resources • Responsible person • Achievement deadline • Evaluation method of the results	Functional	Intersects With	Targeted Capability Maturity Levels	PRM-01.2	Mechanisms exist to define and identify targeted capability maturity levels.	5	
4.4.5.2	N/A	The organization formulates information security objectives and a plan to achieve them. [27001-6.2] a) The information security objectives fulfill the following. • They are consistent with the information security policy. • They are measurable (where feasible). • They take into account applicable information security requirements and the results of risk assessment and risk response. b) Information security objectives are communicated to relevant stakeholders and updated as necessary, and the following are determined in plans to achieve the objectives. • Implementation items • Necessary resources • Responsible person • Achievement deadline • Evaluation method of the results	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and (2) Performing a criticality analysis at predefined decision points in the Secure Development Life Cycle (SDLC).	5	
4.4.5.2	N/A	The organization formulates information security objectives and a plan to achieve them. [27001-6.2] a) The information security objectives fulfill the following. • They are consistent with the information security policy. • They are measurable (where feasible). • They take into account applicable information security requirements and the results of risk assessment and risk response. b) Information security objectives are communicated to relevant stakeholders and updated as necessary, and the following are determined in plans to achieve the objectives. • Implementation items • Necessary resources • Responsible person • Achievement deadline • Evaluation method of the results	Functional	Intersects With	Business Process Definition	PRM-06	Mechanisms exist to define business processes with consideration for security, compliance and resilience that determines: (1) The resulting risk to organizational operations, assets, individuals and other organizations; and (2) Information protection needs arising from the defined business processes and revises the processes as necessary, until an achievable set of protection needs is obtained.	5	
4.4.5.3	N/A	Top management demonstrate leadership and commitment to information security management through the following. [27001-5.1a] • Establish information security policies and objectives. • Establish information security policies and objectives which are consistent with the strategic direction of the organization. The information security policy is documented so that it can be communicated to the organization and made available to stakeholders in an appropriate manner, and evidence of top management's commitment to the information security policy is documented in the following manner. • Signatures on the documented information security policy • Minutes of meetings in which the information security policy was discussed • These are implemented to clarify the responsibilities of top management.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	8	
4.4.5.3	N/A	Top management demonstrate leadership and commitment to information security management through the following. [27001-5.1a] • Establish information security policies and objectives. • Establish information security policies and objectives which are consistent with the strategic direction of the organization. The information security policy is documented so that it can be communicated to the organization and made available to stakeholders in an appropriate manner, and evidence of top management's commitment to the information security policy is documented in the following manner. • Signatures on the documented information security policy • Minutes of meetings in which the information security policy was discussed • These are implemented to clarify the responsibilities of top management.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
4.4.6	Activities to address risks and opportunities [27001-6.1]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.4.6.1	N/A	Determine risks and opportunities. [27001-6.1.1] a) The organization determine the risks and opportunities that need to be addressed, taking into account external and internal issues and the information security-related requirements of stakeholders, in order to support the following. • Information security management achieves the organization's intended results. • Prevent or reduce undesirable impacts. • Achieve continuous improvement. In making this decision, the organization plans the following. • Activities to address the determined risks and opportunities • How activities to address risks and opportunities are integrated into the information security management process and implemented • Methods for evaluating the effectiveness of activities to address risks and opportunities b) As a record of activities to address risks and opportunities, it is confirmed that specific action plans (plans that specify the timing, contents, implementers, locations, and resources required for implementation) are prepared, and when preparing such plans, consideration is given to ensure that each action plan is implemented as part of the information security management process. In addition, it is confirmed that a method to evaluate the effectiveness of the action (method to evaluate the status of implementation and the effect of the implementation) is prepared.	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: Japan - Information System Security Management and Assessment Program (ISMAP)

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf6d9fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.4.6.1	N/A	Determine risks and opportunities. [27001-6.1.1] a) The organization determine the risks and opportunities that need to be addressed, taking into account external and internal issues and the information security-related requirements of stakeholders, in order to support the following. • Information security management achieves the organization's intended results. • Prevent or reduce undesirable impacts. • Achieve continuous improvement. In making this decision, the organization plans the following. • Activities to address the determined risks and opportunities • How activities to address risks and opportunities are integrated into the information security management process and implemented • Methods for evaluating the effectiveness of activities to address risks and opportunities b) As a record of activities to address risks and opportunities, it is confirmed that specific action plans (plans that specify the timing, contents, implementers, locations, and resources required for implementation) are prepared, and when preparing such plans, consideration is given to ensure that each action plan is implemented as part of the information security management process. In addition, it is confirmed that a method to evaluate the effectiveness of the action (method to evaluate the status of implementation and the effect of the implementation) is prepared.	Functional	Intersects With	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk.	5	
4.4.6.1	N/A	Determine risks and opportunities. [27001-6.1.1] a) The organization determine the risks and opportunities that need to be addressed, taking into account external and internal issues and the information security-related requirements of stakeholders, in order to support the following. • Information security management achieves the organization's intended results. • Prevent or reduce undesirable impacts. • Achieve continuous improvement. In making this decision, the organization plans the following. • Activities to address the determined risks and opportunities • How activities to address risks and opportunities are integrated into the information security management process and implemented • Methods for evaluating the effectiveness of activities to address risks and opportunities b) As a record of activities to address risks and opportunities, it is confirmed that specific action plans (plans that specify the timing, contents, implementers, locations, and resources required for implementation) are prepared, and when preparing such plans, consideration is given to ensure that each action plan is implemented as part of the information security management process. In addition, it is confirmed that a method to evaluate the effectiveness of the action (method to evaluate the status of implementation and the effect of the implementation) is prepared.	Functional	Intersects With	Risk Identification	RSK-03	Mechanisms exist to identify and document risks, both internal and external.	5	
4.4.6.1	N/A	Determine risks and opportunities. [27001-6.1.1] a) The organization determine the risks and opportunities that need to be addressed, taking into account external and internal issues and the information security-related requirements of stakeholders, in order to support the following. • Information security management achieves the organization's intended results. • Prevent or reduce undesirable impacts. • Achieve continuous improvement. In making this decision, the organization plans the following. • Activities to address the determined risks and opportunities • How activities to address risks and opportunities are integrated into the information security management process and implemented • Methods for evaluating the effectiveness of activities to address risks and opportunities b) As a record of activities to address risks and opportunities, it is confirmed that specific action plans (plans that specify the timing, contents, implementers, locations, and resources required for implementation) are prepared, and when preparing such plans, consideration is given to ensure that each action plan is implemented as part of the information security management process. In addition, it is confirmed that a method to evaluate the effectiveness of the action (method to evaluate the status of implementation and the effect of the implementation) is prepared.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
4.4.6.1	N/A	Determine risks and opportunities. [27001-6.1.1] a) The organization determine the risks and opportunities that need to be addressed, taking into account external and internal issues and the information security-related requirements of stakeholders, in order to support the following. • Information security management achieves the organization's intended results. • Prevent or reduce undesirable impacts. • Achieve continuous improvement. In making this decision, the organization plans the following. • Activities to address the determined risks and opportunities • How activities to address risks and opportunities are integrated into the information security management process and implemented • Methods for evaluating the effectiveness of activities to address risks and opportunities b) As a record of activities to address risks and opportunities, it is confirmed that specific action plans (plans that specify the timing, contents, implementers, locations, and resources required for implementation) are prepared, and when preparing such plans, consideration is given to ensure that each action plan is implemented as part of the information security management process. In addition, it is confirmed that a method to evaluate the effectiveness of the action (method to evaluate the status of implementation and the effect of the implementation) is prepared.	Functional	Intersects With	Risk Assessment Methodology	RSK-04.2	Mechanisms exist to implement a risk assessment methodology to ensure coverage for organizational components relevant for secure, compliant and resilient operations.	5	
4.4.6.1	N/A	Determine risks and opportunities. [27001-6.1.1] a) The organization determine the risks and opportunities that need to be addressed, taking into account external and internal issues and the information security-related requirements of stakeholders, in order to support the following. • Information security management achieves the organization's intended results. • Prevent or reduce undesirable impacts. • Achieve continuous improvement. In making this decision, the organization plans the following. • Activities to address the determined risks and opportunities • How activities to address risks and opportunities are integrated into the information security management process and implemented • Methods for evaluating the effectiveness of activities to address risks and opportunities b) As a record of activities to address risks and opportunities, it is confirmed that specific action plans (plans that specify the timing, contents, implementers, locations, and resources required for implementation) are prepared, and when preparing such plans, consideration is given to ensure that each action plan is implemented as part of the information security management process. In addition, it is confirmed that a method to evaluate the effectiveness of the action (method to evaluate the status of implementation and the effect of the implementation) is prepared.	Functional	Intersects With	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.4.6.1	N/A	Determine risks and opportunities. [27001-6.1.1] a) The organization determine the risks and opportunities that need to be addressed, taking into account external and internal issues and the information security-related requirements of stakeholders, in order to support the following. • Information security management achieves the organization's intended results. • Prevent or reduce undesirable impacts. • Achieve continuous improvement. In making this decision, the organization plans the following. • Activities to address the determined risks and opportunities • How activities to address risks and opportunities are integrated into the information security management process and implemented • Methods for evaluating the effectiveness of activities to address risks and opportunities b) As a record of activities to address risks and opportunities, it is confirmed that specific action plans (plans that specify the timing, contents, implementers, locations, and resources required for implementation) are prepared, and when preparing such plans, consideration is given to ensure that each action plan is implemented as part of the information security management process. In addition, it is confirmed that a method to evaluate the effectiveness of the action (method to evaluate the status of implementation and the effect of the implementation) is prepared.	Functional	Intersects With	Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum: (1) Deficiency tracking number; (2) Applicable security, compliance and/or resilience control; (3) Description of the deficiency(ies); (4) Risk associated with the deficiency(ies); (5) Source deficiency identification/detection; (6) Temporary compensating controls, if applicable; (7) Point of Contact (POC) (e.g., asset/process owner); (8) Resources required to conduct remediation actions; (9) Planned remedial actions to the deficiency(ies); (10) Proposed remediation timeline; and (11) Disposition statement (e.g., closeout summary).	5	
4.4.7	Information security risk assessment [27001-6.1.2]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.4.7.1	N/A	The organization defines and applies an information security risk assessment process through the following. [27001-6.1.2a) / 6.1.2b)] a) Establish and maintain information security risk criteria, including the following. • Risk acceptance criteria • Criteria for conducting information security risk assessments. b) Consideration is given to ensure that risk acceptance criteria reflect the following. • The organization's values • Objectives • Resources c) The following points are considered when formulating risk acceptance criteria. • The nature and type of causes and possible effects, and how they are measured. • Frequency of occurrence • Frequency of occurrence, time frame for considering frequency of occurrence and consequences • How to determine the risk level • Views of stakeholders • Risk criteria can be imposed on the organization or developed based on legal and regulatory requirements and other requirements agreed to by the organization. d) The following results are produced when information security assessments are repeated. • The results of information security risk assessments are consistent and valid. • The results of the information security risk assessment are comparable. Because there is no standard risk assessment method for information security management, and each organization often selects the one that	Functional	Intersects With	Risk Tolerance	RSK-01.3	Mechanisms exist to define organizational risk tolerance, the specified range of acceptable results.	5	
4.4.7.1	N/A	The organization defines and applies an information security risk assessment process through the following. [27001-6.1.2a) / 6.1.2b)] a) Establish and maintain information security risk criteria, including the following. • Risk acceptance criteria • Criteria for conducting information security risk assessments. b) Consideration is given to ensure that risk acceptance criteria reflect the following. • The organization's values • Objectives • Resources c) The following points are considered when formulating risk acceptance criteria. • The nature and type of causes and possible effects, and how they are measured. • Frequency of occurrence • Frequency of occurrence, time frame for considering frequency of occurrence and consequences • How to determine the risk level • Views of stakeholders • Risk criteria can be imposed on the organization or developed based on legal and regulatory requirements and other requirements agreed to by the organization. d) The following results are produced when information security assessments are repeated. • The results of information security risk assessments are consistent and valid. • The results of the information security risk assessment are comparable. Because there is no standard risk assessment method for information security management, and each organization often selects the one that	Functional	Intersects With	Risk Threshold	RSK-01.4	Mechanisms exist to define organizational risk threshold, the level of risk exposure above which risks are addressed and below which risks may be accepted.	5	
4.4.7.1	N/A	The organization defines and applies an information security risk assessment process through the following. [27001-6.1.2a) / 6.1.2b)] a) Establish and maintain information security risk criteria, including the following. • Risk acceptance criteria • Criteria for conducting information security risk assessments. b) Consideration is given to ensure that risk acceptance criteria reflect the following. • The organization's values • Objectives • Resources c) The following points are considered when formulating risk acceptance criteria. • The nature and type of causes and possible effects, and how they are measured. • Frequency of occurrence • Frequency of occurrence, time frame for considering frequency of occurrence and consequences • How to determine the risk level • Views of stakeholders • Risk criteria can be imposed on the organization or developed based on legal and regulatory requirements and other requirements agreed to by the organization. d) The following results are produced when information security assessments are repeated. • The results of information security risk assessments are consistent and valid. • The results of the information security risk assessment are comparable. Because there is no standard risk assessment method for information security management, and each organization often selects the one that	Functional	Intersects With	Risk Appetite	RSK-01.5	Mechanisms exist to define organizational risk appetite, the degree of uncertainty the organization is willing to accept in anticipation of a reward.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2023.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: Japan - Information System Security Management and Assessment Program (ISMAP)

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b0bf6d9fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.4.7.1	N/A	The organization defines and applies an information security risk assessment process through the following. [27001-6.1.2a) / 6.1.2b)] a) Establish and maintain information security risk criteria, including the following. • Risk acceptance criteria • Criteria for conducting information security risk assessments. b) Consideration is given to ensure that risk acceptance criteria reflect the following. • The organization's values • Objectives • Resources c) The following points are considered when formulating risk acceptance criteria. • The nature and type of causes and possible effects, and how they are measured. • Frequency of occurrence • Frequency of occurrence, time frame for considering frequency of occurrence and consequences • How to determine the risk level • Views of stakeholders • Risk criteria can be imposed on the organization or developed based on legal and regulatory requirements and other requirements agreed to by the organization. d) The following results are produced when information security assessments are repeated. • The results of information security risk assessments are consistent and valid. • The results of the information security risk assessment are comparable. Because there is no standard risk assessment method for information security management, and each organization often selects the one that	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	8	
4.4.7.1	N/A	The organization defines and applies an information security risk assessment process through the following. [27001-6.1.2a) / 6.1.2b)] a) Establish and maintain information security risk criteria, including the following. • Risk acceptance criteria • Criteria for conducting information security risk assessments. b) Consideration is given to ensure that risk acceptance criteria reflect the following. • The organization's values • Objectives • Resources c) The following points are considered when formulating risk acceptance criteria. • The nature and type of causes and possible effects, and how they are measured. • Frequency of occurrence • Frequency of occurrence, time frame for considering frequency of occurrence and consequences • How to determine the risk level • Views of stakeholders • Risk criteria can be imposed on the organization or developed based on legal and regulatory requirements and other requirements agreed to by the organization. d) The following results are produced when information security assessments are repeated. • The results of information security risk assessments are consistent and valid. • The results of the information security risk assessment are comparable. Because there is no standard risk assessment method for information security management, and each organization often selects the one that	Functional	Subset Of	Risk Assessment Methodology	RSK-04.2	Mechanisms exist to implement a risk assessment methodology to ensure coverage for organizational components relevant for secure, compliant and resilient operations.	10	
4.4.7.1	N/A	The organization defines and applies an information security risk assessment process through the following. [27001-6.1.2a) / 6.1.2b)] a) Establish and maintain information security risk criteria, including the following. • Risk acceptance criteria • Criteria for conducting information security risk assessments. b) Consideration is given to ensure that risk acceptance criteria reflect the following. • The organization's values • Objectives • Resources c) The following points are considered when formulating risk acceptance criteria. • The nature and type of causes and possible effects, and how they are measured. • Frequency of occurrence • Frequency of occurrence, time frame for considering frequency of occurrence and consequences • How to determine the risk level • Views of stakeholders • Risk criteria can be imposed on the organization or developed based on legal and regulatory requirements and other requirements agreed to by the organization. d) The following results are produced when information security assessments are repeated. • The results of information security risk assessments are consistent and valid. • The results of the information security risk assessment are comparable. Because there is no standard risk assessment method for information security management, and each organization often selects the one that	Functional	Intersects With	Risk Treatment Options	RSK-06.3	Mechanisms exist to select appropriate risk treatment options, based on applicable risk assessment findings, including: (1) Mitigating the risk to an acceptable level; (2) Avoiding the risk (e.g., terminating the project); (3) Transferring the risk to a third party (e.g., insurance, service provider, etc.); or (4) Accepting the risk.	5	
4.4.7.1	N/A	The organization defines and applies an information security risk assessment process through the following. [27001-6.1.2a) / 6.1.2b)] a) Establish and maintain information security risk criteria, including the following. • Risk acceptance criteria • Criteria for conducting information security risk assessments. b) Consideration is given to ensure that risk acceptance criteria reflect the following. • The organization's values • Objectives • Resources c) The following points are considered when formulating risk acceptance criteria. • The nature and type of causes and possible effects, and how they are measured. • Frequency of occurrence • Frequency of occurrence, time frame for considering frequency of occurrence and consequences • How to determine the risk level • Views of stakeholders • Risk criteria can be imposed on the organization or developed based on legal and regulatory requirements and other requirements agreed to by the organization. d) The following results are produced when information security assessments are repeated. • The results of information security risk assessments are consistent and valid. • The results of the information security risk assessment are comparable. Because there is no standard risk assessment method for information security management, and each organization often selects the one that	Functional	Intersects With	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.4.7.2	N/A	The organization identifies information security risks through the following. [27001-6.1.2c] a) Apply the information security risk assessment process to identify the risks associated with loss of confidentiality, integrity, and availability of information. b) Identify the risk owners in the process of identifying risks. c) Take the following into consideration when identifying risks. • Risks for which the source or cause of the risk is not known are identified, regardless of whether the source is under the control of the organization. • Carefully consider the specific chain of consequences, including spillover and cumulative effects. • In addition to identifying what could happen, scenarios are considered that show possible causes and what consequences could be caused • All significant causes and consequences • The following are identified — Risk sources — Affected areas and events — Causes and possible consequences A comprehensive list of risks, including risks associated with failure to pursue certain opportunities, is developed, as risks not identified at this stage will be excluded from future analysis.	Functional	Intersects With	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk.	5	
4.4.7.2	N/A	The organization identifies information security risks through the following. [27001-6.1.2c] a) Apply the information security risk assessment process to identify the risks associated with loss of confidentiality, integrity, and availability of information. b) Identify the risk owners in the process of identifying risks. c) Take the following into consideration when identifying risks. • Risks for which the source or cause of the risk is not known are identified, regardless of whether the source is under the control of the organization. • Carefully consider the specific chain of consequences, including spillover and cumulative effects. • In addition to identifying what could happen, scenarios are considered that show possible causes and what consequences could be caused • All significant causes and consequences • The following are identified — Risk sources — Affected areas and events — Causes and possible consequences A comprehensive list of risks, including risks associated with failure to pursue certain opportunities, is developed, as risks not identified at this stage will be excluded from future analysis.	Functional	Intersects With	Risk Identification	RSK-03	Mechanisms exist to identify and document risks, both internal and external.	5	
4.4.7.2	N/A	The organization identifies information security risks through the following. [27001-6.1.2c] a) Apply the information security risk assessment process to identify the risks associated with loss of confidentiality, integrity, and availability of information. b) Identify the risk owners in the process of identifying risks. c) Take the following into consideration when identifying risks. • Risks for which the source or cause of the risk is not known are identified, regardless of whether the source is under the control of the organization. • Carefully consider the specific chain of consequences, including spillover and cumulative effects. • In addition to identifying what could happen, scenarios are considered that show possible causes and what consequences could be caused • All significant causes and consequences • The following are identified — Risk sources — Affected areas and events — Causes and possible consequences A comprehensive list of risks, including risks associated with failure to pursue certain opportunities, is developed, as risks not identified at this stage will be excluded from future analysis.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
4.4.7.2	N/A	The organization identifies information security risks through the following. [27001-6.1.2c] a) Apply the information security risk assessment process to identify the risks associated with loss of confidentiality, integrity, and availability of information. b) Identify the risk owners in the process of identifying risks. c) Take the following into consideration when identifying risks. • Risks for which the source or cause of the risk is not known are identified, regardless of whether the source is under the control of the organization. • Carefully consider the specific chain of consequences, including spillover and cumulative effects. • In addition to identifying what could happen, scenarios are considered that show possible causes and what consequences could be caused • All significant causes and consequences • The following are identified — Risk sources — Affected areas and events — Causes and possible consequences A comprehensive list of risks, including risks associated with failure to pursue certain opportunities, is developed, as risks not identified at this stage will be excluded from future analysis.	Functional	Intersects With	Risk Catalog	RSK-03.1	Mechanisms exist to develop and keep current a catalog of applicable risks associated with the organization's business operations and technologies in use.	5	
4.4.7.2	N/A	The organization identifies information security risks through the following. [27001-6.1.2c] a) Apply the information security risk assessment process to identify the risks associated with loss of confidentiality, integrity, and availability of information. b) Identify the risk owners in the process of identifying risks. c) Take the following into consideration when identifying risks. • Risks for which the source or cause of the risk is not known are identified, regardless of whether the source is under the control of the organization. • Carefully consider the specific chain of consequences, including spillover and cumulative effects. • In addition to identifying what could happen, scenarios are considered that show possible causes and what consequences could be caused • All significant causes and consequences • The following are identified — Risk sources — Affected areas and events — Causes and possible consequences A comprehensive list of risks, including risks associated with failure to pursue certain opportunities, is developed, as risks not identified at this stage will be excluded from future analysis.	Functional	Intersects With	Risk Register	RSK-04.1	Mechanisms exist to maintain a risk register that facilitates monitoring and reporting of risks.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.4.7.3	N/A	The organization analyzes information security risks through the following. [27001-6.1.2d]] a) Perform risk analysis through the following procedure. • Identify the possible consequences of the identified risks if they actually occur. • Analyze the frequency of occurrence of the identified risks. • Determine the level of risk. • The following points are considered based on the identified threats and vulnerabilities. — Business impact of a security incident — Frequency of security incidents — Effectiveness of controls, if any b) The following points are also considered in the risk analysis. • Causes and sources of risks • Favorable and unfavorable consequences of risks • Frequency of occurrence of risks • Factors affecting the consequences and frequency of occurrence of risks The risk analysis can be conducted qualitatively, semi-quantitatively, quantitatively, or through a combination of these methods, depending on the situation.	Functional	Intersects With	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk.	5	
4.4.7.3	N/A	The organization analyzes information security risks through the following. [27001-6.1.2d]] a) Perform risk analysis through the following procedure. • Identify the possible consequences of the identified risks if they actually occur. • Analyze the frequency of occurrence of the identified risks. • Determine the level of risk. • The following points are considered based on the identified threats and vulnerabilities. — Business impact of a security incident — Frequency of security incidents — Effectiveness of controls, if any b) The following points are also considered in the risk analysis. • Causes and sources of risks • Favorable and unfavorable consequences of risks • Frequency of occurrence of risks • Factors affecting the consequences and frequency of occurrence of risks The risk analysis can be conducted qualitatively, semi-quantitatively, quantitatively, or through a combination of these methods, depending on the situation.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
4.4.7.3	N/A	The organization analyzes information security risks through the following. [27001-6.1.2d]] a) Perform risk analysis through the following procedure. • Identify the possible consequences of the identified risks if they actually occur. • Analyze the frequency of occurrence of the identified risks. • Determine the level of risk. • The following points are considered based on the identified threats and vulnerabilities. — Business impact of a security incident — Frequency of security incidents — Effectiveness of controls, if any b) The following points are also considered in the risk analysis. • Causes and sources of risks • Favorable and unfavorable consequences of risks • Frequency of occurrence of risks • Factors affecting the consequences and frequency of occurrence of risks The risk analysis can be conducted qualitatively, semi-quantitatively, quantitatively, or through a combination of these methods, depending on the situation.	Functional	Intersects With	Instances Requiring A Risk Assessment	RSK-04.3	Mechanisms exist to define instances that require a risk assessment to be performed.	5	
4.4.7.3	N/A	The organization analyzes information security risks through the following. [27001-6.1.2d]] a) Perform risk analysis through the following procedure. • Identify the possible consequences of the identified risks if they actually occur. • Analyze the frequency of occurrence of the identified risks. • Determine the level of risk. • The following points are considered based on the identified threats and vulnerabilities. — Business impact of a security incident — Frequency of security incidents — Effectiveness of controls, if any b) The following points are also considered in the risk analysis. • Causes and sources of risks • Favorable and unfavorable consequences of risks • Frequency of occurrence of risks • Factors affecting the consequences and frequency of occurrence of risks The risk analysis can be conducted qualitatively, semi-quantitatively, quantitatively, or through a combination of these methods, depending on the situation.	Functional	Intersects With	Business Impact Analysis (BIA)	RSK-08	Mechanisms exist to conduct a Business Impact Analysis (BIA) to identify and assess security, compliance and resilience risks.	5	
4.4.7.4	N/A	The organization evaluates information security risks through the following. [27001-6.1.2e]] • Compare the risk level determined as a result of the risk analysis with the risk criteria. • Prioritization is performed for risk response. • The results of the risk assessment are stored for use in future improvements. When performing prioritization for risk responses, a broader range of situations, the level of risk accepted by others and laws, regulations, and other requirements are considered.	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	5	
4.4.7.4	N/A	The organization evaluates information security risks through the following. [27001-6.1.2e]] • Compare the risk level determined as a result of the risk analysis with the risk criteria. • Prioritization is performed for risk response. • The results of the risk assessment are stored for use in future improvements. When performing prioritization for risk responses, a broader range of situations, the level of risk accepted by others and laws, regulations, and other requirements are considered.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
4.4.7.4	N/A	The organization evaluates information security risks through the following. [27001-6.1.2e]] • Compare the risk level determined as a result of the risk analysis with the risk criteria. • Prioritization is performed for risk response. • The results of the risk assessment are stored for use in future improvements. When performing prioritization for risk responses, a broader range of situations, the level of risk accepted by others and laws, regulations, and other requirements are considered.	Functional	Intersects With	Risk Assessment Methodology	RSK-04.2	Mechanisms exist to implement a risk assessment methodology to ensure coverage for organizational components relevant for secure, compliant and resilient operations.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.4.7.4	N/A	The organization evaluates information security risks through the following. [27001-6.1.2e]] - Compare the risk level determined as a result of the risk analysis with the risk criteria. - Prioritization is performed for risk response. - The results of the risk assessment are stored for use in future improvements. When performing prioritization for risk responses, a broader range of situations, the level of risk accepted by others and laws, regulations, and other requirements are considered.	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or resilience-related: (1) Assessments; (2) Audits; and/or (3) Incidents.	5	
4.4.8	Information security risk response [27001-6.1.3]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.4.8.1	N/A	The organization selects appropriate information security risk response options, taking into account the results of the information security assessment. [27001-6.1.3a]] Information security risk response options include the following. - Avoidance of risk by deciding not to initiate or continue activities that create risk - Acceptance of risk or bearing of risk for the purpose of an opportunity - Elimination of sources of risk - Changing the frequency of occurrence - Changing the outcome - Sharing risks with others (including through contracts and risk finance) - Retention of risk through decision-making based on information Furthermore, the reasons for selecting any of the options are clarified and described in order to help evaluate and improve the risk response.	Functional	Subset Of	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or resilience-related: (1) Assessments; (2) Audits; and/or (3) Incidents.	10	
4.4.8.1	N/A	The organization selects appropriate information security risk response options, taking into account the results of the information security assessment. [27001-6.1.3a]] Information security risk response options include the following. - Avoidance of risk by deciding not to initiate or continue activities that create risk - Acceptance of risk or bearing of risk for the purpose of an opportunity - Elimination of sources of risk - Changing the frequency of occurrence - Changing the outcome - Sharing risks with others (including through contracts and risk finance) - Retention of risk through decision-making based on information Furthermore, the reasons for selecting any of the options are clarified and described in order to help evaluate and improve the risk response.	Functional	Intersects With	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	5	
4.4.8.1	N/A	The organization selects appropriate information security risk response options, taking into account the results of the information security assessment. [27001-6.1.3a]] Information security risk response options include the following. - Avoidance of risk by deciding not to initiate or continue activities that create risk - Acceptance of risk or bearing of risk for the purpose of an opportunity - Elimination of sources of risk - Changing the frequency of occurrence - Changing the outcome - Sharing risks with others (including through contracts and risk finance) - Retention of risk through decision-making based on information Furthermore, the reasons for selecting any of the options are clarified and described in order to help evaluate and improve the risk response.	Functional	Intersects With	Risk Treatment Options	RSK-06.3	Mechanisms exist to select appropriate risk treatment options, based on applicable risk assessment findings, including: (1) Mitigating the risk to an acceptable level; (2) Avoiding the risk (e.g., terminating the project); (3) Transferring the risk to a third party (e.g., insurance, service provider, etc.); or (4) Accepting the risk.	8	
4.4.8.1	N/A	The organization selects appropriate information security risk response options, taking into account the results of the information security assessment. [27001-6.1.3a]] Information security risk response options include the following. - Avoidance of risk by deciding not to initiate or continue activities that create risk - Acceptance of risk or bearing of risk for the purpose of an opportunity - Elimination of sources of risk - Changing the frequency of occurrence - Changing the outcome - Sharing risks with others (including through contracts and risk finance) - Retention of risk through decision-making based on information Furthermore, the reasons for selecting any of the options are clarified and described in order to help evaluate and improve the risk response.	Functional	Intersects With	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	8	
4.4.8.2	N/A	The organization determines all controls necessary to implement the selected information security risk response. [27001-6.1.3b]] The purpose of the controls (control objectives) and the controls are discussed after determining the policy for risk response. Select appropriate information security measures by balancing the effects of the measures with the cost and effort required for the measures, taking into account the following. - Acceptable level of risk - Relevant laws and regulations - Regulatory and contractual requirements - Other social responsibilities In selecting specific controls, appropriate controls are selected from the controls criteria corresponding to the control objectives. However, because the controls criteria do not cover everything, other controls can be added depending on the business and operations of the organization.	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or resilience-related: (1) Assessments; (2) Audits; and/or (3) Incidents.	8	
4.4.8.2	N/A	The organization determines all controls necessary to implement the selected information security risk response. [27001-6.1.3b]] The purpose of the controls (control objectives) and the controls are discussed after determining the policy for risk response. Select appropriate information security measures by balancing the effects of the measures with the cost and effort required for the measures, taking into account the following. - Acceptable level of risk - Relevant laws and regulations - Regulatory and contractual requirements - Other social responsibilities In selecting specific controls, appropriate controls are selected from the controls criteria corresponding to the control objectives. However, because the controls criteria do not cover everything, other controls can be added depending on the business and operations of the organization.	Functional	Intersects With	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bfb6d9fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.4.8.2	N/A	The organization determines all controls necessary to implement the selected information security risk response. [27001-6.1.3b]] The purpose of the controls (control objectives) and the controls are discussed after determining the policy for risk response. Select appropriate information security measures by balancing the effects of the measures with the cost and effort required for the measures, taking into account the following. • Acceptable level of risk • Relevant laws and regulations • Regulatory and contractual requirements • Other social responsibilities In selecting specific controls, appropriate controls are selected from the controls criteria corresponding to the control objectives. However, because the controls criteria do not cover everything, other controls can be added depending on the business and operations of the organization.	Functional	Intersects With	Risk Treatment Options	RSK-06.3	Mechanisms exist to select appropriate risk treatment options, based on applicable risk assessment findings, including: (1) Mitigating the risk to an acceptable level; (2) Avoiding the risk (e.g., terminating the project); (3) Transferring the risk to a third party (e.g., insurance, service provider, etc.); or (4) Accepting the risk.	8	
4.4.8.2	N/A	The organization determines all controls necessary to implement the selected information security risk response. [27001-6.1.3b]] The purpose of the controls (control objectives) and the controls are discussed after determining the policy for risk response. Select appropriate information security measures by balancing the effects of the measures with the cost and effort required for the measures, taking into account the following. • Acceptable level of risk • Relevant laws and regulations • Regulatory and contractual requirements • Other social responsibilities In selecting specific controls, appropriate controls are selected from the controls criteria corresponding to the control objectives. However, because the controls criteria do not cover everything, other controls can be added depending on the business and operations of the organization.	Functional	Subset Of	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	10	
4.4.8.3	N/A	The organization verifies that no controls have been overlooked. [27001-6.1.3c]] The organization refers to the controls criteria to ensure that no necessary controls have been overlooked, and other control objectives and controls can be added if control objectives and controls other than those shown in the controls criteria become necessary.	Functional	Subset Of	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	10	
4.4.8.4	N/A	The organization formulates an information security risk response plan. [27001-6.1.3e]] a) The information security risk response plan includes the following. • Rationale for the selection of response options, including expected effects • The person who approves the information security risk response plan and the person responsible for the implementation of the response plan • Details of response • Necessary resources • Cost, effort, and constraints • Requirements for later reporting and monitoring • Targets for each milestone in the response process • Response timing and schedule b) Responsibility and authority In information security management, final approval is almost always given by the top management, and the responsibility is concentrated on the top management. On the other hand, the risk owners have the responsibility and authority for information security risk assessment and risk response. Because the risk owners are often the top management or those who are appointed by the top management and to whom the responsibility and authority are delegated, the responsibilities of the top management and risk owners are clarified in the information security management.	Functional	Subset Of	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	10	
4.4.8.5	N/A	The organization obtains approval from the risk owners for the information security risk response plan and have the risk owners accept the residual information security risks. [27001-6.1.3f]] Once control objectives and controls have been selected for all risks, the residual risks are clarified and a plan for future action is developed. The following points are taken into account when preparing the plan. • When it will be technically feasible • When it will be feasible in terms of costs Residual risks are periodically reviewed and, if necessary, targeted for action, and residual risks after risk response are recognized by the management and other stakeholders in addition to the risk owners. In addition, approved minutes of meetings are kept properly to clarify the responsibility of the risk owners.	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or resilience-related: (1) Assessments; (2) Audits; and/or (3) Incidents.	8	
4.4.8.5	N/A	The organization obtains approval from the risk owners for the information security risk response plan and have the risk owners accept the residual information security risks. [27001-6.1.3f]] Once control objectives and controls have been selected for all risks, the residual risks are clarified and a plan for future action is developed. The following points are taken into account when preparing the plan. • When it will be technically feasible • When it will be feasible in terms of costs Residual risks are periodically reviewed and, if necessary, targeted for action, and residual risks after risk response are recognized by the management and other stakeholders in addition to the risk owners. In addition, approved minutes of meetings are kept properly to clarify the responsibility of the risk owners.	Functional	Subset Of	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	10	
4.5	Implementation of information security management [27001-8]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.5.1	Resource management [27001-7.1 / 5.1]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.5.1.1	N/A	The organization determines and provides the resources necessary to establish, implement, maintain, and continuously improve information security management. [27001-7.1] In order to meet the control objectives, the organization continuously implements the controls and secure the management resources so that they can be provided appropriately at the right time to cope with changes in the environment, such as an increase in the number of personnel and systems.	Functional	Subset Of	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	10	
4.5.1.1	N/A	The organization determines and provides the resources necessary to establish, implement, maintain, and continuously improve information security management. [27001-7.1] In order to meet the control objectives, the organization continuously implements the controls and secure the management resources so that they can be provided appropriately at the right time to cope with changes in the environment, such as an increase in the number of personnel and systems.	Functional	Intersects With	Security, Compliance & Resilience Resource Management	PRM-02	Mechanisms exist to address all capital planning and investment requests, including the resources needed to implement the Security, Compliance & Resilience Program (SCRPM) and document all exceptions to this requirement.	8	
4.5.1.1	N/A	The organization determines and provides the resources necessary to establish, implement, maintain, and continuously improve information security management. [27001-7.1] In order to meet the control objectives, the organization continuously implements the controls and secure the management resources so that they can be provided appropriately at the right time to cope with changes in the environment, such as an increase in the number of personnel and systems.	Functional	Intersects With	Security, Compliance & Resilience in Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	8	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b0bf6d69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.5.1.1	N/A	The organization determines and provides the resources necessary to establish, implement, maintain, and continuously improve information security management. [27001-7.1] In order to meet the control objectives, the organization continuously implements the controls and secure the management resources so that they can be provided appropriately at the right time to cope with changes in the environment, such as an increase in the number of personnel and systems.	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and (2) Performing a criticality analysis at predefined decision points in the Secure Development Life Cycle (SDLC).	5	
4.5.1.1	N/A	The organization determines and provides the resources necessary to establish, implement, maintain, and continuously improve information security management. [27001-7.1] In order to meet the control objectives, the organization continuously implements the controls and secure the management resources so that they can be provided appropriately at the right time to cope with changes in the environment, such as an increase in the number of personnel and systems.	Functional	Intersects With	Business Process Definition	PRM-06	Mechanisms exist to define business processes with consideration for security, compliance and resilience that determines: (1) The resulting risk to organizational operations, assets, individuals and other organizations; and (2) Information protection needs arising from the defined business processes and revises the processes as necessary, until an achievable set of protection needs is obtained.	5	
4.5.1.2	N/A	Top management allocates the following resources to ensure that the resources required for information security management are available. [27001-5.1c] • People or organizations required for each process of information security management • Facilities, equipment, and systems required for each process of information security management • Costs required for the above	Functional	Subset Of	Allocation of Resources	PRM-03	Mechanisms exist to identify and allocate resources for management, operational, technical and data protection requirements within business process planning for projects / initiatives.	10	
4.5.2	Competence, awareness [27001-7.2 / 7.3 / 5.1]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.5.2.1	N/A	Top management communicates the importance of effective information security management and compliance with its requirements. [27001-5.1d] Together with the information security policy, top management communicates to the stakeholders that while top management is responsible for information security management, implementation requires the cooperation of the entire organization. In addition, standards such as information classification are established so that organizations can make the same decisions according to the same regulations. In the case of information such as personal information, which can have partially different interpretations by different organizations, stakeholders are communicated to after clarifying your company's approach in addition to the general approach.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	8	
4.5.2.1	N/A	Top management communicates the importance of effective information security management and compliance with its requirements. [27001-5.1d] Together with the information security policy, top management communicates to the stakeholders that while top management is responsible for information security management, implementation requires the cooperation of the entire organization. In addition, standards such as information classification are established so that organizations can make the same decisions according to the same regulations. In the case of information such as personal information, which can have partially different interpretations by different organizations, stakeholders are communicated to after clarifying your company's approach in addition to the general approach.	Functional	Intersects With	Business As Usual (BAU) Security, Compliance & Resilience Practices	GOV-14	Mechanisms exist to incorporate security, compliance and resilience principles into Business As Usual (BAU) practices through executive leadership involvement.	8	
4.5.2.1	N/A	Top management communicates the importance of effective information security management and compliance with its requirements. [27001-5.1d] Together with the information security policy, top management communicates to the stakeholders that while top management is responsible for information security management, implementation requires the cooperation of the entire organization. In addition, standards such as information classification are established so that organizations can make the same decisions according to the same regulations. In the case of information such as personal information, which can have partially different interpretations by different organizations, stakeholders are communicated to after clarifying your company's approach in addition to the general approach.	Functional	Intersects With	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	8	
4.5.2.2	N/A	The organization determines the competencies required for the person (or people) under its control to perform tasks that affect the organization's information security performance. [27001-7.2a] The organization identifies the tasks related to and affecting information security management, and create a separation of duties that clarifies the roles. The following points are clarified in these separation of duties. • Job title • Job description • Scope of responsibility of the responsible person • Knowledge required for the job • Qualifications required for the job • Experience required for the job Because such knowledge, qualifications, and experience can change due to changes in the environment or objectives, they are reviewed from time to time to ensure that they are up-to-date.	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing screening criteria for individuals filling those positions.	5	
4.5.2.2	N/A	The organization determines the competencies required for the person (or people) under its control to perform tasks that affect the organization's information security performance. [27001-7.2a] The organization identifies the tasks related to and affecting information security management, and create a separation of duties that clarifies the roles. The following points are clarified in these separation of duties. • Job title • Job description • Scope of responsibility of the responsible person • Knowledge required for the job • Qualifications required for the job • Experience required for the job Because such knowledge, qualifications, and experience can change due to changes in the environment or objectives, they are reviewed from time to time to ensure that they are up-to-date.	Functional	Subset Of	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	10	
4.5.2.2	N/A	The organization determines the competencies required for the person (or people) under its control to perform tasks that affect the organization's information security performance. [27001-7.2a] The organization identifies the tasks related to and affecting information security management, and create a separation of duties that clarifies the roles. The following points are clarified in these separation of duties. • Job title • Job description • Scope of responsibility of the responsible person • Knowledge required for the job • Qualifications required for the job • Experience required for the job Because such knowledge, qualifications, and experience can change due to changes in the environment or objectives, they are reviewed from time to time to ensure that they are up-to-date.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.5.2.2	N/A	The organization determines the competencies required for the person (or people) under its control to perform tasks that affect the organization's information security performance. [27001-7.2a] The organization identifies the tasks related to and affecting information security management, and create a separation of duties that clarifies the roles. The following points are clarified in these separation of duties. • Job title • Job description • Scope of responsibility of the responsible person • Knowledge required for the job • Qualifications required for the job • Experience required for the job Because such knowledge, qualifications, and experience can change due to changes in the environment or objectives, they are reviewed from time to time to ensure that they are up-to-date.	Functional	Intersects With	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	5	
4.5.2.2	N/A	The organization determines the competencies required for the person (or people) under its control to perform tasks that affect the organization's information security performance. [27001-7.2a] The organization identifies the tasks related to and affecting information security management, and create a separation of duties that clarifies the roles. The following points are clarified in these separation of duties. • Job title • Job description • Scope of responsibility of the responsible person • Knowledge required for the job • Qualifications required for the job • Experience required for the job Because such knowledge, qualifications, and experience can change due to changes in the environment or objectives, they are reviewed from time to time to ensure that they are up-to-date.	Functional	Intersects With	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	5	
4.5.2.3	N/A	The organization ensures that the person (or people) under its control who perform tasks that affect the organization's information security performance are equipped with competence based on appropriate education, training, or experience. [27001-7.2b] Applicable actions include, for example, providing education and training, mentoring, and reassignment of currently employed people (in cases where education and training are deemed to not be too late, personnel with appropriate competence can be hired, and in cases where the work is not closely related to internal operations, it can be outsourced.)	Functional	Intersects With	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	8	
4.5.2.4	N/A	The organization takes actions to ensure that employees acquire the necessary competencies and evaluate the effectiveness of the actions taken. [27001-7.2c] Education and training are important as a means of acquiring the necessary competence. Education is conducted to provide the necessary knowledge, and training is conducted to provide the necessary skills and experience. The content of training is effective, including not only general knowledge of threats and vulnerabilities, but also content that reflects the characteristics of the organization, such as business risks. The following are conducted to confirm whether or not the necessary competencies have been acquired as a result of the education and training. • Confirmation test of knowledge • Practical tests of skills • Benchmarking using checklists, etc. The results of these tests are recorded to ensure objectivity in personnel selection.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and (4) Technological developments.	5	
4.5.2.4	N/A	The organization takes actions to ensure that employees acquire the necessary competencies and evaluate the effectiveness of the actions taken. [27001-7.2c] Education and training are important as a means of acquiring the necessary competence. Education is conducted to provide the necessary knowledge, and training is conducted to provide the necessary skills and experience. The content of training is effective, including not only general knowledge of threats and vulnerabilities, but also content that reflects the characteristics of the organization, such as business risks. The following are conducted to confirm whether or not the necessary competencies have been acquired as a result of the education and training. • Confirmation test of knowledge • Practical tests of skills • Benchmarking using checklists, etc. The results of these tests are recorded to ensure objectivity in personnel selection.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5	
4.5.2.4	N/A	The organization takes actions to ensure that employees acquire the necessary competencies and evaluate the effectiveness of the actions taken. [27001-7.2c] Education and training are important as a means of acquiring the necessary competence. Education is conducted to provide the necessary knowledge, and training is conducted to provide the necessary skills and experience. The content of training is effective, including not only general knowledge of threats and vulnerabilities, but also content that reflects the characteristics of the organization, such as business risks. The following are conducted to confirm whether or not the necessary competencies have been acquired as a result of the education and training. • Confirmation test of knowledge • Practical tests of skills • Benchmarking using checklists, etc. The results of these tests are recorded to ensure objectivity in personnel selection.	Functional	Intersects With	Continuing Professional Education (CPE) - Security, Compliance & Resilience Personnel	SAT-03.7	Mechanisms exist to ensure security, compliance and resilience personnel receive Continuing Professional Education (CPE) training to maintain currency and proficiency with industry-recognized secure practices that are pertinent to their assigned roles and responsibilities.	5	
4.5.2.4	N/A	The organization takes actions to ensure that employees acquire the necessary competencies and evaluate the effectiveness of the actions taken. [27001-7.2c] Education and training are important as a means of acquiring the necessary competence. Education is conducted to provide the necessary knowledge, and training is conducted to provide the necessary skills and experience. The content of training is effective, including not only general knowledge of threats and vulnerabilities, but also content that reflects the characteristics of the organization, such as business risks. The following are conducted to confirm whether or not the necessary competencies have been acquired as a result of the education and training. • Confirmation test of knowledge • Practical tests of skills • Benchmarking using checklists, etc. The results of these tests are recorded to ensure objectivity in personnel selection.	Functional	Intersects With	Security, Compliance & Resilience Training Records	SAT-04	Mechanisms exist to document, retain and monitor individual training activities, including: (1) Initial security, compliance and resilience awareness training; (2) Recurring awareness training; and (3) Technology Assets, Applications and/or Services (TAAS)-specific training.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b0bf6d9fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.5.2.5	N/A	The organization keeps track of personal competencies and retains appropriate documented information as evidence for a period of time determined by the organization. [27001-7.2d] The following are considered and implemented regularly for education and training. • Basic plan for education and training • Education and training implementation plan • Confirmation tests or evaluation reports In the case of partial exemption of education and training, it is clarified which skills, experience and qualifications are applicable, an investigation is performed for each responsible person, and a list is created. Clarify and update expiration dates for qualifications.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and (4) Technological developments.	5	
4.5.2.5	N/A	The organization keeps track of personal competencies and retains appropriate documented information as evidence for a period of time determined by the organization. [27001-7.2d] The following are considered and implemented regularly for education and training. • Basic plan for education and training • Education and training implementation plan • Confirmation tests or evaluation reports In the case of partial exemption of education and training, it is clarified which skills, experience and qualifications are applicable, an investigation is performed for each responsible person, and a list is created. Clarify and update expiration dates for qualifications.	Functional	Intersects With	Security, Compliance & Resilience Training Records	SAT-04	Mechanisms exist to document, retain and monitor individual training activities, including: (1) Initial security, compliance and resilience awareness training; (2) Recurring awareness training; and (3) Technology Assets, Applications and/or Services (TAAS)-specific training.	5	
4.5.2.6	N/A	All people working under the control of the organization are aware of the information security policy. [27001-7.3a] The purpose and importance of the organization's information security activities are communicated as part of the information security policy notification and education, to increase the understanding of the people involved as to why the controls are being implemented.	Functional	Intersects With	User Awareness	HRS-03.1	Mechanisms exist to communicate with users about their roles and responsibilities to maintain a safe and secure working environment.	8	
4.5.2.6	N/A	All people working under the control of the organization are aware of the information security policy. [27001-7.3a] The purpose and importance of the organization's information security activities are communicated as part of the information security policy notification and education, to increase the understanding of the people involved as to why the controls are being implemented.	Functional	Intersects With	Formal Indoctrination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	8	
4.5.2.6	N/A	All people working under the control of the organization are aware of the information security policy. [27001-7.3a] The purpose and importance of the organization's information security activities are communicated as part of the information security policy notification and education, to increase the understanding of the people involved as to why the controls are being implemented.	Functional	Subset Of	Policy Familiarization & Acknowledgement	HRS-05.7	Mechanisms exist to ensure personnel receive recurring familiarization with the organization's security, compliance and resilience policies and provide acknowledgement.	10	
4.5.2.7	N/A	People working under the control of the organization recognize their own contribution to the effectiveness of information security management, including the benefits derived from improved information security performance. [27001-7.3b] Clarify the role of each person and their contribution to the effectiveness of information security management by communicating the following points to people working under the control of the organization. • Their respective roles in information security management • The tasks and procedures to execute the roles (including the reporting procedures when anomalies are detected) • Location of documents describing the above	Functional	Subset Of	User Awareness	HRS-03.1	Mechanisms exist to communicate with users about their roles and responsibilities to maintain a safe and secure working environment.	10	
4.5.2.8	N/A	People working under the control of the organization are aware of the implications of not complying with the requirements of information security management. [27001-7.3c]	Functional	Intersects With	User Awareness	HRS-03.1	Mechanisms exist to communicate with users about their roles and responsibilities to maintain a safe and secure working environment.	8	
4.5.2.8	N/A	People working under the control of the organization are aware of the implications of not complying with the requirements of information security management. [27001-7.3c]	Functional	Subset Of	Policy Familiarization & Acknowledgement	HRS-05.7	Mechanisms exist to ensure personnel receive recurring familiarization with the organization's security, compliance and resilience policies and provide acknowledgement.	10	
4.5.3	Communication [27001-7.4]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.5.3.1	N/A	The organization determines the need to conduct internal and external communications related to information security management. [27001-7.4] a)The following are considered when implementing internal and external communications. • The content of the communication (what is to be communicated) • The timing of the communication • Target audience of the communication • The person who conducts communication • Communication implementation process b)Internal communication is conducted with the following parties as appropriate and on a regular basis. • Top management • Persons authorized to ensure that information security management complies with the requirements of this management standard • Those who have the authority to report the performance of information security management to top management or within the organization • Employees in the organization c) Communication is conducted with the following parties in external communication, as necessary. • Suppliers, partners, and other stakeholders in the supply chain • Parent company and group companies • Ministries and government agencies that oversee the security of the organization • Security organizations and associations to which the organization belongs	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
4.5.3.1	N/A	The organization determines the need to conduct internal and external communications related to information security management. [27001-7.4] a)The following are considered when implementing internal and external communications. • The content of the communication (what is to be communicated) • The timing of the communication • Target audience of the communication • The person who conducts communication • Communication implementation process b)Internal communication is conducted with the following parties as appropriate and on a regular basis. • Top management • Persons authorized to ensure that information security management complies with the requirements of this management standard • Those who have the authority to report the performance of information security management to top management or within the organization • Employees in the organization c) Communication is conducted with the following parties in external communication, as necessary. • Suppliers, partners, and other stakeholders in the supply chain • Parent company and group companies • Ministries and government agencies that oversee the security of the organization • Security organizations and associations to which the organization belongs	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRP), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b0bdf6d9fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.5.3.1	N/A	The organization determines the need to conduct internal and external communications related to information security management. [27001-7.4] a)The following are considered when implementing internal and external communications. • The content of the communication (what is to be communicated) • The timing of the communication • Target audience of the communication • The person who conducts communication • Communication implementation process b)Internal communication is conducted with the following parties as appropriate and on a regular basis. • Top management • Persons authorized to ensure that information security management complies with the requirements of this management standard • Those who have the authority to report the performance of information security management to top management or within the organization • Employees in the organization c) Communication is conducted with the following parties in external communication, as necessary. • Suppliers, partners, and other stakeholders in the supply chain • Parent company and group companies • Ministries and government agencies that oversee the security of the organization • Security organizations and associations to which the organization belongs	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
4.5.3.1	N/A	The organization determines the need to conduct internal and external communications related to information security management. [27001-7.4] a)The following are considered when implementing internal and external communications. • The content of the communication (what is to be communicated) • The timing of the communication • Target audience of the communication • The person who conducts communication • Communication implementation process b)Internal communication is conducted with the following parties as appropriate and on a regular basis. • Top management • Persons authorized to ensure that information security management complies with the requirements of this management standard • Those who have the authority to report the performance of information security management to top management or within the organization • Employees in the organization c) Communication is conducted with the following parties in external communication, as necessary. • Suppliers, partners, and other stakeholders in the supply chain • Parent company and group companies • Ministries and government agencies that oversee the security of the organization • Security organizations and associations to which the organization belongs	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5	
4.5.3.1	N/A	The organization determines the need to conduct internal and external communications related to information security management. [27001-7.4] a)The following are considered when implementing internal and external communications. • The content of the communication (what is to be communicated) • The timing of the communication • Target audience of the communication • The person who conducts communication • Communication implementation process b)Internal communication is conducted with the following parties as appropriate and on a regular basis. • Top management • Persons authorized to ensure that information security management complies with the requirements of this management standard • Those who have the authority to report the performance of information security management to top management or within the organization • Employees in the organization c) Communication is conducted with the following parties in external communication, as necessary. • Suppliers, partners, and other stakeholders in the supply chain • Parent company and group companies • Ministries and government agencies that oversee the security of the organization • Security organizations and associations to which the organization belongs	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	5	
4.5.4	Planning and management of information security management [27001-8.1]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.5.4.1	N/A	The organization plans, implements, and manages the processes necessary to implement activities that address risks and opportunities to meet information security requirements. [27001-8.1]	Functional	Subset Of	Security, Compliance & Resilience Program (SCRPP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
4.5.4.2	N/A	The organization implements a plan to achieve its information security objectives. [27001-8.1]	Functional	Subset Of	Security, Compliance & Resilience Program (SCRPP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
4.5.4.3	N/A	The organization maintains documented information to provide confidence that the plan has been implemented as planned. [27001-8.1] The organization confirms that the following information is collected in the documented information. • Implementation status of controls • Effectiveness of the controls • Changes in the environment surrounding the controls The organization also establishes a system for identifying and determining this information.	Functional	Intersects With	Ability To Demonstrate Conformity	CPL-01.3	Mechanisms exist to ensure the organization is able to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	
4.5.4.3	N/A	The organization maintains documented information to provide confidence that the plan has been implemented as planned. [27001-8.1] The organization confirms that the following information is collected in the documented information. • Implementation status of controls • Effectiveness of the controls • Changes in the environment surrounding the controls The organization also establishes a system for identifying and determining this information.	Functional	Intersects With	Conformity Assessment	CPL-01.4	Mechanisms exist to conduct assessments to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	
4.5.4.4	N/A	The organization manages planned changes, reviews the consequences of unintended changes, and takes action to mitigate adverse effects, as necessary. [27001-8.1]	Functional	Subset Of	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	10	
4.5.4.5	N/A	The organization determines and controls the processes to be outsourced. [27001-8.1]	Functional	Subset Of	Outsourcing Non-Essential Functions or Services	SEA-02.2	Mechanisms exist to identify non-essential functions or services that are capable of being outsourced to external service providers and align with the organization's enterprise architecture and security standards.	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-home/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf6d9e91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.5.5	Implementation of an information security risk assessment [27001-8.2.8.3]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.5.5.1	N/A	The organization performs an information security risk assessment in any of the following cases. [27001-8.2] • At predetermined intervals • When a significant change is proposed • When a significant change occurs	Functional	Subset Of	Instances Requiring A Risk Assessment	RSK-04.3	Mechanisms exist to define instances that require a risk assessment to be performed.	10	
4.5.5.2	N/A	The organization implements an information security risk response plan. [27001-8.3] Measures are taken to ensure that the identified individual responsibilities are fulfilled in the implementation of the information security risk response plan.	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	10	
4.5.5.2	N/A	The organization implements an information security risk response plan. [27001-8.3] Measures are taken to ensure that the identified individual responsibilities are fulfilled in the implementation of the information security risk response plan.	Functional	Intersects With	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	8	
4.5.5.3	N/A	Top management provides sufficient management resources for the information security risk response plan. The information security risk response plan requires adequate management resources, and the following points are considered. • Costs, manpower, man-hours, and technology for the implementation and operation of controls • Costs for temporary response in the event of a security incident • Costs for other risk responses The management resources required to measure the effectiveness of the controls in implementation are considered and budgeted.	Functional	Intersects With	Security, Compliance & Resilience Resource Management	PRM-02	Mechanisms exist to address all capital planning and investment requests, including the resources needed to implement the Security, Compliance & Resilience Program (SCRPP) and document all exceptions to this requirement.	5	
4.5.5.3	N/A	Top management provides sufficient management resources for the information security risk response plan. The information security risk response plan requires adequate management resources, and the following points are considered. • Costs, manpower, man-hours, and technology for the implementation and operation of controls • Costs for temporary response in the event of a security incident • Costs for other risk responses The management resources required to measure the effectiveness of the controls in implementation are considered and budgeted.	Functional	Intersects With	Prioritization To Address Evolving Risks & Threats	PRM-02.1	Mechanisms exist to integrate foundational cybersecurity practices with advanced technologies to maintain situation awareness of and minimize the organization's exposure to evolving risks and threats.	3	
4.5.5.3	N/A	Top management provides sufficient management resources for the information security risk response plan. The information security risk response plan requires adequate management resources, and the following points are considered. • Costs, manpower, man-hours, and technology for the implementation and operation of controls • Costs for temporary response in the event of a security incident • Costs for other risk responses The management resources required to measure the effectiveness of the controls in implementation are considered and budgeted.	Functional	Intersects With	Allocation of Resources	PRM-03	Mechanisms exist to identify and allocate resources for management, operational, technical and data protection requirements within business process planning for projects / initiatives.	8	
4.6	Monitoring and review of information security management [27001-5.1 / 8.2 / 9 / 10.2]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.6.1	Continual improvement of effectiveness [27001-10.2 / 8.2 / 9.2 / 9.3 / 5.1]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.6.1.1	N/A	The organization continuously improves the appropriateness, adequacy, and effectiveness of its information security management by implementing the following. [27001-10.2 / 8.2 / 9.2 / 9.3] • Periodic information security risk assessment • Periodic information security internal assessments • Periodic management review by top management In the process of continuous improvement, nonconformities are detected and dealt with not only with the controls that have been implemented so far, but also by responding to new threats and vulnerabilities due to changes in the environment.	Functional	Intersects With	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRPP).	5	
4.6.1.1	N/A	The organization continuously improves the appropriateness, adequacy, and effectiveness of its information security management by implementing the following. [27001-10.2 / 8.2 / 9.2 / 9.3] • Periodic information security risk assessment • Periodic information security internal assessments • Periodic management review by top management In the process of continuous improvement, nonconformities are detected and dealt with not only with the controls that have been implemented so far, but also by responding to new threats and vulnerabilities due to changes in the environment.	Functional	Intersects With	Commitment To Continual Improvements	GOV-01.3	Mechanisms exist to commit appropriate resources needed for continual improvement of the organization's Security, Compliance & Resilience Program (SCRPP), including: (1) Staffing; (2) Budget; (3) Processes; and (4) Technologies.	5	
4.6.1.1	N/A	The organization continuously improves the appropriateness, adequacy, and effectiveness of its information security management by implementing the following. [27001-10.2 / 8.2 / 9.2 / 9.3] • Periodic information security risk assessment • Periodic information security internal assessments • Periodic management review by top management In the process of continuous improvement, nonconformities are detected and dealt with not only with the controls that have been implemented so far, but also by responding to new threats and vulnerabilities due to changes in the environment.	Functional	Intersects With	Non-Compliance Oversight	CPL-01.1	Mechanisms exist to document and review instances of non-compliance with statutory, regulatory and/or contractual obligations to develop appropriate risk mitigation actions.	5	
4.6.1.1	N/A	The organization continuously improves the appropriateness, adequacy, and effectiveness of its information security management by implementing the following. [27001-10.2 / 8.2 / 9.2 / 9.3] • Periodic information security risk assessment • Periodic information security internal assessments • Periodic management review by top management In the process of continuous improvement, nonconformities are detected and dealt with not only with the controls that have been implemented so far, but also by responding to new threats and vulnerabilities due to changes in the environment.	Functional	Intersects With	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	5	
4.6.1.1	N/A	The organization continuously improves the appropriateness, adequacy, and effectiveness of its information security management by implementing the following. [27001-10.2 / 8.2 / 9.2 / 9.3] • Periodic information security risk assessment • Periodic information security internal assessments • Periodic management review by top management In the process of continuous improvement, nonconformities are detected and dealt with not only with the controls that have been implemented so far, but also by responding to new threats and vulnerabilities due to changes in the environment.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
4.6.1.1	N/A	The organization continuously improves the appropriateness, adequacy, and effectiveness of its information security management by implementing the following. [27001-10.2 / 8.2 / 9.2 / 9.3] • Periodic information security risk assessment • Periodic information security internal assessments • Periodic management review by top management In the process of continuous improvement, nonconformities are detected and dealt with not only with the controls that have been implemented so far, but also by responding to new threats and vulnerabilities due to changes in the environment.	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf6d9f91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.6.1.2	N/A	Top management promotes continuous improvement. [27001-5.1g] Assign roles, responsibilities, and authorities for implementing 4.6.1.1, and communicate them to relevant personnel for implementation.	Functional	Subset Of	Commitment To Continual Improvements	GOV-01.3	Mechanisms exist to commit appropriate resources needed for continual improvement of the organization's Security, Compliance & Resilience Program (SCRCP), including: (1) Staffing; (2) Budget; (3) Processes; and (4) Technologies.	10	
4.6.2	Performance evaluation [27001-9]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.6.2.1	N/A	The organization continuously evaluates information security performance and the effectiveness of information security management to determine the following. [27001-9.1] • Scope of monitoring and measurement required (including information security processes and controls) • Methods of monitoring, measurement, analysis, and evaluation to ensure valid results (methods that produce comparable and reproducible results) • Timing and frequency of monitoring and measurement • The person who conducts monitoring and measurement • Timing and frequency of analysis (including causality and correlation) and evaluation of the results of monitoring and measurement • The person who conducts the analysis and evaluation of the results of monitoring and measurement • Response measures in accordance with the results of the analysis and evaluation • Frequency of reporting the results of the analysis and evaluation	Functional	Subset Of	Measures of Performance	GOV-05	Mechanisms exist to develop, report and monitor Security, Compliance & Resilience Program (SCRCP) measures of performance.	10	
4.6.2.2	N/A	The organization conducts internal assessments at predetermined intervals. [27001-9.2a) / 9.2b)] a) The following are confirmed when conducting internal assessments. • Confirm compliance with the following. —Requirements stipulated by the organization itself regarding information security management —Requirements of this management criteria • Information security management is effectively implemented and maintained. b) Internal assessments are conducted on a regular basis to comprehensively confirm the effectiveness of controls, and the plans and results are managed in the following documents. • Basic plan for internal assessments • Internal assessment implementation plan • Internal assessment report The scope, purpose, management system, and period or date of the assessment are determined in advance in the basic plan, the timing and location of the assessment, the personnel in charge of the assessment and their assignments, and the detailed assessment methods are determined in advance in the implementation plan. An implementation report is prepared in order to prove that the assessment was conducted as planned.	Functional	Intersects With	Conformity Assessment	CPL-01.4	Mechanisms exist to conduct assessments to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	
4.6.2.2	N/A	The organization conducts internal assessments at predetermined intervals. [27001-9.2a) / 9.2b)] a) The following are confirmed when conducting internal assessments. • Confirm compliance with the following. —Requirements stipulated by the organization itself regarding information security management —Requirements of this management criteria • Information security management is effectively implemented and maintained. b) Internal assessments are conducted on a regular basis to comprehensively confirm the effectiveness of controls, and the plans and results are managed in the following documents. • Basic plan for internal assessments • Internal assessment implementation plan • Internal assessment report The scope, purpose, management system, and period or date of the assessment are determined in advance in the basic plan, the timing and location of the assessment, the personnel in charge of the assessment and their assignments, and the detailed assessment methods are determined in advance in the implementation plan. An implementation report is prepared in order to prove that the assessment was conducted as planned.	Functional	Subset Of	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	10	
4.6.2.2	N/A	The organization conducts internal assessments at predetermined intervals. [27001-9.2a) / 9.2b)] a) The following are confirmed when conducting internal assessments. • Confirm compliance with the following. —Requirements stipulated by the organization itself regarding information security management —Requirements of this management criteria • Information security management is effectively implemented and maintained. b) Internal assessments are conducted on a regular basis to comprehensively confirm the effectiveness of controls, and the plans and results are managed in the following documents. • Basic plan for internal assessments • Internal assessment implementation plan • Internal assessment report The scope, purpose, management system, and period or date of the assessment are determined in advance in the basic plan, the timing and location of the assessment, the personnel in charge of the assessment and their assignments, and the detailed assessment methods are determined in advance in the implementation plan. An implementation report is prepared in order to prove that the assessment was conducted as planned. c) The following items are included in the assessment of conformity • Relevant legal or regulatory requirements • Information security requirements identified through information security risk assessment, etc. d) The assessment of the effective implementation and maintenance of information security management include the following items • Effectiveness and maintenance of controls • Whether controls are being implemented as expected.	Functional	Intersects With	Internal Audit Function	CPL-02.1	Mechanisms exist to implement an internal audit function that is capable of providing senior organization management with insights into the appropriateness of the organization's technology and information governance processes.	5	
4.6.2.3	N/A	The organization plans, establishes, implements, and maintains an assessment program that includes requirements and reporting on frequency, methods, responsibilities, and plans. [27001-9.2c] The assessment program takes into account the importance of the processes involved and the results of previous assessments. Because assessments can not only be conducted for the entire scope at once, but also for only a part of the scope, and since it is important to clarify the objectives of each assessment and to implement an appropriate assessment plan, the following points are considered in the development of the assessment program • Objectives and key targets of the assessment • The status and importance of the assessment process to be covered • The status and importance of the area to be assessed • Previous assessment results	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.6.2.4	N/A	The organization clarifies the assessment criteria and scope. [27001-9.2d] The assessment program includes not only the overall assessment schedule, but also the following. • Assessment criteria (including the following) — Objectives, authority, and responsibilities — Independence, objectivity, and professional ethics — Professional competence — Work obligations — Quality control — How the assessment is conducted — Format of the assessment report • Scope of the assessment • Frequency or timing of the assessment • Assessment method (separate information security assessment criteria are developed and prepared for both internal assessments and assessments by external organizations to ensure high quality assessments)	Functional	Subset Of	Internal Audit Function	CPL-02.1	Mechanisms exist to implement an internal audit function that is capable of providing senior organization management with insights into the appropriateness of the organization's technology and information governance processes.	10	
4.6.2.5	N/A	The organization selects assessors and conducts assessments that ensure the objectivity and impartiality of the assessment process. [27001-9.2e] The organization selects assessors in accordance with the assessment criteria and consider the following. • Independence in terms of appearance • Mental independence • Professional ethics and integrity In the case of internal assessors, they are assigned other personnel so that they do not conduct an assessment on the work they are engaged in themselves.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	
4.6.2.5	N/A	The organization selects assessors and conducts assessments that ensure the objectivity and impartiality of the assessment process. [27001-9.2e] The organization selects assessors in accordance with the assessment criteria and consider the following. • Independence in terms of appearance • Mental independence • Professional ethics and integrity In the case of internal assessors, they are assigned other personnel so that they do not conduct an assessment on the work they are engaged in themselves.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	8	
4.6.2.6	N/A	The organization ensures that the results of the assessment are reported to the relevant management team. [27001-9.2f]	Functional	Intersects With	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	5	
4.6.2.7	N/A	The organization maintains documented information as evidence of the assessment program and assessment results. [27001-9.2g] The assessment procedures reflect and document the following, and are used for mutual communication. • Responsibilities and requirements for planning and conducting the assessment • Responsibilities and requirements for reporting results and maintaining records The requirements are essential to ensure assessment quality, and the responsible person and the assessor conducts the assessment with the same objective.	Functional	Intersects With	Defensible Evidence of Due Diligence	CPL-13.1	Mechanisms exist to produce evidence of due diligence activities performed, capable of withstanding external audit or regulatory scrutiny.	5	
4.6.2.7	N/A	The organization maintains documented information as evidence of the assessment program and assessment results. [27001-9.2g] The assessment procedures reflect and document the following, and are used for mutual communication. • Responsibilities and requirements for planning and conducting the assessment • Responsibilities and requirements for reporting results and maintaining records The requirements are essential to ensure assessment quality, and the responsible person and the assessor conducts the assessment with the same objective.	Functional	Intersects With	Defensible Evidence of Due Care	CPL-13.2	Mechanisms exist to produce evidence of due care activities performed, capable of withstanding external audit or regulatory scrutiny.	5	
4.6.3	Management review [27001-9.3]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.6.3.1	N/A	Top management conducts management reviews at predetermined intervals. [27001-9.3] The following points are considered and documented in order to conduct management reviews at predetermined intervals. • Basic plan for management review • Management review implementation plan • Implementation report for management review The objective and timing of implementation are determined in the basic plan, and detailed assessment methods are determined in advance in the implementation plan.	Functional	Subset Of	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	10	
4.6.3.2	N/A	Top management considers the following in the management review. [27001-9.3] • Status of actions taken as a result of the previous management reviews • Changes in external and internal issues related to information security management • Feedback on information security performance, including the following -Nonconformities and corrective actions -Results of monitoring and measurement -Assessment results -Achievement of information security objectives • Feedback from stakeholders • Results of information security risk assessment and status of information security risk response plan • Opportunities for continual improvement In addition, activities and events that are expected to constitute such information are recorded and reported as necessary, and those that are highly urgent are defined in advance, and standards are established so that everyone can make the same decision.	Functional	Subset Of	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	10	
4.6.3.3	N/A	Outputs from management reviews include decisions on opportunities for continuous improvement and the need for any changes in information security management. [27001-9.3] The following activities are implemented and improvement measures are considered in order to reflect the results of the management review in improvement measures. • Improvement of the effectiveness of information security management • Updates to information security risk assessment and information security risk response plan • Modification of procedures and controls in consideration of internal and external events that can impact information security management • Identification of required management resources • Improvement of performance measurement methods Records of the information security risk response options selected are referred to when planning improvement measures.	Functional	Subset Of	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: Japan - Information System Security Management and Assessment Program (ISMAP)

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b0bf6d69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.6.3.3	N/A	Outputs from management reviews include decisions on opportunities for continuous improvement and the need for any changes in information security management. [27001-9.3] The following activities are implemented and improvement measures are considered in order to reflect the results of the management review in improvement measures. • Improvement of the effectiveness of information security management • Updates to information security risk assessment and information security risk response plan • Modification of procedures and controls in consideration of internal and external events that can impact information security management • Identification of required management resources • Improvement of performance measurement methods Records of the information security risk response options selected are referred to when planning improvement measures.	Functional	Intersects With	Commitment To Continual Improvements	GOV-01.3	Mechanisms exist to commit appropriate resources needed for continual improvement of the organization's Security, Compliance & Resilience Program (SCR), including: (1) Staffing; (2) Budget; (3) Processes; and (4) Technologies.	5	
4.6.3.4	N/A	The organization retains documented information as evidence of the results of management reviews. [27001-9.3] Because the results of management reviews are used for the next management review, the results are specifically recorded so that the details and results can be understood.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	
4.7	Maintenance and improvement of information security management [27001-10]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.7.1	Corrective actions [27001-10.1]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.7.1.1	N/A	The organization takes actions to correct nonconformities when they occur. [27001-10.1a] a) The following are performed when taking corrective action. • Actions to control and correct the nonconformity • Actions to address the consequences of the nonconformity • The following are documented to ensure that corrective actions are implemented in accordance with procedures — Evaluation of the need for the actions selected to ensure that the nonconformity is not recurring — Determination of the corrective action required — Implementation of the corrective action required — Records of actions taken — Review of the corrective actions taken b) Nonconformities are detected through the following activities • Periodic information security risk assessment • Periodic information security internal assessments • Periodic management reviews • The following are documented in order to detect nonconformities in a procedural manner. — Identification of nonconformities with information security management — Determination of the cause of nonconformities with information security management. In some cases, nonconformities cannot be determined through a single activity alone, so nonconformities are detected by considering the combined results.	Functional	Intersects With	Non-Compliance Oversight	CPL-01.1	Mechanisms exist to document and review instances of non-compliance with statutory, regulatory and/or contractual obligations to develop appropriate risk mitigation actions.	8	
4.7.1.1	N/A	The organization takes actions to correct nonconformities when they occur. [27001-10.1a] a) The following are performed when taking corrective action. • Actions to control and correct the nonconformity • Actions to address the consequences of the nonconformity • The following are documented to ensure that corrective actions are implemented in accordance with procedures — Evaluation of the need for the actions selected to ensure that the nonconformity is not recurring — Determination of the corrective action required — Implementation of the corrective action required — Records of actions taken — Review of the corrective actions taken b) Nonconformities are detected through the following activities • Periodic information security risk assessment • Periodic information security internal assessments • Periodic management reviews • The following are documented in order to detect nonconformities in a procedural manner. — Identification of nonconformities with information security management — Determination of the cause of nonconformities with information security management. In some cases, nonconformities cannot be determined through a single activity alone, so nonconformities are detected by considering the combined results.	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	8	
4.7.1.1	N/A	The organization takes actions to correct nonconformities when they occur. [27001-10.1a] a) The following are performed when taking corrective action. • Actions to control and correct the nonconformity • Actions to address the consequences of the nonconformity • The following are documented to ensure that corrective actions are implemented in accordance with procedures — Evaluation of the need for the actions selected to ensure that the nonconformity is not recurring — Determination of the corrective action required — Implementation of the corrective action required — Records of actions taken — Review of the corrective actions taken b) Nonconformities are detected through the following activities • Periodic information security risk assessment • Periodic information security internal assessments • Periodic management reviews • The following are documented in order to detect nonconformities in a procedural manner. — Identification of nonconformities with information security management — Determination of the cause of nonconformities with information security management. In some cases, nonconformities cannot be determined through a single activity alone, so nonconformities are detected by considering the combined results.	Functional	Intersects With	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	8	
4.7.1.2	N/A	The organization evaluates the need to take action to remove the cause of the nonconformity in order to prevent its recurrence or occurrence elsewhere. [27001-10.1b] The following are performed when evaluating the need. • Review of the nonconformity • Clarification of the cause of the nonconformity • Clarification of the existence of similar nonconformities or the likelihood of their occurrence	Functional	Subset Of	Non-Compliance Oversight	CPL-01.1	Mechanisms exist to document and review instances of non-compliance with statutory, regulatory and/or contractual obligations to develop appropriate risk mitigation actions.	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: Japan - Information System Security Management and Assessment Program (ISMAP)

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf69f91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.7.1.3	N/A	The organization takes the necessary actions. [27001-10.1c]]	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or resilience-related: (1) Assessments; (2) Audits; and/or (3) Incidents.	5	
4.7.1.4	N/A	The organization reviews the effectiveness of all corrective actions taken. [27001-10.1d]]	Functional	Subset Of	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	10	
4.7.1.4	N/A	The organization reviews the effectiveness of all corrective actions taken. [27001-10.1d]]	Functional	Intersects With	Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum: (1) Deficiency tracking number; (2) Applicable security, compliance and/or resilience control; (3) Description of the deficiency(ies); (4) Risk associated with the deficiency(ies); (5) Source deficiency identification/detection; (6) Temporary compensating controls, if applicable; (7) Point of Contact (POC) (e.g., asset/process owner); (8) Resources required to conduct remediation actions; (9) Planned remedial actions to the deficiency(ies); (10) Proposed remediation timeline; and (11) Disposition statement (e.g., closeout summary).	8	
4.7.1.5	N/A	The organization makes changes to its information security management when necessary. [27001-10.1e]]	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRPP), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	
4.7.1.6	N/A	The organization ensures that corrective actions are proportionate to the impact of the nonconformities detected. [27001-10.1]]	Functional	Subset Of	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or resilience-related: (1) Assessments; (2) Audits; and/or (3) Incidents.	10	
4.7.1.7	N/A	The organization maintains the following documented information as evidence of corrective actions. [27001-10.1f] / 10.1g]] • The nature of the nonconformity and the action taken • Results of corrective actions	Functional	Subset Of	Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum: (1) Deficiency tracking number; (2) Applicable security, compliance and/or resilience control; (3) Description of the deficiency(ies); (4) Risk associated with the deficiency(ies); (5) Source deficiency identification/detection; (6) Temporary compensating controls, if applicable; (7) Point of Contact (POC) (e.g., asset/process owner); (8) Resources required to conduct remediation actions; (9) Planned remedial actions to the deficiency(ies); (10) Proposed remediation timeline; and (11) Disposition statement (e.g., closeout summary).	10	
4.8	Management of documented information [27001-7.5]]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.8.1	Guidelines for documentation [27001-7.5.1]]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.8.1.1	N/A	The organization documents the following information required by information security management. [27001-7.5.1] • Information security policy • Information security objectives • Information security risk assessment process • Information security risk response process • Results of information security risk assessment • Information security risk response plan • Results of performance measurement While it does not matter which document these contents are stated in, the information needs to be structured in such a way that it is communicated to those who need to know the information, and such documents not be accessible to those who do not need to know them.	Functional	Intersects With	Security, Compliance & Resilience Program (SCRPP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	8	
4.8.1.1	N/A	The organization documents the following information required by information security management. [27001-7.5.1] • Information security policy • Information security objectives • Information security risk assessment process • Information security risk response process • Results of information security risk assessment • Information security risk response plan • Results of performance measurement While it does not matter which document these contents are stated in, the information needs to be structured in such a way that it is communicated to those who need to know the information, and such documents not be accessible to those who do not need to know them.	Functional	Intersects With	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	8	
4.8.2	Creation, modification, and management of documents [27001-7.5.2 / 7.5.3]]	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.8.2.1	N/A	The organization creates and update documented information by doing the following [27001-7.5.2] • Description of appropriate identifying information (for example, title, date, author, and reference number) • Selection of an appropriate format (for example, language, software version, charts) and medium (for example, paper, digital). • Appropriate review and approval on appropriateness and validity • Definition of the lifecycle of the documented information and development of procedures to handle it accordingly • Review and approval of appropriateness before issuing documents • Update and re-approval of documents as necessary • Prevention of misuse of obsolete documents • When obsolete documents are retained for any purpose, a description of appropriate identification information that identifies them as obsolete documents • Updating of documents at a defined frequency in accordance with legal and regulatory requirements and changes in the environment In addition, appropriate document management procedures are developed, taking into consideration whether all these activities are reflected in document management and whether these activities cause significant obstacles to business operations.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf6d9fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.8.2.1	N/A	The organization creates and update documented information by doing the following [27001-7.5.2] • Description of appropriate identifying information (for example, title, date, author, and reference number) • Selection of an appropriate format (for example, language, software version, charts) and medium (for example, paper, digital). • Appropriate review and approval on appropriateness and validity • Definition of the lifecycle of the documented information and development of procedures to handle it accordingly • Review and approval of appropriateness before issuing documents • Update and re-approval of documents as necessary • Prevention of misuse of obsolete documents • When obsolete documents are retained for any purpose, a description of appropriate identification information that identifies them as obsolete documents • Updating of documents at a defined frequency in accordance with legal and regulatory requirements and changes in the environment In addition, appropriate document management procedures are developed, taking into consideration whether all these activities are reflected in document management and whether these activities cause significant obstacles to business operations.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCR), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	
4.8.2.2	N/A	The organization manages documented information as required by information security management to ensure the following. [27001-7.5.3] • The documented information is available and suitable for use when and where it is needed. • Documented information is adequately protected (for example, against loss of confidentiality, improper use, and loss of integrity). • Distribution, access, retrieval, and use of documented information • Storage and preservation of documented information, including maintaining legibility • Management of changes in documented information (for example, version control) • Retention and disposal of documented information In addition, documents determined to be necessary by the organization for the planning and operation of information security management are identified and managed as necessary, even if they are obtained from external sources.	Functional	Subset Of	Security, Compliance & Resilience Program (SCR)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
4.9	Information security risk communication	Effective communication between stakeholders can have a significant impact on decision-making. Information security risk communication involves the exchange and sharing of information about information security risks between decision makers and other stakeholders (including cloud service users and outsourcers involved in the provision of cloud services), and agreement on how to manage those risks.	Functional	Intersects With	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	5	
4.9	Information security risk communication	Effective communication between stakeholders can have a significant impact on decision-making. Information security risk communication involves the exchange and sharing of information about information security risks between decision makers and other stakeholders (including cloud service users and outsourcers involved in the provision of cloud services), and agreement on how to manage those risks.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	
4.9	Information security risk communication	Effective communication between stakeholders can have a significant impact on decision-making. Information security risk communication involves the exchange and sharing of information about information security risks between decision makers and other stakeholders (including cloud service users and outsourcers involved in the provision of cloud services), and agreement on how to manage those risks.	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5	
4.9.1	Risk communication plan	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.9.1.1	N/A	A risk communication plan is formulated. A risk communication plan is formulated and documented for the following two categories. • Risk communication plan for normal operations • Risk communication plan for emergencies • The risk communication plan pays attention to how to encourage communication between decision-makers and other stakeholders (including cloud service users and outsourcers involved in the provision of cloud services) and includes the following information. • Effective information exchange and sharing with the participation of appropriate stakeholders • Compliance with legal, regulatory, and governance requirements • Provision of feedback and reporting on communications and discussions • Use of communications to build trust in the organization • Implementation of communication with stakeholders in the event of a crisis or unforeseen event	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5	
4.9.2	Implementation of risk communication	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.9.2.1	N/A	Establish a mechanism for implementing risk communication. Establish a mechanism for discussing risks, prioritizing and responding appropriately to risks, accepting risks, and coordinating with key decision makers and stakeholders (including cloud service users and outsourcers involved in the provision of cloud services). This mechanism ensures the following items. • Appropriate communication of the key components of the risk management framework and any subsequent modifications • Appropriate internal reporting on the framework, its effectiveness and outcomes • Provision of relevant information derived from the adaptation of risk management that is available at the appropriate level and time • Processes for consultation with internal stakeholders The mechanism can include, where appropriate, a process for compiling risk information from a variety of sources and can need to take into account the susceptibility of an impact from risk information. A committee is one place where this mechanism can be established.	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5	
4.9.2.2	N/A	Risk communication is conducted. Risk communication is implemented on an ongoing basis at all stages of the risk management process to achieve the following. • Provide assurance of the organization's risk management results • Collect risk information • Share the results of the risk assessment and provide a risk response plan • Avoid or reduce the occurrence and consequences of information security violations due to a lack of mutual understanding between decision makers and stakeholders (including cloud service users and outsourcers involved in the provision of cloud services) • Support decision making • Obtain new information security knowledge • Develop a response plans to reduce the consequences of all incidents in coordination with other organizations • Make decision makers and stakeholders (including cloud service users and outsourcers involved in the provision of cloud services) aware of their responsibility for risk • Improve security awareness Collaborate with the appropriate public relations or communications department within the organization to coordinate all risk communication-related tasks in the implementation of risk communication.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf6d9fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.9.2.2	N/A	Risk communication is conducted. Risk communication is implemented on an ongoing basis at all stages of the risk management process to achieve the following. • Provide assurance of the organization's risk management results • Collect risk information • Share the results of the risk assessment and provide a risk response plan • Avoid or reduce the occurrence and consequences of information security violations due to a lack of mutual understanding between decision makers and stakeholders (including cloud service users and outsourcers involved in the provision of cloud services) • Support decision making • Obtain new information security knowledge • Develop a response plans to reduce the consequences of all incidents in coordination with other organizations • Make decision makers and stakeholders (including cloud service users and outsourcers involved in the provision of cloud services) aware of their responsibility for risk • Improve security awareness Collaborate with the appropriate public relations or communications department within the organization to coordinate all risk communication-related tasks in the implementation of risk communication.	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5	
5	N/A	Information security policies	Functional	Subset Of	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
5.1	N/A	Management direction for information security Control Objective: To provide management direction and support for information security in accordance with business requirements and relevant laws and regulations.	Functional	Subset Of	Security, Compliance & Resilience Program (SCRP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
5.1.1	N/A	5.1.1 corresponds to the part of 5.1.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Program (SCRP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
5.1.1	N/A	5.1.1 corresponds to the part of 5.1.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
5.1.1	N/A	5.1.1 corresponds to the part of 5.1.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRP), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	
5.1.1	N/A	5.1.1 corresponds to the part of 5.1.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Data Privacy Program	PRI-01	Mechanisms exist to facilitate the implementation and operation of data protection controls throughout the data lifecycle to ensure all forms of Personal Data (PD) are processed lawfully, fairly and transparently.	10	
5.1.1	N/A	5.1.1 corresponds to the part of 5.1.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Dissemination of Data Privacy Program Information	PRI-01.3	Mechanisms exist to: (1) Ensure that the public has access to information about organizational data privacy activities and can communicate with its Chief Privacy Officer (CPO) or similar role; (2) Ensure that organizational data privacy practices are publicly available through organizational websites or document repositories; (3) Utilize publicly facing email addresses and/or phone lines to enable the public to provide feedback and/or direct questions to data privacy office(s) regarding data privacy practices; and (4) Inform data subjects when changes are made to the privacy notice and the nature of such changes.	5	
5.1.1.1	N/A	At the highest level of policies, the organization formulates an information security policy that is approved by the governing body and represents the organization's approach to managing its information security objectives.	Functional	Subset Of	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	Controls pattern 1
5.1.1.2	N/A	5.1.1.2 corresponds to the a) part of the requirements 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and (2) Set of objectives to achieve that plan.	5	Controls pattern 1
5.1.1.3	N/A	5.1.1.3 corresponds to the b) part of the requirements 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	Controls pattern 1
5.1.1.4	N/A	5.1.1.4 corresponds to the c) part of the requirements 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures, selection of security solutions, monitoring, threat hunting, response and recovery activities.	5	Controls pattern 1
5.1.1.5	N/A	5.1.1.5 corresponds to the a) part of the statements 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Define Control Objectives	GOV-09	Mechanisms exist to establish control objectives as the basis for the selection, implementation and management of the organization's internal security, compliance and resilience control system.	5	Controls pattern 1
5.1.1.6	N/A	5.1.1.6 corresponds to the b) part of the statements 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRP).	5	Controls pattern 1
5.1.1.7	N/A	5.1.1.7 corresponds to the c) part of the statements 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Exception Management	GOV-02.1	Mechanisms exist to prohibit exceptions to standards, except when the exception has been formally assessed for risk impact, approved and recorded.	5	Controls pattern 1
5.1.1.8	N/A	At lower levels of policies, the information security policy is supported by topic-specific individual policies.	Functional	Subset Of	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	Controls pattern 1
5.1.1.9	N/A	5.1.1.9 corresponds to the a) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	5	Controls pattern 1
5.1.1.10	N/A	5.1.1.10 corresponds to the b) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	Controls pattern 1
5.1.1.11	N/A	5.1.1.11 corresponds to the c) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	5	Controls pattern 1
5.1.1.12	N/A	5.1.1.12 corresponds to the d) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	5	Controls pattern 1
5.1.1.13	N/A	5.1.1.13 corresponds to the e) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	5	Controls pattern 1
5.1.1.14	N/A	5.1.1.14 corresponds to the f) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	Controls pattern 1
5.1.1.15	N/A	5.1.1.15 corresponds to the g) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Device Management (EDM)	END-01	Mechanisms exist to facilitate the implementation of Endpoint Device Management (EDM) controls.	5	Controls pattern 1
5.1.1.16	N/A	5.1.1.16 corresponds to the h) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Vulnerability & Patch Management Program (VPMPP)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	5	Controls pattern 1
5.1.1.17	N/A	5.1.1.17 corresponds to the i) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	5	Controls pattern 1
5.1.1.18	N/A	5.1.1.18 corresponds to the j) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	5	Controls pattern 1
5.1.1.19	N/A	5.1.1.19 corresponds to the k) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Data Privacy Program	PRI-01	Mechanisms exist to facilitate the implementation and operation of data protection controls throughout the data lifecycle to ensure all forms of Personal Data (PD) are processed lawfully, fairly and transparently.	5	Controls pattern 1
5.1.1.20	N/A	5.1.1.20 corresponds to the l) part of the examples 5.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	5	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: [Japan - Information System Security Management and Assessment Program \(ISMAP\)](https://www.ismap.gp.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bbfd69fe91bf93&sps=1)
Focal Document URL: https://www.ismap.gp.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bbfd69fe91bf93&sps=1
Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.1.1.21	N/A	5.1.1.21 corresponds to the 1st(last) sentence(beginning with "These policies") of the 6th(last) paragraph of the Implementation guidance of 5.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	Controls pattern 1
5.1.1.22.P	N/A	5.1.1.22.P corresponds to the 1st of the 10 bullet points(beginning with "~ the baseline") in the 1st paragraph of the Implementation guidance of 5.1.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	5	Controls pattern 1
5.1.1.23.P	N/A	5.1.1.23.P corresponds to the bullet points(beginning with "~ risks from authorized") in the 1st paragraph of the Implementation guidance of 5.1.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	5	Controls pattern 1
5.1.1.24.P	N/A	5.1.1.24.P corresponds to the bullet points(beginning with "~ multi-tenancy") in the 1st paragraph of the Implementation guidance of 5.1.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	5	Controls pattern 1
5.1.1.25.P	N/A	5.1.1.25.P corresponds to the bullet points(beginning with "~ access to cloud") in the 1st paragraph of the Implementation guidance of 5.1.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	5	Controls pattern 1
5.1.1.26.P	N/A	5.1.1.26.P corresponds to the bullet points(beginning with "~ access control") in the 1st paragraph of the Implementation guidance of 5.1.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	5	Controls pattern 1
5.1.1.27.P	N/A	5.1.1.27.P corresponds to the bullet points(beginning with "~ communications") in the 1st paragraph of the Implementation guidance of 5.1.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	5	Controls pattern 1
5.1.1.28.P	N/A	5.1.1.28.P corresponds to the bullet points(beginning with "~ virtualization") in the 1st paragraph of the Implementation guidance of 5.1.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	5	Controls pattern 1
5.1.1.29.P	N/A	5.1.1.29.P corresponds to the bullet points(beginning with "~ access to and") in the 1st paragraph of the Implementation guidance of 5.1.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	5	Controls pattern 1
5.1.1.30.P	N/A	5.1.1.30.P corresponds to the bullet points(beginning with "~ lifecycle management") in the 1st paragraph of the Implementation guidance of 5.1.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	5	Controls pattern 1
5.1.1.31.P	N/A	Cloud service providers expand their information security policies with reference to the provision and use of cloud services, taking into account guidelines for breach notification and information sharing to support investigation and forensics.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
5.1.2	N/A	5.1.2 corresponds to the part of 5.1.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCR), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	
5.1.2.1	N/A	5.1.2.1 corresponds to the 1st sentence(beginning with "Each policy should") of the 1st paragraph of the Implementation guidance of 5.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCR).	5	Controls pattern 1
5.1.2.2	N/A	5.1.2.2 corresponds to the 2nd sentence(beginning with "The review should") of the 1st paragraph of the Implementation guidance of 5.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCR), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	Controls pattern 1
5.1.2.3	N/A	In review of the policies for information security, the organization takes into account and reflect the results of management reviews.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCR), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	Controls pattern 1
5.1.2.4	N/A	5.1.2.4 corresponds to the 1st(last) sentence(beginning with "Management approval") of the 3rd(last) paragraph of the Implementation guidance of 5.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCR), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	Controls pattern 1
6	N/A	Organization of information security	Functional	Subset Of	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
6.1	N/A	Internal organization Control Objective: To establish a management framework to initiate and control the implementation and operation of information security within the organization.	Functional	Subset Of	Security, Compliance & Resilience Program (SCR)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
6.1.1	N/A	6.1.1 corresponds to the part of 6.1.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	
6.1.1.1	N/A	6.1.1.1 corresponds to the 1st sentence(beginning with "Allocation of information") of the 1st paragraph of the Implementation guidance of 6.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Controls pattern 1
6.1.1.2	N/A	6.1.1.2 corresponds to the 2nd sentence(beginning with "Responsibilities") of the 1st paragraph of the Implementation guidance of 6.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Controls pattern 1
6.1.1.3	N/A	6.1.1.3 corresponds to the 3rd sentence(beginning with "Responsibilities") of the 1st paragraph of the Implementation guidance of 6.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Controls pattern 1
6.1.1.4	N/A	6.1.1.4 corresponds to the 4th sentence(beginning with "These responsibilities") of the 1st paragraph of the Implementation guidance of 6.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Controls pattern 1
6.1.1.5	N/A	The organization defines local responsibilities for protecting assets and implementing specific information security processes.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Controls pattern 1
6.1.1.6	N/A	6.1.1.6 corresponds to the 1st & 2nd(last) sentence(beginning with "Individuals with" & "Nevertheless they remain") of the 2nd paragraph of the Implementation guidance of 6.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Controls pattern 1
6.1.1.7	N/A	6.1.1.7 corresponds to the 1st sentence(beginning with "Areas for which") of the 3rd(last) paragraph of the Implementation guidance of 6.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Controls pattern 1
6.1.1.8	N/A	6.1.1.8 corresponds to the a) part of 6.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCI) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	Controls pattern 1
6.1.1.9	N/A	6.1.1.9 corresponds to the b) part of 6.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCI) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	Controls pattern 1
6.1.1.10	N/A	6.1.1.10 corresponds to the c) part of 6.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCI) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	Controls pattern 1
6.1.1.11	N/A	6.1.1.11 corresponds to the d) part of 6.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCI) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	Controls pattern 1
6.1.1.12	N/A	6.1.1.12 corresponds to the e) part of 6.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCI) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	Controls pattern 1
6.1.1.13.PB	N/A	6.1.1.13.PB corresponds to the 6.1.1 Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Controls pattern 1
6.1.2	N/A	6.1.2 corresponds to the part of 6.1.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	5	Controls pattern 1
6.1.2.1	N/A	6.1.2.1 corresponds to the 1st sentence(beginning with "Care should be") of the 1st paragraph of the Implementation guidance of 6.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	5	Controls pattern 1
6.1.2.2	N/A	6.1.2.2 corresponds to the 2nd sentence(beginning with "The initiation") of the 1st paragraph of the Implementation guidance of 6.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	5	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: Japan - Information System Security Management and Assessment Program (ISMAP)

Focal Document URL: https://www.ismap.go.jp/csm/?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
6.1.2.3	N/A	6.1.2.3 corresponds to the 3rd sentence(beginning with "The possibility") of the 1st paragraph of the Implementation guidance of 6.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	5	Controls pattern 1
6.1.2.4	N/A	6.1.2.4 corresponds to the 2nd(last) sentence(beginning with "Whenever it is") of the 2nd(last) paragraph of the Implementation guidance of 6.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	5	Controls pattern 1
6.1.3	N/A	6.1.3 corresponds to the part of 6.1.3 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Contacts With Authorities	GOV-06	Mechanisms exist to identify and document appropriate contacts with relevant law enforcement and regulatory bodies.	5	Controls pattern 1
6.1.3.1	N/A	The organization has procedures in place for when and by whom to contact relevant authorities (for example, law enforcement, regulators, and supervisory authorities).	Functional	Intersects With	Contacts With Authorities	GOV-06	Mechanisms exist to identify and document appropriate contacts with relevant law enforcement and regulatory bodies.	5	Controls pattern 1
6.1.3.2	N/A	The organization has procedures in place for timely reporting information security incidents that have been identified when it is suspected that laws have been broken.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5	Controls pattern 1
6.1.3.3.PB	N/A	6.1.3.3.PB corresponds to the 6.1. Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Intersects With	Contacts With Authorities	GOV-06	Mechanisms exist to identify and document appropriate contacts with relevant law enforcement and regulatory bodies.	5	Controls pattern 3
6.1.3.5	N/A	If there are warning signs, the organization enhances the level of monitoring activities based on information from the relevant authorities.	Functional	Intersects With	Audit Level Adjustments	MON-02.6	Mechanisms exist to adjust the level of audit review, analysis and reporting based on evolving threat information from law enforcement, industry associations or other credible sources of threat intelligence.	5	Controls pattern 1
6.1.4	N/A	6.1.4 corresponds to the part of 6.1.4 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Contacts With Groups & Associations	GOV-07	Mechanisms exist to establish contact with selected groups and associations within the security, compliance and resilience communities to: (1) Facilitate ongoing cybersecurity and data protection education and training for organizational personnel; (2) Maintain currency with recommended cybersecurity and data protection practices, techniques and technologies; and (3) Share current cybersecurity and/or data protection-related information including threats, vulnerabilities and incidents.	5	
6.1.4.1	N/A	6.1.4.1 corresponds to the a) part of 6.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Contacts With Groups & Associations	GOV-07	Mechanisms exist to establish contact with selected groups and associations within the security, compliance and resilience communities to: (1) Facilitate ongoing cybersecurity and data protection education and training for organizational personnel; (2) Maintain currency with recommended cybersecurity and data protection practices, techniques and technologies; and (3) Share current cybersecurity and/or data protection-related information including threats, vulnerabilities and incidents.	5	Controls pattern 1
6.1.4.2	N/A	6.1.4.2 corresponds to the b) part of 6.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Contacts With Groups & Associations	GOV-07	Mechanisms exist to establish contact with selected groups and associations within the security, compliance and resilience communities to: (1) Facilitate ongoing cybersecurity and data protection education and training for organizational personnel; (2) Maintain currency with recommended cybersecurity and data protection practices, techniques and technologies; and (3) Share current cybersecurity and/or data protection-related information including threats, vulnerabilities and incidents.	5	Controls pattern 1
6.1.4.3	N/A	6.1.4.3 corresponds to the c) part of 6.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Contacts With Groups & Associations	GOV-07	Mechanisms exist to establish contact with selected groups and associations within the security, compliance and resilience communities to: (1) Facilitate ongoing cybersecurity and data protection education and training for organizational personnel; (2) Maintain currency with recommended cybersecurity and data protection practices, techniques and technologies; and (3) Share current cybersecurity and/or data protection-related information including threats, vulnerabilities and incidents.	5	Controls pattern 1
6.1.4.3	N/A	6.1.4.3 corresponds to the c) part of 6.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	Controls pattern 1
6.1.4.4	N/A	6.1.4.4 corresponds to the d) part of 6.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Contacts With Groups & Associations	GOV-07	Mechanisms exist to establish contact with selected groups and associations within the security, compliance and resilience communities to: (1) Facilitate ongoing cybersecurity and data protection education and training for organizational personnel; (2) Maintain currency with recommended cybersecurity and data protection practices, techniques and technologies; and (3) Share current cybersecurity and/or data protection-related information including threats, vulnerabilities and incidents.	5	Controls pattern 1
6.1.4.5	N/A	6.1.4.5 corresponds to the e) part of 6.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Contacts With Groups & Associations	GOV-07	Mechanisms exist to establish contact with selected groups and associations within the security, compliance and resilience communities to: (1) Facilitate ongoing cybersecurity and data protection education and training for organizational personnel; (2) Maintain currency with recommended cybersecurity and data protection practices, techniques and technologies; and (3) Share current cybersecurity and/or data protection-related information including threats, vulnerabilities and incidents.	5	Controls pattern 1
6.1.4.6	N/A	6.1.4.6 corresponds to the f) part of 6.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Contacts With Groups & Associations	GOV-07	Mechanisms exist to establish contact with selected groups and associations within the security, compliance and resilience communities to: (1) Facilitate ongoing cybersecurity and data protection education and training for organizational personnel; (2) Maintain currency with recommended cybersecurity and data protection practices, techniques and technologies; and (3) Share current cybersecurity and/or data protection-related information including threats, vulnerabilities and incidents.	5	Controls pattern 1
6.1.4.7	N/A	If there are warning signs, the organization enhances the level of monitoring activities based on information from information security related workshops or conferences, and information security professional associations and organizations.	Functional	Intersects With	Audit Level Adjustments	MON-02.6	Mechanisms exist to adjust the level of audit review, analysis and reporting based on evolving threat information from law enforcement, industry associations or other credible sources of threat intelligence.	5	Controls pattern 1
6.1.5	N/A	6.1.5 corresponds to the part of 6.1.5 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience In Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	5	
6.1.5.1	N/A	6.1.5.1 corresponds to the 1st & 2nd sentence(beginning with "Information security" & "This applies generally") of the 1st paragraph of the Implementation guidance of 6.1.5 in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience In Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	5	Controls pattern 1
6.1.5.2	N/A	6.1.5.2 corresponds to the a) part of 6.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and	5	Controls pattern 1
6.1.5.3	N/A	6.1.5.3 corresponds to the b) part of 6.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	Controls pattern 1

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
6.1.5.4	N/A	6.1.5.4 corresponds to the c) part of 6.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	5	Controls pattern 1
6.1.5.5	N/A	6.1.5.5 corresponds to the 2nd(last) sentence(beginning with "Information security") of the 1st paragraph of the Implementation guidance of 6.1.5 in ISO/IEC 27002:2013.	Functional	Intersects With	Business Process Definition	PRM-06	Mechanisms exist to define business processes with consideration for security, compliance and resilience that determines: (1) The resulting risk to organizational operations, assets, individuals and other organizations; and (2) Information protection needs arising from the defined business processes and revises the processes as necessary, until an achievable set of protection needs is obtained.	5	Controls pattern 1
6.1.5.6	N/A	6.1.5.6 corresponds to the 2nd(last) sentence(beginning with "Responsibilities") of the 2nd(last) paragraph of the Implementation guidance of 6.1.5 in ISO/IEC 27002:2013.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCI) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	Controls pattern 1
6.2	N/A	Mobile devices and teleworking Control Objective: To ensure the security of teleworking and use of mobile devices.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	
6.2.1	N/A	6.2.1 corresponds to the part of 6.2.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
6.2.1	N/A	6.2.1 corresponds to the part of 6.2.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	
6.2.1.1	N/A	6.2.1.1 corresponds to the 1st sentence(beginning with "When using mobile") of the 1st paragraph of the Implementation guidance of 6.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.2	N/A	6.2.1.2 corresponds to the 2nd sentence(beginning with "The mobile device") of the 1st paragraph of the implementation guidance of 6.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.3	N/A	6.2.1.3 corresponds to the 2nd paragraph a) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.4	N/A	6.2.1.4 corresponds to the 2nd paragraph b) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.5	N/A	6.2.1.5 corresponds to the 2nd paragraph c) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.6	N/A	6.2.1.6 corresponds to the 2nd paragraph d) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.7	N/A	6.2.1.7 corresponds to the 2nd paragraph e) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.8	N/A	6.2.1.8 corresponds to the 2nd paragraph f) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.9	N/A	6.2.1.9 corresponds to the 2nd paragraph g) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.10	N/A	6.2.1.10 corresponds to the 2nd paragraph h) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.11	N/A	6.2.1.11 corresponds to the 2nd paragraph i) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.12	N/A	6.2.1.12 corresponds to the 2nd paragraph j) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.13	N/A	6.2.1.13 corresponds to the 2nd paragraph k) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.14	N/A	6.2.1.14 corresponds to the 1st sentence(beginning with "Care should be") of the 3rd paragraph of the Implementation guidance of 6.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.15	N/A	6.2.1.15 corresponds to the 2nd(last) sentence(beginning with "Protection should") of the 3rd paragraph of the Implementation guidance of 6.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.16	N/A	6.2.1.16 corresponds to the 1st sentence(beginning with "Mobile devices") of the 4th paragraph of the Implementation guidance of 6.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.17	N/A	6.2.1.17 corresponds to the 2nd sentence(beginning with "A specific procedure") of the 4th paragraph of the Implementation guidance of 6.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.18	N/A	6.2.1.18 corresponds to the 3rd(last) sentence(beginning with "Devices carrying") of the 4th paragraph of the Implementation guidance of 6.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Unattended End-User Equipment	AST-06	Mechanisms exist to implement enhanced protection measures for unattended technology assets to protect against tampering and unauthorized access.	5	Controls pattern 1
6.2.1.19	N/A	Mobile devices that contain highly important, sensitive, or high-impact business information are physically locked when possible, or special locks are used to secure mobile devices.	Functional	Intersects With	Unattended End-User Equipment	AST-06	Mechanisms exist to implement enhanced protection measures for unattended technology assets to protect against tampering and unauthorized access.	5	Controls pattern 1
6.2.1.20	N/A	6.2.1.20 corresponds to the 1st(last) sentence(beginning with "Training should") of the 5th paragraph of the Implementation guidance of 6.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Controls pattern 1
6.2.1.21	N/A	6.2.1.21 corresponds to the last paragraph a) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.22	N/A	6.2.1.22 corresponds to the last paragraph b) part of 6.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Endpoint Protection Measures	END-02	Mechanisms exist to protect the confidentiality, integrity, availability and safety of endpoint devices.	5	Controls pattern 1
6.2.1.23	N/A	When the information security policy for mobile devices permits the use of personally-owned mobile devices, the policy and related security measures should include the use of functions that do not allow mobile devices to store information or measures to encrypt information stored on mobile devices. Whenever possible, use a function that prevents mobile devices from storing information.	Functional	Intersects With	Personally-Owned Mobile Devices	MDM-06	Mechanisms exist to restrict the connection of personally-owned, mobile devices to organizational Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
6.2.2	N/A	6.2.2 corresponds to the part of 6.2.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	
6.2.2.1	N/A	6.2.2.1 corresponds to the 1st sentence(beginning with "Organizations allowing") of the 1st paragraph of the Implementation guidance of 6.2.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.2	N/A	6.2.2.2 corresponds to the a) part of the following matters 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.3	N/A	6.2.2.3 corresponds to the b) part of the following matters 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.4	N/A	6.2.2.4 corresponds to the c) part of the following matters 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.5	N/A	6.2.2.5 corresponds to the d) part of the following matters 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.6	N/A	6.2.2.6 corresponds to the e) part of the following matters 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.7	N/A	6.2.2.7 corresponds to the f) part of the following matters 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.8	N/A	6.2.2.8 corresponds to the g) part of the following matters 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.9	N/A	6.2.2.9 corresponds to the h) part of the following matters 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.10	N/A	6.2.2.10 corresponds to the i) part of the following matters 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.11	N/A	6.2.2.11 corresponds to the j) part of the following matters 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm/?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bbfd69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
6.2.2.12	N/A	6.2.2.12 corresponds to the a) part of the guidelines and arrangements 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.13	N/A	6.2.2.13 corresponds to the b) part of the guidelines and arrangements 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.14	N/A	6.2.2.14 corresponds to the c) part of the guidelines and arrangements 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.15	N/A	6.2.2.15 corresponds to the d) part of the guidelines and arrangements 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.16	N/A	6.2.2.16 corresponds to the e) part of the guidelines and arrangements 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.17	N/A	6.2.2.17 corresponds to the f) part of the guidelines and arrangements 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.18	N/A	6.2.2.18 corresponds to the g) part of the guidelines and arrangements 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.19	N/A	6.2.2.19 corresponds to the h) part of the guidelines and arrangements 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.20	N/A	6.2.2.20 corresponds to the i) part of the guidelines and arrangements 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.2.2.21	N/A	6.2.2.21 corresponds to the j) part of the guidelines and arrangements 6.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Work From Anywhere (WFA) - Telecommuting Security	NET-14.5	Mechanisms exist to define secure telecommuting practices and govern remote access to Technology Assets, Applications, Services and/or Data (TAASD) for remote workers.	5	Controls pattern 1
6.3.P	N/A	Relationship between cloud service customer and cloud service provider Control Objective: To clarify the relationship regarding shared roles and responsibilities between the cloud service customer and the cloud service provider for information security management.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
6.3.1.P	N/A	6.3.1.P corresponds to the part of CLD.6.3.1 Control in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASC) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASC) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	
6.3.1.1.PB	N/A	6.3.1.1.PB corresponds to the 1st(last) sentence(beginning with "The cloud service") of the 1st(last) paragraph of the Implementation guidance of CLD.6.3.1 in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Customer Responsibility Matrix (CRM)	CLD-06.1	Mechanisms exist to formally document a Customer Responsibility Matrix (CRM), delineating assigned responsibilities for security, compliance and resilience controls between the Cloud Service Provider (CSP) and its customers.	5	Controls pattern 3
7	N/A	Human resource security	Functional	Subset Of	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	10	
7.1	N/A	Prior to employment Control Objective: To ensure that employees and contractors understand their responsibilities and are suitable for the roles for which they are considered.	Functional	Subset Of	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	10	
7.1.1	N/A	7.1.1 corresponds to the part of 7.1.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	5	
7.1.1.1	N/A	7.1.1.1 corresponds to the 1st paragraph a) part of 7.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	5	Controls pattern 1
7.1.1.2	N/A	7.1.1.2 corresponds to the 1st paragraph b) part of 7.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	5	Controls pattern 1
7.1.1.3	N/A	7.1.1.3 corresponds to the 1st paragraph c) part of 7.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	5	Controls pattern 1
7.1.1.4	N/A	7.1.1.4 corresponds to the 1st paragraph d) part of 7.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Identity Proofing (Identity Verification)	IAC-28	Mechanisms exist to verify the identity of a user before issuing authenticators or modifying access permissions.	5	Controls pattern 1
7.1.1.5	N/A	7.1.1.5 corresponds to the 1st paragraph e) part of 7.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	5	Controls pattern 1
7.1.1.6	N/A	7.1.1.6 corresponds to the 2nd paragraph a) part of 7.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	5	Controls pattern 1
7.1.1.7	N/A	7.1.1.7 corresponds to the 2nd paragraph b) part of 7.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Roles With Special Protection Measures	HRS-04.1	Mechanisms exist to ensure that individuals accessing a system that stores, transmits or processes information requiring special protection satisfy organization-defined personnel screening criteria.	5	Controls pattern 1
7.1.1.8	N/A	7.1.1.8 corresponds to the 1st(last) sentence(beginning with "Where a job, either") of the 3rd paragraph of the Implementation guidance of 7.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Roles With Special Protection Measures	HRS-04.1	Mechanisms exist to ensure that individuals accessing a system that stores, transmits or processes information requiring special protection satisfy organization-defined personnel screening criteria.	5	Controls pattern 1
7.1.1.9	N/A	7.1.1.9 corresponds to the 1st(last) sentence(beginning with "Procedures should") of the 4th paragraph of the Implementation guidance of 7.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	5	Controls pattern 1
7.1.1.10	N/A	7.1.1.10 corresponds to the 1st sentence(beginning with "A screening process") of the 5th paragraph of the Implementation guidance of 7.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	5	Controls pattern 1
7.1.1.10	N/A	7.1.1.10 corresponds to the 1st sentence(beginning with "A screening process") of the 5th paragraph of the Implementation guidance of 7.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Third-Party Personnel	HRS-10	Mechanisms exist to govern third-party personnel by reviewing and monitoring third-party security, compliance and/or resilience roles and responsibilities.	5	Controls pattern 1
7.1.1.11	N/A	7.1.1.11 corresponds to the 2nd sentence(beginning with "In these cases,") of the 5th paragraph of the Implementation guidance of 7.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Controls pattern 1
7.1.1.12	N/A	7.1.1.12 corresponds to the 1st sentence(beginning with "Information on") of the 6th(last) paragraph of the Implementation guidance of 7.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	Controls pattern 1
7.1.1.13	N/A	7.1.1.13 corresponds to the 2nd(last) sentence(beginning with "Depending on applicable") of the 6th(last) paragraph of the Implementation guidance of 7.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Human Resources Security Management	HRS-01	Mechanisms exist to facilitate the implementation of personnel security controls.	10	Controls pattern 1
7.1.2	N/A	7.1.2 corresponds to the part of 7.1.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	
7.1.2.1	N/A	7.1.2.1 corresponds to the 1st sentence(beginning with "The contractual") of the 1st paragraph of the Implementation guidance of 7.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Controls pattern 1
7.1.2.2	N/A	7.1.2.2 corresponds to the a) part of 7.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Controls pattern 1
7.1.2.3	N/A	7.1.2.3 corresponds to the b) part of 7.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Controls pattern 1
7.1.2.4	N/A	7.1.2.4 corresponds to the c) part of 7.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Controls pattern 1
7.1.2.5	N/A	7.1.2.5 corresponds to the d) part of 7.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Controls pattern 1
7.1.2.6	N/A	7.1.2.6 corresponds to the e) part of 7.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Controls pattern 1
7.1.2.7	N/A	7.1.2.7 corresponds to the 1st(last) sentence(beginning with "Information security") of the 2nd paragraph of the Implementation guidance of 7.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	User Awareness	HRS-03.1	Mechanisms exist to communicate with users about their roles and responsibilities to maintain a safe and secure working environment.	5	Controls pattern 1
7.1.2.8	N/A	The organization has mechanisms in place to ensure that employees and contract parties agree to terms and conditions of employment related to information security.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**
Focal Document URL: https://www.ismap.gp.jp/csm/?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bbfd69fe91bf93&spa=1
Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
7.1.2.9	N/A	Terms and conditions of employment are to be appropriate for the nature and extent of access by employees and contract parties to information systems and services and related organizational assets.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Controls pattern 1
7.1.2.10	N/A	7.1.2.10 corresponds to the 4th(last) sentence(beginning with "Where appropriate," of the 1st(last) paragraph of the Implementation guidance of 7.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Post-Employment Requirements Awareness	HRS-06.2	Mechanisms exist to notify individuals of their applicable, legally-binding post-employment requirements for the protection of sensitive and/or regulated data.	5	Controls pattern 1
7.2	N/A	During employment Control Objective: To ensure that employees and contractors are aware of and fulfill their information security responsibilities.	Functional	Intersects With	User Awareness	HRS-03.1	Mechanisms exist to communicate with users about their roles and responsibilities to maintain a safe and secure working environment.	5	
7.2	N/A	During employment Control Objective: To ensure that employees and contractors are aware of and fulfill their information security responsibilities.	Functional	Intersects With	Formal Indoctination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	5	
7.2	N/A	During employment Control Objective: To ensure that employees and contractors are aware of and fulfill their information security responsibilities.	Functional	Intersects With	Policy Familiarization & Acknowledgement	HRS-05.7	Mechanisms exist to ensure personnel receive recurring familiarization with the organization's security, compliance and resilience policies and provide acknowledgement.	5	
7.2.1	N/A	7.2.1 corresponds to the part of 7.2.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	
7.2.1.1	N/A	7.2.1.1 corresponds to the a) part of 7.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Formal Indoctination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	5	Controls pattern 1
7.2.1.2	N/A	7.2.1.2 corresponds to the b) part of 7.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	5	Controls pattern 1
7.2.1.3	N/A	7.2.1.3 corresponds to the c) part of 7.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Policy Familiarization & Acknowledgement	HRS-05.7	Mechanisms exist to ensure personnel receive recurring familiarization with the organization's security, compliance and resilience policies and provide acknowledgement.	5	Controls pattern 1
7.2.1.4	N/A	7.2.1.4 corresponds to the d) part of 7.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	User Awareness	HRS-03.1	Mechanisms exist to communicate with users about their roles and responsibilities to maintain a safe and secure working environment.	5	Controls pattern 1
7.2.1.5	N/A	7.2.1.5 corresponds to the e) part of 7.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Controls pattern 1
7.2.1.6	N/A	7.2.1.6 corresponds to the f) part of 7.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5	Controls pattern 1
7.2.1.7	N/A	7.2.1.7 corresponds to the g) part of 7.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Reporting Suspicious Activities	HRS-15	Mechanisms exist to enable personnel to report suspicious activities and/or behavior without fear of reprisal or other negative consequences (e.g., whistleblower protections).	5	Controls pattern 1
7.2.1.8	N/A	7.2.1.8 corresponds to the 1st(last) sentence(beginning with "Management should") of the 1st paragraph of the Implementation guidance of 7.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Business As Usual (BAU) Security, Compliance & Resilience Practices	GOV-14	Mechanisms exist to incorporate security, compliance and resilience principles into Business As Usual (BAU) practices through executive leadership involvement.	5	Controls pattern 1
7.2.2	N/A	7.2.2 corresponds to the part of 7.2.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	
7.2.2.1	N/A	7.2.2.1 corresponds to the 1st(last) sentence(beginning with "An information") of the 1st paragraph of the Implementation guidance of 7.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	Controls pattern 1
7.2.2.2	N/A	7.2.2.2 corresponds to the 1st sentence(beginning with "An information") of the 2nd paragraph of the Implementation guidance of 7.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	Controls pattern 1
7.2.2.3	N/A	Information security awareness programs include multiple awareness activities, such as campaigns (for example, Information Security Day) and the publication of brochures or bulletins.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	Controls pattern 1
7.2.2.4	N/A	7.2.2.4 corresponds to the 1st sentence(beginning with "The awareness programme") of the 3rd paragraph of the Implementation guidance of 7.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	Controls pattern 1
7.2.2.5	N/A	The organization plans information security awareness program activities over the long term, preferably on a regular basis, to ensure that new employees and contract parties are included.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	Controls pattern 1
7.2.2.6	N/A	7.2.2.6 corresponds to the 3rd(last) sentence(beginning with "The awareness programme") of the 3rd paragraph of the Implementation guidance of 7.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	Controls pattern 1
7.2.2.7	N/A	The organization conducts awareness training as required by the organization's information security awareness program (for example, through a variety of means, including classroom training, distance learning, Internet-based training, and self-learning).	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Controls pattern 1
7.2.2.8	N/A	7.2.2.8 corresponds to the a) part of 7.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Controls pattern 1
7.2.2.9	N/A	7.2.2.9 corresponds to the b) part of 7.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Controls pattern 1
7.2.2.10	N/A	7.2.2.10 corresponds to the c) part of 7.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Controls pattern 1
7.2.2.11	N/A	7.2.2.11 corresponds to the d) part of 7.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Controls pattern 1
7.2.2.12	N/A	7.2.2.12 corresponds to the e) part of 7.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Controls pattern 1
7.2.2.13	N/A	The organization conducts information security education and training not only on a regular basis, but also as needed in accordance with changes in information systems.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Controls pattern 1
7.2.2.14	N/A	7.2.2.14 corresponds to the 2nd sentence(beginning with "Initial education") of the 6th paragraph of the Implementation guidance of 7.2.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5	Controls pattern 1
7.2.2.15	N/A	7.2.2.15 corresponds to the 1st sentence(beginning with "The organization") of the 7th(last) paragraph of the Implementation guidance of 7.2.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Controls pattern 1
7.2.2.16	N/A	Programs for effective implementation of education and training include a process that takes into account the organization's information that needs to be protected and the controls in place to protect the information.	Functional	Intersects With	Sensitive / Regulated Data Storage, Handling & Processing	SAT-03.3	Mechanisms exist to ensure that every user accessing a system processing, storing or transmitting sensitive and/or regulated data is formally trained in data handling requirements.	5	Controls pattern 1
7.2.2.17	N/A	Programs for effective implementation of education and training are to be defined in line with the organization's policies for information security and related procedures.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	Controls pattern 1
7.2.2.18	N/A	The program should consider different forms of education and training, e.g. lectures or self-studies (for example, procedure check training and scenario non-presentation type training).	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	Controls pattern 1
7.2.2.19.PB	N/A	Cloud service providers provide education and training to raise awareness among employees regarding the proper handling of cloud service customer data and cloud service derived data, and require contract parties to do the same.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5	Controls pattern 1
7.2.2.19.PB	N/A	Cloud service providers provide education and training to raise awareness among employees regarding the proper handling of cloud service customer data and cloud service derived data, and require contract parties to do the same.	Functional	Intersects With	Sensitive / Regulated Data Storage, Handling & Processing	SAT-03.3	Mechanisms exist to ensure that every user accessing a system processing, storing or transmitting sensitive and/or regulated data is formally trained in data handling requirements.	5	Controls pattern 1
7.2.2.25	N/A	Information security awareness programs and education and training are to be established and implemented in consideration of normal times, emergencies, cases of a crisis, cases requiring urgent response, and incident response.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf69e91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
7.2.3	N/A	7.2.3 corresponds to the part of 7.2.3 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Personnel Sanctions	HRS-07	Mechanisms exist to sanction personnel failing to comply with established security policies, standards and procedures.	5	
7.2.3.1	N/A	7.2.3.1 corresponds to the 1st(last) sentence(beginning with "The disciplinary") of the 1st paragraph of the Implementation guidance of 7.2.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Personnel Sanctions	HRS-07	Mechanisms exist to sanction personnel failing to comply with established security policies, standards and procedures.	10	Controls pattern 1
7.2.3.2	N/A	7.2.3.2 corresponds to the 1st sentence(beginning with "The formal disciplinary") of the 2nd paragraph of the Implementation guidance of 7.2.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Personnel Sanctions	HRS-07	Mechanisms exist to sanction personnel failing to comply with established security policies, standards and procedures.	10	Controls pattern 1
7.2.3.3	N/A	Formal disciplinary process establish a step-by-step response that considers the nature and severity of the violation and its business impact, whether it is a first or repeated violation, whether the violator has been properly trained and educated, relevant laws and regulations, business contracts, and other necessary factors.	Functional	Subset Of	Personnel Sanctions	HRS-07	Mechanisms exist to sanction personnel failing to comply with established security policies, standards and procedures.	10	Controls pattern 1
7.2.3.4	N/A	7.2.3.4 corresponds to the 1st sentence(beginning with "The disciplinary") of the 3rd(last) paragraph of the Implementation guidance of 7.2.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Personnel Sanctions	HRS-07	Mechanisms exist to sanction personnel failing to comply with established security policies, standards and procedures.	10	Controls pattern 1
7.3	N/A	Termination and change of employment Control Objective: To protect the organization's interests as part of the process of changing or terminating employment.	Functional	Intersects With	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	5	
7.3.1	N/A	7.3.1 corresponds to the part of 7.3.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	10	
7.3.1.1	N/A	7.3.1.1 corresponds to the 1st(last) sentence(beginning with "The communication") of the 1st paragraph of the Implementation guidance of 7.3.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	10	Controls pattern 1
7.3.1.2	N/A	7.3.1.2 corresponds to the 1st(last) sentence(beginning with "Responsibilities") of the 2nd paragraph of the Implementation guidance of 7.3.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	10	Controls pattern 1
7.3.1.3	N/A	7.3.1.3 corresponds to the 1st(last) sentence(beginning with "Changes of responsibility") of the 3rd(last) paragraph of the Implementation guidance of 7.3.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Personnel Termination	HRS-09	Mechanisms exist to govern the termination of individual employment.	10	Controls pattern 1
8	N/A	Asset management	Functional	Subset Of	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	10	
8.1	N/A	Responsibility for assets Control Objective: To identify organizational assets and define appropriate protection responsibilities.	Functional	Subset Of	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	10	
8.1.1	N/A	8.1.1 corresponds to the part of 8.1.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	5	
8.1.1.1	N/A	8.1.1.1 corresponds to the 1st sentence(beginning with "An organization") of the 1st paragraph of the Implementation guidance of 8.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	10	Controls pattern 1
8.1.1.2	N/A	8.1.1.2 corresponds to the 2nd sentence(beginning with "The lifecycle of") of the 1st paragraph of the Implementation guidance of 8.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	10	Controls pattern 1
8.1.1.3	N/A	8.1.1.3 corresponds to the 3rd sentence(beginning with "Documentation should") of the 1st paragraph of the Implementation guidance of 8.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	10	Controls pattern 1
8.1.1.4	N/A	8.1.1.4 corresponds to the 1st(last) sentence(beginning with "The asset inventory") of the 2nd paragraph of the Implementation guidance of 8.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	10	Controls pattern 1
8.1.1.5	N/A	The organization assigns and classifies a person responsible for the management of each asset identified.	Functional	Intersects With	Asset Ownership Assignment	AST-03	Mechanisms exist to ensure asset ownership responsibilities are assigned, tracked and managed at a team, individual, or responsible organization level to establish a common understanding of requirements for asset protection.	5	Controls pattern 1
8.1.1.6.PB	N/A	8.1.1.6.PB corresponds to the 8.1. Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Subset Of	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	10	Controls pattern 1
8.1.2	N/A	8.1.2 corresponds to the part of 8.1.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Asset Ownership Assignment	AST-03	Mechanisms exist to ensure asset ownership responsibilities are assigned, tracked and managed at a team, individual, or responsible organization level to establish a common understanding of requirements for asset protection.	5	
8.1.2.1	N/A	The organization assigns management responsibility to qualified parties (individuals and organizations given management responsibility for the life cycle of the asset) at the time the asset is created or transferred to the organization in a process that ensures timely assignment of management responsibility for the asset.	Functional	Intersects With	Asset Ownership Assignment	AST-03	Mechanisms exist to ensure asset ownership responsibilities are assigned, tracked and managed at a team, individual, or responsible organization level to establish a common understanding of requirements for asset protection.	5	Controls pattern 1
8.1.2.2	N/A	8.1.2.2 corresponds to the 3rd(last) sentence(beginning with "The asset owner") of the 2nd paragraph of the Implementation guidance of 8.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Asset Ownership Assignment	AST-03	Mechanisms exist to ensure asset ownership responsibilities are assigned, tracked and managed at a team, individual, or responsible organization level to establish a common understanding of requirements for asset protection.	5	Controls pattern 1
8.1.2.3	N/A	8.1.2.3 corresponds to the a) part of 8.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	5	Controls pattern 1
8.1.2.4	N/A	8.1.2.4 corresponds to the b) part of 8.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Asset Scope Classification	AST-04.1	Mechanisms exist to determine security, compliance and resilience control applicability by identifying, assigning and documenting the appropriate asset scope categorization for all Technology Assets, Applications and/or Services (TAAS) and personnel (internal and third-parties).	5	Controls pattern 1
8.1.2.5	N/A	8.1.2.5 corresponds to the c) part of 8.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: Japan - Information System Security Management and Assessment Program (ISMAP)

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf69e91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.1.2.6	N/A	8.1.2.6 corresponds to the d) part of 8.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	5	Controls pattern 1
8.1.2.7.PB	N/A	The cloud service provider provides the cloud service customer with one of the following to manage the assets (including backups) of such customer. (a) A function that encrypts the assets managed by the relevant customer before they are recorded (including backups) on a storage medium, and enables the relevant customer to manage and delete the encryption key (b) Information necessary for the relevant customer to implement the function of encrypting the assets managed by the relevant customer before recording (including backup) them on the storage media, and manage and delete the cryptographic keys	Functional	Intersects With	Cloud Security Architecture	CLD-02	Mechanisms exist to ensure the cloud security architecture supports the organization's technology strategy to securely design, configure and maintain cloud employments.	3	Controls pattern 2
8.1.3	N/A	8.1.3 corresponds to the part of 8.1.3 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	5	
8.1.3.1	N/A	8.1.3.1 corresponds to the 1st sentence(beginning with "Employees and external") of the 1st(last) paragraph of the Implementation guidance of 8.1.3 in ISO/IEC 27002:2013.	Functional	Intersects With	User Awareness	HRS-03.1	Mechanisms exist to communicate with users about their roles and responsibilities to maintain a safe and secure working environment.	5	Controls pattern 1
8.1.3.1	N/A	8.1.3.1 corresponds to the 1st sentence(beginning with "Employees and external") of the 1st(last) paragraph of the Implementation guidance of 8.1.3 in ISO/IEC 27002:2013.	Functional	Intersects With	Formal Indoctination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	5	Controls pattern 1
8.1.3.1	N/A	8.1.3.1 corresponds to the 1st sentence(beginning with "Employees and external") of the 1st(last) paragraph of the Implementation guidance of 8.1.3 in ISO/IEC 27002:2013.	Functional	Intersects With	Policy Familiarization & Acknowledgement	HRS-05.7	Mechanisms exist to ensure personnel receive recurring familiarization with the organization's security, compliance and resilience policies and provide acknowledgement.	5	Controls pattern 1
8.1.3.2	N/A	8.1.3.2 corresponds to the 2nd(last) sentence(beginning with "They should be") of the 1st(last) paragraph of the Implementation guidance of 8.1.3 in ISO/IEC 27002:2013.	Functional	Intersects With	Rules of Behavior	HRS-05.1	Mechanisms exist to define acceptable and unacceptable rules of behavior for the use of technologies, including consequences for unacceptable behavior.	5	Controls pattern 1
8.1.4	N/A	8.1.4 corresponds to the part of 8.1.4 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Return of Assets	AST-10	Mechanisms exist to ensure that employees and third-party users return all organizational assets in their possession upon termination of employment, contract or agreement.	5	
8.1.4.1	N/A	8.1.4.1 corresponds to the 1st(last) sentence(beginning with "The termination") of the 1st paragraph of the Implementation guidance of 8.1.4 in ISO/IEC 27002:2013.	Functional	Intersects With	Onboarding, Transferring & Offboarding Personnel	HRS-01.1	Mechanisms exist to proactively govern the following personnel management actions: (1) Onboarding new personnel (e.g., new hires); (2) Transferring personnel into new roles within the organization; and (3) Offboarding personnel (e.g., termination of employment).	5	Controls pattern 1
8.1.4.2	N/A	8.1.4.2 corresponds to the 1st(last) sentence(beginning with "In cases where") of the 2nd paragraph of the Implementation guidance of 8.1.4 in ISO/IEC 27002:2013.	Functional	Intersects With	Onboarding, Transferring & Offboarding Personnel	HRS-01.1	Mechanisms exist to proactively govern the following personnel management actions: (1) Onboarding new personnel (e.g., new hires); (2) Transferring personnel into new roles within the organization; and (3) Offboarding personnel (e.g., termination of employment).	5	Controls pattern 1
8.1.4.3	N/A	8.1.4.3 corresponds to the 1st(last) sentence(beginning with "In cases where") of the 3rd paragraph of the Implementation guidance of 8.1.4 in ISO/IEC 27002:2013.	Functional	Intersects With	Onboarding, Transferring & Offboarding Personnel	HRS-01.1	Mechanisms exist to proactively govern the following personnel management actions: (1) Onboarding new personnel (e.g., new hires); (2) Transferring personnel into new roles within the organization; and (3) Offboarding personnel (e.g., termination of employment).	5	Controls pattern 1
8.1.4.4	N/A	8.1.4.4 corresponds to the 1st(last) sentence(beginning with "During the notice") of the 4th(last) paragraph of the Implementation guidance of 8.1.4 in ISO/IEC 27002:2013.	Functional	Intersects With	Onboarding, Transferring & Offboarding Personnel	HRS-01.1	Mechanisms exist to proactively govern the following personnel management actions: (1) Onboarding new personnel (e.g., new hires); (2) Transferring personnel into new roles within the organization; and (3) Offboarding personnel (e.g., termination of employment).	5	Controls pattern 1
8.1.5.P	N/A	8.1.5.P corresponds to the part of CLD.8.1.5 Control in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Cloud Infrastructure Offboarding	CLD-01.2	Mechanisms exist to ensure cloud services are decommissioned so that data is securely transitioned to new systems or archived in accordance with applicable organizational standards, as well as statutory, regulatory and contractual obligations.	5	
8.1.5.1.P	N/A	8.1.5.1.P corresponds to the 1st(last) sentence(beginning with "The cloud service") of the 1st paragraph of the Implementation guidance of CLD.8.1.5 in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Cloud Infrastructure Offboarding	CLD-01.2	Mechanisms exist to ensure cloud services are decommissioned so that data is securely transitioned to new systems or archived in accordance with applicable organizational standards, as well as statutory, regulatory and contractual obligations.	5	Controls pattern 3
8.1.5.2.P	N/A	8.1.5.2.P corresponds to the 1st sentence(beginning with "The asset return") of the 2nd(last) paragraph of the Implementation guidance of CLD.8.1.5 in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Cloud Infrastructure Offboarding	CLD-01.2	Mechanisms exist to ensure cloud services are decommissioned so that data is securely transitioned to new systems or archived in accordance with applicable organizational standards, as well as statutory, regulatory and contractual obligations.	5	Controls pattern 1
8.1.5.3.P	N/A	8.1.5.3.P corresponds to the 2nd(last) sentence(beginning with "The arrangements") of the 2nd(last) paragraph of the Implementation guidance of CLD.8.1.5 in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Cloud Infrastructure Offboarding	CLD-01.2	Mechanisms exist to ensure cloud services are decommissioned so that data is securely transitioned to new systems or archived in accordance with applicable organizational standards, as well as statutory, regulatory and contractual obligations.	5	Controls pattern 1
8.1.5.4.P	N/A	Cloud service providers shall implement encrypted erasure for the assets of cloud service users that the cloud service provider is responsible for erasing based on a contract or other agreement.	Functional	Intersects With	Cloud Infrastructure Offboarding	CLD-01.2	Mechanisms exist to ensure cloud services are decommissioned so that data is securely transitioned to new systems or archived in accordance with applicable organizational standards, as well as statutory, regulatory and contractual obligations.	5	Controls pattern 1
8.2	N/A	Information classification Control Objective: To ensure that information receives an appropriate level of protection in accordance with its importance to the organization.	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	
8.2.1	N/A	8.2.1 corresponds to the part of 8.2.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	5	
8.2.1.1	N/A	8.2.1.1 corresponds to the 1st sentence(beginning with "Classifications") of the 1st paragraph of the Implementation guidance of 8.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	10	Controls pattern 1
8.2.1.2	N/A	8.2.1.2 corresponds to the 1st(last) sentence(beginning with "Owners of information") of the 2nd paragraph of the Implementation guidance of 8.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	10	Controls pattern 1
8.2.1.3	N/A	8.2.1.3 corresponds to the 1st sentence(beginning with "The classification") of the 3rd paragraph of the Implementation guidance of 8.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	10	Controls pattern 1
8.2.1.4	N/A	8.2.1.4 corresponds to the 2nd sentence(beginning with "The level of protection") of the 3rd paragraph of the Implementation guidance of 8.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	10	Controls pattern 1
8.2.1.5	N/A	8.2.1.5 corresponds to the 3rd(last) sentence(beginning with "The scheme should") of the 3rd paragraph of the Implementation guidance of 8.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	10	Controls pattern 1
8.2.1.6	N/A	8.2.1.6 corresponds to the 1st(last) sentence(beginning with "Each level should") of the 4th paragraph of the Implementation guidance of 8.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	10	Controls pattern 1
8.2.1.7	N/A	8.2.1.7 corresponds to the 1st(last) sentence(beginning with "The scheme should") of the 5th paragraph of the Implementation guidance of 8.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	10	Controls pattern 1
8.2.1.8	N/A	8.2.1.8 corresponds to the 1st sentence(beginning with "Classification") of the 6th(last) paragraph of the Implementation guidance of 8.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	10	Controls pattern 1
8.2.1.9	N/A	8.2.1.9 corresponds to the 2nd sentence(beginning with "Results of classification") of the 6th(last) paragraph of the Implementation guidance of 8.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	10	Controls pattern 1
8.2.1.10	N/A	8.2.1.10 corresponds to the 3rd(last) sentence(beginning with "Results of classification") of the 6th(last) paragraph of the Implementation guidance of 8.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	10	Controls pattern 1
8.2.2	N/A	8.2.2 corresponds to the part of 8.2.2 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm/?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf6d9e91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.2.2.1	N/A	8.2.2.1 corresponds to the 1st sentence(beginning with "Procedures for") of the 1st paragraph of the Implementation guidance of 8.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	10	Controls pattern 1
8.2.2.2	N/A	8.2.2.2 corresponds to the 2nd sentence(beginning with "The labelling should") of the 1st paragraph of the Implementation guidance of 8.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	10	Controls pattern 1
8.2.2.3	N/A	8.2.2.3 corresponds to the 3rd sentence(beginning with "The labels should") of the 1st paragraph of the Implementation guidance of 8.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	10	Controls pattern 1
8.2.2.4	N/A	8.2.2.4 corresponds to the 4th sentence(beginning with "The procedures") of the 1st paragraph of the Implementation guidance of 8.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	10	Controls pattern 1
8.2.2.5	N/A	8.2.2.5 corresponds to the 6th(last) sentence(beginning with "Employees and contractors") of the 1st paragraph of the Implementation guidance of 8.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	10	Controls pattern 1
8.2.2.6	N/A	8.2.2.6 corresponds to the 1st(last) sentence(beginning with "Output from systems") of the 2nd(last) paragraph of the Implementation guidance of 8.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	10	Controls pattern 1
8.2.2.7.PB	N/A	The cloud service provider documents and discloses the service functions that allow cloud service customers to classify and label the information and related assets handled by the cloud service providers.	Functional	Intersects With	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	5	Controls pattern 3
8.2.3	N/A	8.2.3 corresponds to the part of 8.2.3 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	
8.2.3.1	N/A	8.2.3.1 corresponds to the 1st(last) sentence(beginning with "Procedures should") of the 1st paragraph of the Implementation guidance of 8.2.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	Controls pattern 1
8.2.3.2	N/A	8.2.3.2 corresponds to the a) part of 8.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Defining Access Authorizations for Sensitive / Regulated Data	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and /or physical access to sensitive and/or regulated data.	5	Controls pattern 1
8.2.3.3	N/A	8.2.3.3 corresponds to the b) part of 8.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Sensitive / Regulated Media Records	DCH-01.3	Mechanisms exist to ensure media records for sensitive and/or regulated data contain sufficient information to determine the potential impact in the event of a data loss incident.	5	Controls pattern 1
8.2.3.4	N/A	8.2.3.4 corresponds to the c) part of 8.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Sensitive / Regulated Media Records	DCH-01.3	Mechanisms exist to ensure media records for sensitive and/or regulated data contain sufficient information to determine the potential impact in the event of a data loss incident.	5	Controls pattern 1
8.2.3.5	N/A	8.2.3.5 corresponds to the d) part of 8.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Unattended End-User Equipment	AST-06	Mechanisms exist to implement enhanced protection measures for unattended technology assets to protect against tampering and unauthorized access.	5	Controls pattern 1
8.2.3.6	N/A	8.2.3.6 corresponds to the e) part of 8.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Media Marking	DCH-04	Mechanisms exist to mark media in accordance with data protection requirements so that personnel are alerted to distribution limitations, handling caveats and applicable security requirements.	5	Controls pattern 1
8.2.3.7	N/A	Agreements involving the sharing of information with other organizations include procedures for identifying the classification of that information and for communicating the interpretation of classification labels and access restrictions from or to other organizations, as well as procedures to support that interpretation.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Controls pattern 1
8.3	N/A	Media handling Control Objective: To prevent unauthorized disclosure, modification, removal or destruction of information stored on media.	Functional	Intersects With	Security of Assets & Media	AST-05	Mechanisms exist to maintain strict control over Technology Assets, Applications, Services and/or Data (TAASD) to preserve confidentiality and integrity.	5	
8.3.1	N/A	8.3.1 corresponds to the part of 8.3.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Security of Assets & Media	AST-05	Mechanisms exist to maintain strict control over Technology Assets, Applications, Services and/or Data (TAASD) to preserve confidentiality	5	
8.3.1.1	N/A	8.3.1.1 corresponds to the a) part of 8.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	5	Controls pattern 1
8.3.1.2	N/A	The organization requires authorization for media to be transferred from the organization for the control of removable media when necessary and practical.	Functional	Intersects With	Management Approval For External Media Transfer	AST-05.1	Mechanisms exist to obtain management approval for any sensitive and/or regulated media that is transferred outside of the organization's facilities.	5	Controls pattern 1
8.3.1.3	N/A	The organization keeps records to maintain an assessment trail of media transferred from the organization for the management of removable media.	Functional	Intersects With	Sensitive / Regulated Media Records	DCH-01.3	Mechanisms exist to ensure media records for sensitive and/or regulated data contain sufficient information to determine the potential impact in the event of a data loss incident.	5	Controls pattern 1
8.3.1.4	N/A	8.3.1.4 corresponds to the c) part of 8.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Media Storage	DCH-06	Mechanisms exist to: (1) Physically control and securely store digital and non-digital media within controlled areas using organization-defined security measures; and (2) Protect system media until the media are destroyed or sanitized using approved equipment, techniques and procedures.	5	Controls pattern 1
8.3.1.4	N/A	8.3.1.4 corresponds to the c) part of 8.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physically Secure All Media	DCH-06.1	Mechanisms exist to physically secure all media that contains sensitive information.	5	Controls pattern 1
8.3.1.5	N/A	8.3.1.5 corresponds to the d) part of 8.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Encrypting Data At Rest	CRY-05	Cryptographic mechanisms exist to prevent unauthorized disclosure of data at rest.	5	Controls pattern 1
8.3.1.6	N/A	8.3.1.6 corresponds to the e) part of 8.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	No Relationship	N/A	N/A	N/A	0	
8.3.1.7	N/A	8.3.1.7 corresponds to the f) part of 8.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Separate Storage for Critical Information	BCD-11.2	Mechanisms exist to store backup copies of critical software and other security-related information in a separate facility or in a fire-rated container that is not collocated with the system being backed up.	5	Controls pattern 1
8.3.1.8	N/A	8.3.1.8 corresponds to the g) part of 8.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	No Relationship	N/A	N/A	N/A	0	
8.3.1.9	N/A	8.3.1.9 corresponds to the h) part of 8.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	Controls pattern 1
8.3.1.10	N/A	8.3.1.10 corresponds to the i) part of 8.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Custodians	DCH-07.1	Mechanisms exist to identify custodians throughout the transport of digital or non-digital media.	5	Controls pattern 1
8.3.1.11	N/A	8.3.1.11 corresponds to the 1st(last) sentence(beginning with "Procedures and") of the 2nd(last) paragraph of the Implementation guidance of 8.3.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	5	Controls pattern 1
8.3.2	N/A	8.3.2 corresponds to the part of 8.3.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	5	
8.3.2.1	N/A	8.3.2.1 corresponds to the 1st sentence(beginning with "Formal procedures") of the 1st paragraph of the Implementation guidance of 8.3.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	5	Controls pattern 1
8.3.2.2	N/A	8.3.2.2 corresponds to the 2nd sentence(beginning with "The procedures") of the 1st paragraph of the Implementation guidance of 8.3.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	5	Controls pattern 1
8.3.2.3	N/A	8.3.2.3 corresponds to the a) part of 8.3.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	5	Controls pattern 1
8.3.2.4	N/A	8.3.2.4 corresponds to the b) part of 8.3.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Media Disposal	DCH-08	Mechanisms exist to securely dispose of media when it is no longer required, using formal procedures.	5	Controls pattern 1
8.3.2.5	N/A	8.3.2.5 corresponds to the c) part of 8.3.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Media Disposal	DCH-08	Mechanisms exist to securely dispose of media when it is no longer required, using formal procedures.	5	Controls pattern 1
8.3.2.6	N/A	8.3.2.6 corresponds to the d) part of 8.3.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Media Disposal	DCH-08	Mechanisms exist to securely dispose of media when it is no longer required, using formal procedures.	5	Controls pattern 1

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.3.2.7	N/A	8.3.2.7 corresponds to the e) part of 8.3.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	System Media Sanitization Documentation	DCH-09.1	Mechanisms exist to supervise, track, document and verify system media sanitization and disposal actions.	5	Controls pattern 1
8.3.2.8	N/A	8.3.2.8 corresponds to the 1st(last) sentence(beginning with "When accumulating") of the 2nd(last) paragraph of the Implementation guidance of 8.3.2 in ISO/IEC 27002:2013.	Functional	No Relationship	N/A	N/A	N/A	0	
8.3.3	N/A	8.3.3 corresponds to the part of 8.3.3 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5	
8.3.3.1	N/A	8.3.3.1 corresponds to the a) part of 8.3.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5	Controls pattern 1
8.3.3.2	N/A	8.3.3.2 corresponds to the b) part of 8.3.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5	Controls pattern 1
8.3.3.3	N/A	8.3.3.3 corresponds to the c) part of 8.3.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5	Controls pattern 1
8.3.3.4	N/A	8.3.3.4 corresponds to the d) part of 8.3.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5	Controls pattern 1
8.3.3.5	N/A	8.3.3.5 corresponds to the e) part of 8.3.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5	Controls pattern 1
9	N/A	Access control	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
9.1	N/A	Business requirements of access control Control Objective: To limit access to information and information processing facilities.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
9.1.1	N/A	9.1.1 corresponds to the part of 9.1.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
9.1.1.1	N/A	The person responsible for managing the assets determines appropriate access control rules, access rights, and restrictions for each customer's role related to assets, with the level of control detail and rigor reflecting the information security risks associated with access, and documents the systems and services that do not require customer authentication, along with the rationale for not requiring authentication.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.2	N/A	9.1.1.2 corresponds to the 1st sentence(beginning with "Access controls") of the 2nd paragraph of the Implementation guidance of 9.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.3	N/A	9.1.1.3 corresponds to the 2nd(last) sentence(beginning with "Users and service") of the 2nd paragraph of the Implementation guidance of 9.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.4	N/A	9.1.1.4 corresponds to the a) part of 9.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.5	N/A	9.1.1.5 corresponds to the b) part of 9.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.6	N/A	9.1.1.6 corresponds to the c) part of 9.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.7	N/A	9.1.1.7 corresponds to the d) part of 9.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.8	N/A	9.1.1.8 corresponds to the e) part of 9.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.9	N/A	9.1.1.9 corresponds to the f) part of 9.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.10	N/A	9.1.1.10 corresponds to the g) part of 9.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.11	N/A	9.1.1.11 corresponds to the h) part of 9.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.12	N/A	9.1.1.12 corresponds to the i) part of 9.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.13	N/A	9.1.1.13 corresponds to the j) part of 9.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.14	N/A	9.1.1.14 corresponds to the k) part of 9.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.15	N/A	The access control policy should include the definition and identification of systems and services that do not require user authentication.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 1
9.1.1.16	N/A	The access control policy should include requirements for zero trust architecture (dynamic access control).	Functional	Intersects With	Zero Trust Architecture (ZTA)	NET-01.1	Mechanisms exist to treat all users and devices as potential threats and prevent access to data and resources until the users can be properly authenticated and their access authorized.	5	Controls pattern 1
9.1.2	N/A	9.1.2 corresponds to the part of 9.1.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	
9.1.2.1	N/A	9.1.2.1 corresponds to the 1st sentence(beginning with "A policy should") of the 1st paragraph of the Implementation guidance of 9.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Controls pattern 1
9.1.2.2	N/A	9.1.2.2 corresponds to the a) part of 9.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Controls pattern 1
9.1.2.3	N/A	9.1.2.3 corresponds to the b) part of 9.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Controls pattern 1
9.1.2.4	N/A	9.1.2.4 corresponds to the c) part of 9.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Controls pattern 1
9.1.2.5	N/A	9.1.2.5 corresponds to the d) part of 9.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Controls pattern 1
9.1.2.6	N/A	9.1.2.6 corresponds to the e) part of 9.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Controls pattern 1
9.1.2.7	N/A	9.1.2.7 corresponds to the f) part of 9.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Controls pattern 1
9.1.2.8	N/A	9.1.2.8 corresponds to the 1st(last) sentence(beginning with "The policy on the") of the 2nd(last) paragraph of the Implementation guidance of 9.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	Controls pattern 1
9.2	N/A	User access management Control Objective: To ensure authorized user access and to prevent unauthorized access to systems and services.	Functional	Subset Of	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	10	
9.2.1	N/A	9.2.1 corresponds to the part of 9.2.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	5	
9.2.1.1	N/A	The process for managing customer IDs include the use of unique customer IDs to associate customers with their own actions and make it possible to make customers to take responsibility for their actions.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	5	Controls pattern 1
9.2.1.2	N/A	The organization includes in the process for managing customer IDs of allowing, approving, and recording the use of shared IDs only when necessary for business or operational reasons.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	5	Controls pattern 1

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
9.2.1.3	N/A	9.2.1.3 corresponds to the b) part of 9.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	5	Controls pattern 1
9.2.1.4	N/A	9.2.1.4 corresponds to the c) part of 9.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	5	
9.2.1.5	N/A	9.2.1.5 corresponds to the d) part of 9.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	5	
9.2.1.6.PB	N/A	9.2.1.6.PB corresponds to the 1st(last) sentence(beginning with "To manage access") of the 1st(last) paragraph of the Implementation guidance of 9.2.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	5	Controls pattern 2
9.2.2	N/A	9.2.2 corresponds to the part of 9.2.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5	
9.2.2.1	N/A	9.2.2.1 corresponds to the a) part of 9.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Management Approval For New or Changed Accounts	IAC-28.1	Mechanisms exist to ensure management approvals are required for new accounts or changes in permissions to existing accounts.	5	Controls pattern 1
9.2.2.2	N/A	The organization includes in the process for assigning and revoking access rights to customer IDs a check that the level of access granted is appropriate for the access control policy.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5	Controls pattern 1
9.2.2.3	N/A	The organization includes in the process for assigning and revoking access rights to customer IDs the verification that the level of access granted is consistent with other requirements, such as segregation of duties.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5	Controls pattern 1
9.2.2.4	N/A	9.2.2.4 corresponds to the c) part of 9.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5	Controls pattern 1
9.2.2.5	N/A	9.2.2.5 corresponds to the d) part of 9.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Automated System Account Management (Directory Services)	IAC-15.1	Automated mechanisms exist to support the management of system accounts (e.g., directory services).	5	Controls pattern 1
9.2.2.6	N/A	9.2.2.6 corresponds to the e) part of 9.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5	Controls pattern 1
9.2.2.7	N/A	9.2.2.7 corresponds to the f) part of 9.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5	Controls pattern 1
9.2.2.8.PB	N/A	9.2.2.8.PB corresponds to the 9.2. Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5	Controls pattern 2
9.2.3	N/A	9.2.3 corresponds to the part of 9.2.3 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	10	
9.2.3.1	N/A	9.2.3.1 corresponds to the 1st sentence(beginning with "The allocation") of the 1st(last) paragraph of the Implementation guidance of 9.2.3 in ISO/IEC 27002:2013.	Functional	Intersects With	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
9.2.3.2	N/A	9.2.3.2 corresponds to the a) part of 9.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
9.2.3.3	N/A	9.2.3.3 corresponds to the b) part of 9.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
9.2.3.4	N/A	9.2.3.4 corresponds to the c) 1st sentence(beginning with "c) an authorization") of the 1st(last) paragraph of the Implementation guidance of 9.2.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
9.2.3.5	N/A	9.2.3.5 corresponds to the c) 2nd sentence(beginning with "Privileged access") of the 1st(last) paragraph of the Implementation guidance of 9.2.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
9.2.3.6	N/A	9.2.3.6 corresponds to the d) part of 9.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
9.2.3.7	N/A	9.2.3.7 corresponds to the e) part of 9.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
9.2.3.8	N/A	9.2.3.8 corresponds to the f) part of 9.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
9.2.3.9	N/A	9.2.3.9 corresponds to the g) part of 9.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
9.2.3.10	N/A	9.2.3.10 corresponds to the h) part of 9.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
9.2.3.11.PB	N/A	Depending on the identified risks, cloud service providers provide sufficiently strong authentication technologies (for example, multi-factor authentication) for administrator authentication of cloud service customers that are tailored to the management capabilities of the cloud service.	Functional	Intersects With	Cloud Security Architecture	CLD-02	Mechanisms exist to ensure the cloud security architecture supports the organization's technology strategy to securely design, configure and maintain cloud employments.	5	Controls pattern 2
9.2.4	N/A	9.2.4 corresponds to the part of 9.2.4 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	
9.2.4.1	N/A	The formal management process for the assignment of secret authentication information requires the customer to sign a document stating that personal secret authentication information will be kept confidential. This signed document can be included in the terms and conditions of employment contracts.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	Controls pattern 1
9.2.4.2	N/A	9.2.4.2 corresponds to the a) part of 9.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Terms of Employment	HRS-05	Mechanisms exist to require all employees and contractors to apply cybersecurity and data protection principles in their daily work to enable secure, compliant and resilient capabilities.	5	Controls pattern 1
9.2.4.3	N/A	9.2.4.3 corresponds to the b) part of 9.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	Controls pattern 1
9.2.4.4	N/A	9.2.4.4 corresponds to the c) part of 9.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	
9.2.4.5	N/A	9.2.4.5 corresponds to the d) part of 9.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	Controls pattern 1
9.2.4.6	N/A	9.2.4.6 corresponds to the e) part of 9.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	Controls pattern 1
9.2.4.7	N/A	9.2.4.7 corresponds to the f) part of 9.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	Controls pattern 1
9.2.4.8	N/A	9.2.4.8 corresponds to the g) part of 9.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticator Management	IAC-10	Mechanisms exist to: (1) Securely manage authenticators for users and devices; and (2) Ensure the strength of authentication is appropriate to the classification of the data being accessed.	5	Controls pattern 1
9.2.4.9.PB	N/A	9.2.4.9.PB corresponds to the 9.2. Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and	5	Controls pattern 3
9.2.5	N/A	9.2.5 corresponds to the part of 9.2.5 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5	
9.2.5.1	N/A	The organization reviews the customer's access rights at defined intervals.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5	Controls pattern 1
9.2.5.2	N/A	The organization reviews customer access rights after any change (for example, promotion, demotion, termination of employment).	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5	Controls pattern 1

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
9.2.5.3	N/A	9.2.5.3 corresponds to the b) part of 9.2.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5	Controls pattern 1
9.2.5.4	N/A	9.2.5.4 corresponds to the c) part of 9.2.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5	Controls pattern 1
9.2.5.5	N/A	9.2.5.5 corresponds to the d) part of 9.2.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5	Controls pattern 1
9.2.5.6	N/A	9.2.5.6 corresponds to the e) part of 9.2.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Periodic Review of Account Privileges	IAC-17	Mechanisms exist to periodically-review the privileges assigned to individuals and service accounts to validate the need for such privileges and reassign or remove unnecessary privileges, as necessary.	5	Controls pattern 1
9.2.6	N/A	9.2.6 corresponds to the part of 9.2.6 Control in ISO/IEC 27002:2013.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5	
9.2.6.1	N/A	9.2.6.1 corresponds to the 1st sentence(beginning with "Upon termination," of the 1st paragraph of the Implementation guidance of 9.2.6 in ISO/IEC 27002:2013.	Functional	Intersects With	Revocation of Access Authorizations	IAC-20.6	Mechanisms exist to revoke logical and physical access authorizations.	5	Controls pattern 1
9.2.6.2	N/A	9.2.6.2 corresponds to the 2nd sentence(beginning with "Changes of employment") of the 1st paragraph of the Implementation guidance of 9.2.6 in ISO/IEC 27002:2013.	Functional	Intersects With	Onboarding, Transferring & Offboarding Personnel	HRS-01.1	Mechanisms exist to proactively govern the following personnel management actions: (1) Onboarding new personnel (e.g., new hires); (2) Transferring personnel into new roles within the organization; and (3) Offboarding personnel (e.g., termination of employment).	5	Controls pattern 1
9.2.6.3	N/A	9.2.6.3 corresponds to the 3rd sentence(beginning with "The access rights") of the 1st paragraph of the Implementation guidance of 9.2.6 in ISO/IEC 27002:2013.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5	Controls pattern 1
9.2.6.4	N/A	9.2.6.4 corresponds to the 4th sentence(beginning with "Any documentation") of the 1st paragraph of the Implementation guidance of 9.2.6 in ISO/IEC 27002:2013.	Functional	Intersects With	Onboarding, Transferring & Offboarding Personnel	HRS-01.1	Mechanisms exist to proactively govern the following personnel management actions: (1) Onboarding new personnel (e.g., new hires); (2) Transferring personnel into new roles within the organization; and (3) Offboarding personnel (e.g., termination of employment).	5	Controls pattern 1
9.2.6.5	N/A	9.2.6.5 corresponds to the 5th(last) sentence(beginning with "If a departing") of the 1st paragraph of the Implementation guidance of 9.2.6 in ISO/IEC 27002:2013.	Functional	Intersects With	Onboarding, Transferring & Offboarding Personnel	HRS-01.1	Mechanisms exist to proactively govern the following personnel management actions: (1) Onboarding new personnel (e.g., new hires); (2) Transferring personnel into new roles within the organization; and (3) Offboarding personnel (e.g., termination of employment).	5	Controls pattern 1
9.2.6.6	N/A	9.2.6.6 corresponds to the 1st sentence(beginning with "Access rights for") of the 2nd(last) paragraph of the Implementation guidance of 9.2.6 in ISO/IEC 27002:2013.	Functional	Intersects With	Onboarding, Transferring & Offboarding Personnel	HRS-01.1	Mechanisms exist to proactively govern the following personnel management actions: (1) Onboarding new personnel (e.g., new hires); (2) Transferring personnel into new roles within the organization; and (3) Offboarding personnel (e.g., termination of employment).	5	Controls pattern 1
9.3	N/A	User responsibilities Control Objective: To make users accountable for safeguarding their authentication information.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5	
9.3.1	N/A	9.3.1 corresponds to the part of 9.3.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5	
9.3.1.1	N/A	9.3.1.1 corresponds to the a) part of 9.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5	Controls pattern 1
9.3.1.2	N/A	9.3.1.2 corresponds to the b) part of 9.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5	Controls pattern 1
9.3.1.3	N/A	9.3.1.3 corresponds to the c) part of 9.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5	Controls pattern 1
9.3.1.4	N/A	9.3.1.4 corresponds to the d) part of 9.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Controls pattern 1
9.3.1.5	N/A	9.3.1.5 corresponds to the e) part of 9.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5	Controls pattern 1
9.3.1.6	N/A	9.3.1.6 corresponds to the f) part of 9.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5	Controls pattern 1
9.3.1.7	N/A	9.3.1.7 corresponds to the g) part of 9.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Protection of Authenticators	IAC-10.5	Mechanisms exist to protect authenticators commensurate with the sensitivity of the information to which use of the authenticator permits access.	5	Controls pattern 1
9.4	N/A	System and application access control Control Objective: To prevent unauthorized access to systems and applications.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	
9.4.1	N/A	9.4.1 corresponds to the part of 9.4.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	
9.4.1.1	N/A	9.4.1.1 corresponds to the 1st(last) sentence(beginning with "Restrictions to") of the 1st paragraph of the Implementation guidance of 9.4.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Controls pattern 1
9.4.1.2	N/A	The application system function provides only essential functions to meet access restriction requirements, and provide a menu to control access to those functions.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Controls pattern 1
9.4.1.3	N/A	The organization controls the functions, ports, protocols, services, and data that customers can access to meet access restriction requirements.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Controls pattern 1
9.4.1.4	N/A	9.4.1.4 corresponds to the c) part of 9.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Controls pattern 1
9.4.1.5	N/A	9.4.1.5 corresponds to the d) part of 9.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Controls pattern 1
9.4.1.6	N/A	9.4.1.6 corresponds to the e) part of 9.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Controls pattern 1
9.4.1.7	N/A	9.4.1.7 corresponds to the f) part of 9.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	Controls pattern 1
9.4.1.8.PB	N/A	9.4.1.8.PB corresponds to the 9.4. Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Controls pattern 2
9.4.2	N/A	9.4.2 corresponds to the part of 9.4.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	
9.4.2.1	N/A	9.4.2.1 corresponds to the 1st(last) sentence(beginning with "A suitable authentication") of the 1st paragraph of the Implementation guidance of 9.4.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.gp.jp/csm/?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bbfd69f91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
9.4.2.2.B	N/A	9.4.2.2.B corresponds to the 1st(last) sentence(beginning with "Where strong authentication") of the 2nd paragraph of the Implementation guidance of 9.4.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.3	N/A	9.4.2.3 corresponds to the 1st sentence(beginning with "The procedure for") of the 3rd(last) paragraph of the Implementation guidance of 9.4.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.4	N/A	9.4.2.4 corresponds to the 2nd sentence(beginning with "The log-on procedure") of the 3rd(last) paragraph of the Implementation guidance of 9.4.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.5	N/A	9.4.2.5 corresponds to the a) part of 9.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.6	N/A	9.4.2.6 corresponds to the b) part of 9.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.7	N/A	9.4.2.7 corresponds to the c) part of 9.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.8	N/A	9.4.2.8 corresponds to the d) part of 9.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.9	N/A	9.4.2.9 corresponds to the e) part of 9.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.10	N/A	9.4.2.10 corresponds to the f) part of 9.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.11	N/A	9.4.2.11 corresponds to the g) part of 9.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.12	N/A	9.4.2.12 corresponds to the h) part of 9.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.13	N/A	9.4.2.13 corresponds to the i) part of 9.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.14	N/A	9.4.2.14 corresponds to the j) part of 9.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.15	N/A	For logon procedures, sessions that meet predetermined conditions are to be terminated, especially in high-risk locations (for example, public or external areas outside the organization's security control, mobile devices).	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.2.16	N/A	9.4.2.16 corresponds to the l) part of 9.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Controls pattern 1
9.4.3	N/A	9.4.3 corresponds to the part of 9.4.3 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	
9.4.3.1	N/A	9.4.3.1 corresponds to the a) part of 9.4.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Controls pattern 1
9.4.3.2	N/A	9.4.3.2 corresponds to the b) part of 9.4.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Controls pattern 1
9.4.3.3	N/A	Password management systems should let the user choose a good quality password. For example, the password should have the number of digits and complexity required for a strong password. (See 9.4.3.3 corresponds to the c) part of 9.4.3 Implementation guidance in ISO/IEC 27002:2013.)	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Controls pattern 1
9.4.3.4	N/A	9.4.3.4 corresponds to the d) part of 9.4.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Controls pattern 1
9.4.3.5	N/A	The password management system forces customers to change passwords periodically or as needed.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Controls pattern 1
9.4.3.6	N/A	9.4.3.6 corresponds to the f) part of 9.4.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Controls pattern 1
9.4.3.7	N/A	9.4.3.7 corresponds to the g) part of 9.4.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Controls pattern 1
9.4.3.8	N/A	9.4.3.8 corresponds to the h) part of 9.4.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Controls pattern 1
9.4.3.9	N/A	9.4.3.9 corresponds to the i) part of 9.4.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	5	Controls pattern 1
9.4.4	N/A	9.4.4 corresponds to the part of 9.4.4 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	
9.4.4.1	N/A	9.4.4.1 corresponds to the a) part of 9.4.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	Controls pattern 1
9.4.4.2	N/A	9.4.4.2 corresponds to the b) part of 9.4.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	Controls pattern 1
9.4.4.3	N/A	9.4.4.3 corresponds to the c) part of 9.4.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	Controls pattern 1
9.4.4.4	N/A	9.4.4.4 corresponds to the d) part of 9.4.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	Controls pattern 1
9.4.4.5	N/A	9.4.4.5 corresponds to the e) part of 9.4.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	Controls pattern 1
9.4.4.6	N/A	9.4.4.6 corresponds to the f) part of 9.4.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	Controls pattern 1
9.4.4.7	N/A	9.4.4.7 corresponds to the g) part of 9.4.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	Controls pattern 1
9.4.4.8	N/A	9.4.4.8 corresponds to the h) part of 9.4.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	Controls pattern 1
9.4.4.9	N/A	9.4.4.9 corresponds to the i) part of 9.4.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	Controls pattern 1
9.4.4.10.P	N/A	9.4.4.10.P corresponds to the 1st(last) sentence(beginning with "The cloud service") of the 1st paragraph of the Implementation guidance of 9.4.4 in ISO/IEC 27017:2015.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	Controls pattern 1
9.4.4.11.P	N/A	9.4.4.11.P corresponds to the 1st(last) sentence(beginning with "The cloud service") of the 2nd(last) paragraph of the Implementation guidance of 9.4.4 in ISO/IEC 27017:2015.	Functional	Intersects With	Use of Privileged Utility Programs	IAC-20.3	Mechanisms exist to restrict and tightly control utility programs that are capable of overriding system and application controls.	5	Controls pattern 1
9.4.5	N/A	9.4.5 corresponds to the part of 9.4.5 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	
9.4.5.1	N/A	9.4.5.1 corresponds to the 1st sentence(beginning with "Access to program") of the 1st paragraph of the Implementation guidance of 9.4.5 in ISO/IEC 27002:2013.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	Controls pattern 1
9.4.5.2	N/A	9.4.5.2 corresponds to the a) part of 9.4.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	Controls pattern 1
9.4.5.3	N/A	9.4.5.3 corresponds to the b) part of 9.4.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	Controls pattern 1
9.4.5.4	N/A	9.4.5.4 corresponds to the c) part of 9.4.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	Controls pattern 1
9.4.5.5	N/A	9.4.5.5 corresponds to the d) part of 9.4.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	Controls pattern 1
9.4.5.6	N/A	9.4.5.6 corresponds to the e) part of 9.4.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	Controls pattern 1
9.4.5.7	N/A	9.4.5.7 corresponds to the f) part of 9.4.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	Controls pattern 1

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
9.4.5.8	N/A	9.4.5.8 corresponds to the g) part of 9.4.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	Controls pattern 1
9.4.5.9	N/A	9.4.5.9 corresponds to the 2nd(last) sentence(beginning with "If the program") of the 1st paragraph of the Implementation guidance of 9.4.5 in ISO/IEC 27002:2013.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	Controls pattern 1
9.5.P	N/A	Access control of cloud service customer data in shared virtual environment Control Objective: To mitigate information security risks when using the shared virtual environment of cloud computing.	Functional	Intersects With	Information In Shared Resources	SEA-05	Mechanisms exist to prevent unauthorized and unintended information transfer via shared system resources.	5	
9.5.1.P	N/A	9.5.1.P corresponds to the part of CLD.9.5.1 Control in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Multi-Tenant Environments	CLD-06	Mechanisms exist to ensure multi-tenant owned or managed assets (physical and virtual) are designed and governed such that provider and customer (tenant) user access is appropriately segmented from other tenant users.	5	
9.5.1.1.P	N/A	The cloud service provider implements appropriate logical separation of virtualized applications, operating systems, storage, and networks to separate the resources used by cloud service customers in a multi-tenant environment.	Functional	Intersects With	Multi-Tenant Environments	CLD-06	Mechanisms exist to ensure multi-tenant owned or managed assets (physical and virtual) are designed and governed such that provider and customer (tenant) user access is appropriately segmented from other tenant users.	5	Controls pattern 1
9.5.1.2.P	N/A	The cloud service provider implements appropriate logical separation of virtualized applications, operating systems, storage, and networks in order to separate the resources used by cloud service customers from the internal management of the cloud service provider.	Functional	Intersects With	Multi-Tenant Environments	CLD-06	Mechanisms exist to ensure multi-tenant owned or managed assets (physical and virtual) are designed and governed such that provider and customer (tenant) user access is appropriately segmented from other tenant users.	5	Controls pattern 1
9.5.1.3.P	N/A	9.5.1.3.P corresponds to the 1st(last) sentence(beginning with "Where the cloud") of the 2nd paragraph of the Implementation guidance of CLD.9.5.1 in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Multi-Tenant Environments	CLD-06	Mechanisms exist to ensure multi-tenant owned or managed assets (physical and virtual) are designed and governed such that provider and customer (tenant) user access is appropriately segmented from other tenant users.	5	Controls pattern 1
9.5.1.4.P	N/A	9.5.1.4.P corresponds to the 1st(last) sentence(beginning with "The cloud service") of the 3rd(last) paragraph of the Implementation guidance of CLD.9.5.1 in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Multi-Tenant Environments	CLD-06	Mechanisms exist to ensure multi-tenant owned or managed assets (physical and virtual) are designed and governed such that provider and customer (tenant) user access is appropriately segmented from other tenant users.	5	Controls pattern 1
9.5.2.P	N/A	9.5.2.P corresponds to the part of CLD.9.5.2 Control in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Baseline Tailoring	CFG-02.9	Mechanisms exist to allow baseline controls to be specialized or customized by applying a defined set of tailoring actions that are specific to: (1) Mission / business functions; (2) Operational environment; (3) Specific threats or vulnerabilities; or (4) Other conditions or situations that could affect mission / business success.	5	
9.5.2.1.PB	N/A	9.5.2.1.PB corresponds to the 1st(last) sentence(beginning with "When configuring") of the 1st(last) paragraph of the Implementation guidance of CLD.9.5.2 in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Baseline Tailoring	CFG-02.9	Mechanisms exist to allow baseline controls to be specialized or customized by applying a defined set of tailoring actions that are specific to: (1) Mission / business functions; (2) Operational environment; (3) Specific threats or vulnerabilities; or (4) Other conditions or situations that could affect mission / business success.	5	Controls pattern 1
10	N/A	Cryptography	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	
10.1	N/A	Cryptographic controls Control Objective: To ensure proper and effective use of cryptography to protect the confidentiality, authenticity and/or integrity of information.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	
10.1.1	N/A	10.1.1 corresponds to the part of 10.1.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	
10.1.1.1	N/A	10.1.1.1 corresponds to the a) part of 10.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
10.1.1.2	N/A	10.1.1.2 corresponds to the b) part of 10.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
10.1.1.3	N/A	10.1.1.3 corresponds to the c) part of 10.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
10.1.1.4	N/A	10.1.1.4 corresponds to the d) part of 10.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
10.1.1.5	N/A	10.1.1.5 corresponds to the e) part of 10.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
10.1.1.6	N/A	10.1.1.6 corresponds to the f) part of 10.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
10.1.1.7	N/A	10.1.1.7 corresponds to the g) part of 10.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
10.1.1.8	N/A	10.1.1.8 corresponds to the 1st sentence(beginning with "When implementing") of the 1st paragraph of the Implementation guidance of 10.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
10.1.1.9.PB	N/A	The cloud service provider provides the cloud service customer with the capability to use cryptographic techniques to protect the information processed by the customer, or provides information about the environment in which the cryptographic techniques are used.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 3
10.1.1.10.P	N/A	10.1.1.10.P corresponds to the 2nd(last) sentence(beginning with "The cloud service") of the 1st(last) paragraph of the Implementation guidance of 10.1.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 3
10.1.2	N/A	10.1.2 corresponds to the part of 10.1.2 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	
10.1.2.1	N/A	10.1.2.1 corresponds to the 1st(last) sentence(beginning with "The policy should") of the 1st paragraph of the Implementation guidance of 10.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.2	N/A	10.1.2.2 corresponds to the 1st sentence(beginning with "Cryptographic algorithms,") of the 2nd paragraph of the Implementation guidance of 10.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.3	N/A	10.1.2.3 corresponds to the 1st sentence(beginning with "All cryptographic") of the 3rd paragraph of the Implementation guidance of 10.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.4	N/A	10.1.2.4 corresponds to the 2nd(last) sentence(beginning with "Equipment used") of the 3rd paragraph of the Implementation guidance of 10.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.5	N/A	10.1.2.5 corresponds to the a) part of 10.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.6	N/A	10.1.2.6 corresponds to the b) part of 10.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.7	N/A	10.1.2.7 corresponds to the c) part of 10.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.8	N/A	10.1.2.8 corresponds to the d) part of 10.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.9	N/A	10.1.2.9 corresponds to the e) part of 10.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.10	N/A	10.1.2.10 corresponds to the f) part of 10.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bbfd69e91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.1.2.11	N/A	10.1.2.11 corresponds to the g) part of 10.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.12	N/A	10.1.2.12 corresponds to the h) part of 10.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.13	N/A	10.1.2.13 corresponds to the i) part of 10.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.14	N/A	10.1.2.14 corresponds to the j) part of 10.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.15	N/A	10.1.2.15 corresponds to the k) part of 10.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.16	N/A	10.1.2.16 corresponds to the 1st(last) sentence(beginning with "In order to reduce") of the 5th paragraph of the Implementation guidance of 10.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.17	N/A	10.1.2.17 corresponds to the 1st sentence(beginning with "In addition to") of the 6th paragraph of the Implementation guidance of 10.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.18	N/A	10.1.2.18 corresponds to the 2nd(last) sentence(beginning with "This authentication") of the 6th paragraph of the Implementation guidance of 10.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.19	N/A	10.1.2.19 corresponds to the 1st(last) sentence(beginning with "The contents of") of the 7th(last) paragraph of the Implementation guidance of 10.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 1
10.1.2.20.PB	N/A	The cloud service provider provides a cloud service customer with a function that allows said customer to manage cryptographic keys used to encrypt information managed by said customer, or provides information on how said customer manages cryptographic keys.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Controls pattern 3
11	N/A	Physical and environmental security	Functional	Subset Of	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	10	
11.1	N/A	Secure areas Control Objective: To prevent unauthorized physical access, damage and interference to the organization's information and information processing facilities.	Functional	Subset Of	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	10	
11.1.1	N/A	11.1.1 corresponds to the part of 11.1.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	
11.1.1.1	N/A	11.1.1.1 corresponds to the a) part of 11.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.1.2	N/A	11.1.1.2 corresponds to the b) part of 11.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.1.3	N/A	The organization controls physical access to the premises or building in order to protect the area where the information and the information processing facility are located. Specifically, the following three points are to be performed. 1. The organization provides a manned reception or other means. 2. The organization restricts access to the site and building to authorized personnel only. 3. The organization creates and maintains a list of authorized personnel.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	
11.1.1.4	N/A	11.1.1.4 corresponds to the d) part of 11.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.1.5	N/A	11.1.1.5 corresponds to the e) part of 11.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.1.6	N/A	11.1.1.6 corresponds to the f) part of 11.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.1.7	N/A	11.1.1.7 corresponds to the g) part of 11.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.2	N/A	11.1.2 corresponds to the part of 11.1.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	
11.1.2.1	N/A	To ensure that secured areas are accessible only to authorized personnel, the organization records the date and time of entry and exit of visitors and reviewed on a regular basis and when an event occurs or there are indications of an event.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.2.2	N/A	The organization supervises all visitors, unless access has been pre-approved, to ensure that secured areas are accessible only to authorized persons.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.2.3	N/A	To ensure that secured areas allow access only to authorized persons, the organization grants access to visitors only for identified and authorized purposes and give instructions on the security requirements and emergency procedures for the area.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.2.4	N/A	To ensure that the area to be secured allows access only to authorized persons, the organization authenticates the visitor's identity through appropriate means.	Functional	Intersects With	Visitor Control	PES-06	Physical access control mechanisms exist to identify, authorize and monitor visitors before allowing access to the facility (other than areas designated as publicly accessible).	5	Controls pattern 1
11.1.2.5	N/A	The organization implements appropriate access controls (for example, implement two-factor authentication mechanisms, such as access cards and secret personal identification numbers) to ensure that secured areas are accessible only to authorized persons.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.2.6	N/A	The organization restricts access to areas where confidential information is processed or stored to authorized personnel only, to ensure that secured areas are accessible only to authorized personnel.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.1.2.7	N/A	11.1.2.7 corresponds to the c) part of 11.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Access Log	PES-03.3	Physical access control mechanisms generate a log entry for each access attempt through controlled ingress and egress points.	5	Controls pattern 1
11.1.2.8	N/A	The organization requires all employees, contract parties, and external parties to wear some form of visible identification to ensure that secured areas are accessible only to authorized persons.	Functional	Intersects With	Distinguish Visitors from On-Site Personnel	PES-06.1	Physical access control mechanisms exist to easily distinguish between onsite personnel and visitors, especially in areas where sensitive and/or regulated data is accessible.	5	Controls pattern 1
11.1.2.9	N/A	To ensure that secured areas are accessible only to authorized persons, security personnel are to be notified immediately if unaccompanied visitors or persons not wearing visible identification are seen.	Functional	Intersects With	Restrict Unescorted Access	PES-06.3	Physical access control mechanisms exist to restrict unescorted access to facilities to personnel with required security clearances, formal access authorizations and validate the need for access.	5	Controls pattern 1
11.1.2.10	N/A	11.1.2.10 corresponds to the e) part of 11.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.2.11	N/A	The organization authorizes and monitors all access to secured areas or confidential information processing facilities to ensure that secured areas are accessible only to authorized persons.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?tid=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b0fd69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
11.1.2.12	N/A	11.1.2.12 corresponds to the f) part of 11.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5	Controls pattern 1
11.1.2.13	N/A	The organization coordinates with the incident response team, depending on the results of the review of date and time records of visitors entering and exiting, to ensure that secured areas are accessible only to authorized persons.	Functional	Intersects With	Monitoring Physical Access	PES-05	Physical access control mechanisms exist to monitor for, detect and respond to physical security incidents.	5	Controls pattern 1
11.1.3	N/A	11.1.3 corresponds to the part of 11.1.3 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.1.3.1	N/A	11.1.3.1 corresponds to the a) part of 11.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.1.3.2	N/A	11.1.3.2 corresponds to the b) part of 11.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.1.3.3	N/A	11.1.3.3 corresponds to the c) part of 11.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.1.3.4	N/A	11.1.3.4 corresponds to the d) part of 11.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.1.4	N/A	11.1.4 corresponds to the part of 11.1.4 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	10	
11.1.4.1	N/A	11.1.4.1 corresponds to the 1st(last) sentence(beginning with "Specialist advice") of the 1st(last) paragraph of the Implementation guidance of 11.1.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	10	Controls pattern 1
11.1.5	N/A	11.1.5 corresponds to the part of 11.1.5 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	
11.1.5.1	N/A	11.1.5.1 corresponds to the a) part of 11.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Controls pattern 1
11.1.5.2	N/A	11.1.5.2 corresponds to the b) part of 11.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Controls pattern 1
11.1.5.3	N/A	11.1.5.3 corresponds to the c) part of 11.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Controls pattern 1
11.1.5.4	N/A	11.1.5.4 corresponds to the d) part of 11.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Controls pattern 1
11.1.5.5	N/A	Arrangements for working in secured areas include controls for employees and external customers working in the area.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Controls pattern 1
11.1.5.6	N/A	The organization applies arrangements for working in secure areas to all activities that take place in secured areas.	Functional	Intersects With	Working in Secure Areas	PES-04.1	Physical security mechanisms exist to allow only authorized personnel access to secure areas.	5	Controls pattern 1
11.1.6	N/A	11.1.6 corresponds to the part of 11.1.6 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Delivery & Removal	PES-10	Physical security mechanisms exist to isolate information processing facilities from points such as delivery and loading areas and other points to avoid unauthorized access.	5	
11.1.6.1	N/A	11.1.6.1 corresponds to the a) part of 11.1.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Delivery & Removal	PES-10	Physical security mechanisms exist to isolate information processing facilities from points such as delivery and loading areas and other points to avoid unauthorized access.	5	Controls pattern 1
11.1.6.2	N/A	11.1.6.2 corresponds to the b) part of 11.1.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Delivery & Removal	PES-10	Physical security mechanisms exist to isolate information processing facilities from points such as delivery and loading areas and other points to avoid unauthorized access.	5	Controls pattern 1
11.1.6.3	N/A	11.1.6.3 corresponds to the c) part of 11.1.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Delivery & Removal	PES-10	Physical security mechanisms exist to isolate information processing facilities from points such as delivery and loading areas and other points to avoid unauthorized access.	5	Controls pattern 1
11.1.6.4	N/A	11.1.6.4 corresponds to the d) part of 11.1.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Delivery & Removal	PES-10	Physical security mechanisms exist to isolate information processing facilities from points such as delivery and loading areas and other points to avoid unauthorized access.	5	Controls pattern 1
11.1.6.5	N/A	11.1.6.5 corresponds to the e) part of 11.1.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Delivery & Removal	PES-10	Physical security mechanisms exist to isolate information processing facilities from points such as delivery and loading areas and other points to avoid unauthorized access.	5	Controls pattern 1
11.1.6.6	N/A	11.1.6.6 corresponds to the f) part of 11.1.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Delivery & Removal	PES-10	Physical security mechanisms exist to isolate information processing facilities from points such as delivery and loading areas and other points to avoid unauthorized access.	5	Controls pattern 1
11.1.6.7	N/A	11.1.6.7 corresponds to the g) part of 11.1.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Delivery & Removal	PES-10	Physical security mechanisms exist to isolate information processing facilities from points such as delivery and loading areas and other points to avoid unauthorized access.	5	Controls pattern 1
11.2	N/A	Equipment Control Objective: To prevent loss, damage, theft or compromise of assets and interruption to the organization's operations.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	
11.2.1	N/A	11.2.1 corresponds to the part of 11.2.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	
11.2.1.1	N/A	11.2.1.1 corresponds to the a) part of 11.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	Controls pattern 1
11.2.1.2	N/A	11.2.1.2 corresponds to the b) part of 11.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	Controls pattern 1
11.2.1.3	N/A	In order to protect equipment, the organization maintains the security of storage facilities to avoid unauthorized access (including remote activation).	Functional	Subset Of	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	10	Controls pattern 1
11.2.1.4	N/A	To protect equipment, the organization separates equipment that requires special protection from the rest of the equipment or place barriers between the equipment.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	Controls pattern 1
11.2.1.5	N/A	11.2.1.5 corresponds to the e) part of 11.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	Controls pattern 1
11.2.1.6	N/A	11.2.1.6 corresponds to the f) part of 11.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	Controls pattern 1
11.2.1.7	N/A	11.2.1.7 corresponds to the g) part of 11.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	Controls pattern 1
11.2.1.8	N/A	11.2.1.8 corresponds to the h) part of 11.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	Controls pattern 1
11.2.1.9	N/A	11.2.1.9 corresponds to the i) part of 11.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	Controls pattern 1
11.2.1.10	N/A	11.2.1.10 corresponds to the j) part of 11.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	Controls pattern 1
11.2.2	N/A	11.2.2 corresponds to the part of 11.2.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Supporting Utilities	PES-07	Facility security mechanisms exist to protect power equipment and power cabling for the system from damage and destruction.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
11.2.2.1	N/A	11.2.2.1 corresponds to the a) part of 11.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Supporting Utilities	PES-07	Facility security mechanisms exist to protect power equipment and power cabling for the system from damage and destruction.	5	Controls pattern 1
11.2.2.2	N/A	11.2.2.2 corresponds to the b) part of 11.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Supporting Utilities	PES-07	Facility security mechanisms exist to protect power equipment and power cabling for the system from damage and destruction.	5	Controls pattern 1
11.2.2.3	N/A	11.2.2.3 corresponds to the c) part of 11.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Supporting Utilities	PES-07	Facility security mechanisms exist to protect power equipment and power cabling for the system from damage and destruction.	5	Controls pattern 1
11.2.2.4	N/A	11.2.2.4 corresponds to the d) part of 11.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Supporting Utilities	PES-07	Facility security mechanisms exist to protect power equipment and power cabling for the system from damage and destruction.	5	Controls pattern 1
11.2.2.5	N/A	11.2.2.5 corresponds to the e) part of 11.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Supporting Utilities	PES-07	Facility security mechanisms exist to protect power equipment and power cabling for the system from damage and destruction.	5	Controls pattern 1
11.2.2.6	N/A	11.2.2.6 corresponds to the 1st sentence(beginning with "Emergency lighting") of the 2nd(last) paragraph of the Implementation guidance of 11.2.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Emergency Lighting	PES-07.4	Facility security mechanisms exist to utilize and maintain automatic emergency lighting that activates in the event of a power outage or disruption and that covers emergency exits and evacuation routes within the facility.	5	Controls pattern 1
11.2.2.7	N/A	11.2.2.7 corresponds to the 2nd sentence(beginning with "Emergency switches") of the 2nd(last) paragraph of the Implementation guidance of 11.2.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Emergency Shutoff	PES-07.2	Facility security mechanisms exist to shut off power in emergency situations by: (1) Placing emergency shutoff switches or devices in close proximity to systems or system components to facilitate safe and easy access for personnel; and (2) Protecting emergency power shutoff capability from unauthorized activation.	5	Controls pattern 1
11.2.3	N/A	11.2.3 corresponds to the part of 11.2.3 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Transmission Medium Security	PES-12.1	Physical security mechanisms exist to protect power and telecommunications cabling carrying data or supporting information services from interception, interference or damage.	5	
11.2.3.1	N/A	11.2.3.1 corresponds to the a) part of 11.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Transmission Medium Security	PES-12.1	Physical security mechanisms exist to protect power and telecommunications cabling carrying data or supporting information services from interception, interference or damage.	5	Controls pattern 1
11.2.3.2	N/A	11.2.3.2 corresponds to the b) part of 11.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Transmission Medium Security	PES-12.1	Physical security mechanisms exist to protect power and telecommunications cabling carrying data or supporting information services from interception, interference or damage.	5	Controls pattern 1
11.2.3.3	N/A	11.2.3.3 corresponds to the c) part of 11.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Transmission Medium Security	PES-12.1	Physical security mechanisms exist to protect power and telecommunications cabling carrying data or supporting information services from interception, interference or damage.	5	Controls pattern 1
11.2.4	N/A	11.2.4 corresponds to the part of 11.2.4 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Maintenance Operations	MNT-01	Mechanisms exist to develop, disseminate, review & update procedures to facilitate the implementation of maintenance controls across the enterprise.	10	Controls pattern 1
11.2.4.1	N/A	11.2.4.1 corresponds to the a) part of 11.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Maintenance Operations	MNT-01	Mechanisms exist to develop, disseminate, review & update procedures to facilitate the implementation of maintenance controls across the enterprise.	10	Controls pattern 1
11.2.4.2	N/A	To ensure continuous maintenance of availability and integrity, the organization maintains a list of authorized maintenance personnel, and only these personnel perform repairs and care of equipment.	Functional	Intersects With	Authorized Maintenance Personnel	MNT-06	Mechanisms exist to maintain a current list of authorized maintenance organizations or personnel.	5	Controls pattern 1
11.2.4.3	N/A	To ensure continuous maintenance of availability and integrity, the organization maintains and reviews records of all apparent and actual failures and all preventive and corrective maintenance to ensure that availability and integrity are maintained on an ongoing basis.	Functional	Subset Of	Maintenance Operations	MNT-01	Mechanisms exist to develop, disseminate, review & update procedures to facilitate the implementation of maintenance controls across the enterprise.	10	Controls pattern 1
11.2.4.4	N/A	To ensure continuous maintenance of availability and integrity, the organization implements appropriate controls when planning maintenance of equipment, taking into account whether this maintenance is to be performed by personnel on the premises or outside the organization. The organization deletes confidential information from the equipment, or ensures that maintenance personnel are sufficiently trustworthy and have the necessary access rights.	Functional	Subset Of	Controlled Maintenance	MNT-02	Mechanisms exist to conduct controlled maintenance activities throughout the lifecycle of the Technology Asset, Application and/or Service (TAAS).	10	Controls pattern 1
11.2.4.5	N/A	11.2.4.5 corresponds to the e) part of 11.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Maintenance Operations	MNT-01	Mechanisms exist to develop, disseminate, review & update procedures to facilitate the implementation of maintenance controls across the enterprise.	10	Controls pattern 1
11.2.4.6	N/A	11.2.4.6 corresponds to the f) part of 11.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Maintenance Validation	MNT-10	Mechanisms exist to validate: (1) Maintenance activities were appropriately performed according to the work order; and (2) Applicable security, compliance and resilience controls are operational.	5	Controls pattern 1
11.2.4.7	N/A	To ensure continued availability and integrity, the organization requires authorization and monitor remote maintenance.	Functional	Intersects With	Auditing Remote Maintenance	MNT-05.1	Mechanisms exist to audit remote, non-local maintenance and diagnostic sessions, as well as review the maintenance action performed during remote maintenance sessions.	5	Controls pattern 1
11.2.4.7	N/A	To ensure continued availability and integrity, the organization requires authorization and monitor remote maintenance.	Functional	Intersects With	Remote Maintenance Pre-Approval	MNT-05.5	Mechanisms exist to require maintenance personnel to obtain pre-approval and scheduling for remote, non-local maintenance sessions.	5	Controls pattern 1
11.2.4.8	N/A	To ensure continued availability and integrity, the organization develops required specifications and authorization procedures for remote maintenance tools.	Functional	Intersects With	Remote Maintenance	MNT-05	Mechanisms exist to authorize, monitor and control remote, non-local maintenance and diagnostic activities.	5	Controls pattern 1
11.2.4.9	N/A	To ensure continued availability and integrity, the organization performs authentication when establishing remote maintenance sessions.	Functional	Subset Of	Remote Maintenance	MNT-05	Mechanisms exist to authorize, monitor and control remote, non-local maintenance and diagnostic activities.	10	Controls pattern 1
11.2.4.10	N/A	To ensure continued availability and integrity, the organization records remote maintenance and keep records.	Functional	Subset Of	Remote Maintenance	MNT-05	Mechanisms exist to authorize, monitor and control remote, non-local maintenance and diagnostic activities.	10	Controls pattern 1
11.2.4.11	N/A	To ensure continued availability and integrity, the organization disconnects sessions and network connections used for remote maintenance after completion of the maintenance.	Functional	Intersects With	Remote Maintenance Disconnect Verification	MNT-05.4	Mechanisms exist to provide remote disconnect verification to ensure remote, non-local maintenance and diagnostic sessions are properly terminated.	5	Controls pattern 1
11.2.5	N/A	11.2.5 corresponds to the part of 11.2.5 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Prevent Unauthorized Removal	MNT-04.3	Mechanisms exist to prevent or control the removal of equipment undergoing maintenance that contains organizational information.	5	
11.2.5.1	N/A	The organization identifies and authorizes employees and external customers who are authorized to take assets off the premises.	Functional	Intersects With	Prevent Unauthorized Removal	MNT-04.3	Mechanisms exist to prevent or control the removal of equipment undergoing maintenance that contains organizational information.	5	Controls pattern 1
11.2.5.2	N/A	11.2.5.2 corresponds to the b) part of 11.2.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Prevent Unauthorized Removal	MNT-04.3	Mechanisms exist to prevent or control the removal of equipment undergoing maintenance that contains organizational information.	5	Controls pattern 1
11.2.5.3	N/A	11.2.5.3 corresponds to the c) part of 11.2.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Prevent Unauthorized Removal	MNT-04.3	Mechanisms exist to prevent or control the removal of equipment undergoing maintenance that contains organizational information.	5	Controls pattern 1
11.2.5.4	N/A	11.2.5.4 corresponds to the d) part of 11.2.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Prevent Unauthorized Removal	MNT-04.3	Mechanisms exist to prevent or control the removal of equipment undergoing maintenance that contains organizational information.	5	Controls pattern 1
11.2.6	N/A	11.2.6 corresponds to the part of 11.2.6 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Off-Site Maintenance	MNT-09	Mechanisms exist to ensure off-site maintenance activities are conducted securely and the asset(s) undergoing maintenance actions are secured during physical transfer and storage while off-site.	5	
11.2.6.1	N/A	11.2.6.1 corresponds to the 1st sentence(beginning with "The use of any") of the 1st paragraph of the Implementation guidance of 11.2.6 in ISO/IEC 27002:2013.	Functional	Intersects With	Off-Site Maintenance	MNT-09	Mechanisms exist to ensure off-site maintenance activities are conducted securely and the asset(s) undergoing maintenance actions are secured during physical transfer and storage while off-site.	5	Controls pattern 1
11.2.6.2	N/A	11.2.6.2 corresponds to the a) part of 11.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Off-Site Maintenance	MNT-09	Mechanisms exist to ensure off-site maintenance activities are conducted securely and the asset(s) undergoing maintenance actions are secured during physical transfer and storage while off-site.	5	Controls pattern 1
11.2.6.3	N/A	11.2.6.3 corresponds to the b) part of 11.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Off-Site Maintenance	MNT-09	Mechanisms exist to ensure off-site maintenance activities are conducted securely and the asset(s) undergoing maintenance actions are secured during physical transfer and storage while off-site.	5	Controls pattern 1
11.2.6.4	N/A	11.2.6.4 corresponds to the c) part of 11.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Off-Site Maintenance	MNT-09	Mechanisms exist to ensure off-site maintenance activities are conducted securely and the asset(s) undergoing maintenance actions are secured during physical transfer and storage while off-site.	5	Controls pattern 1
11.2.6.5	N/A	11.2.6.5 corresponds to the d) part of 11.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Off-Site Maintenance	MNT-09	Mechanisms exist to ensure off-site maintenance activities are conducted securely and the asset(s) undergoing maintenance actions are secured during physical transfer and storage while off-site.	5	Controls pattern 1
11.2.6.6	N/A	11.2.6.6 corresponds to the 1st(last) sentence(beginning with "Risks, e.g. of") of the 3rd(last) paragraph of the Implementation guidance of 11.2.6 in ISO/IEC 27002:2013.	Functional	Intersects With	Off-Site Maintenance	MNT-09	Mechanisms exist to ensure off-site maintenance activities are conducted securely and the asset(s) undergoing maintenance actions are secured during physical transfer and storage while off-site.	5	Controls pattern 1
11.2.7	N/A	11.2.7 corresponds to the part of 11.2.7 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
11.2.7.1	N/A	11.2.7.1 corresponds to the 1st(last) sentence(beginning with "Equipment should") of the 1st paragraph of the Implementation guidance of 11.2.7 in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	5	Controls pattern 1
11.2.7.2	N/A	The organization ensures that storage media containing confidential or copyrighted information is physically destroyed, or the information is destroyed, erased, or overwritten.	Functional	Intersects With	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	5	Controls pattern 1
11.2.7.3	N/A	In the erasure or overwriting of storage media containing confidential or copyrighted information, the organization utilizes technology that makes the original information irremovable from the media, rather than using standard erase or initialization functions.	Functional	Intersects With	System Media Sanitization	DCH-09	Mechanisms exist to sanitize system media with the strength and integrity commensurate with the classification or sensitivity of the information prior to disposal, release out of organizational control or release for reuse.	5	Controls pattern 1
11.2.7.4.PB	N/A	11.2.7.4.PB corresponds to the 11.2. Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Intersects With	Equipment Siting & Protection	PES-12	Physical security mechanisms exist to locate system components within the facility to minimize potential damage from physical and environmental hazards and to minimize the opportunity for unauthorized access.	5	Controls pattern 1
11.2.8	N/A	11.2.8 corresponds to the part of 11.2.8 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Unattended End-User Equipment	AST-06	Mechanisms exist to implement enhanced protection measures for unattended technology assets to protect against tampering and unauthorized access.	5	Controls pattern 1
11.2.8.1	N/A	11.2.8.1 corresponds to the 1st sentence(beginning with "All users should") of the 1st(last) paragraph of the Implementation guidance of 11.2.8 in ISO/IEC 27002:2013.	Functional	Intersects With	Unattended End-User Equipment	AST-06	Mechanisms exist to implement enhanced protection measures for unattended technology assets to protect against tampering and unauthorized access.	5	Controls pattern 1
11.2.8.2	N/A	11.2.8.2 corresponds to the a) part of 11.2.8 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Unattended End-User Equipment	AST-06	Mechanisms exist to implement enhanced protection measures for unattended technology assets to protect against tampering and unauthorized access.	5	Controls pattern 1
11.2.8.3	N/A	11.2.8.3 corresponds to the b) part of 11.2.8 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Unattended End-User Equipment	AST-06	Mechanisms exist to implement enhanced protection measures for unattended technology assets to protect against tampering and unauthorized access.	5	Controls pattern 1
11.2.8.4	N/A	11.2.8.4 corresponds to the c) part of 11.2.8 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Unattended End-User Equipment	AST-06	Mechanisms exist to implement enhanced protection measures for unattended technology assets to protect against tampering and unauthorized access.	5	Controls pattern 1
11.2.9	N/A	11.2.9 corresponds to the part of 11.2.9 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.2.9.1	N/A	11.2.9.1 corresponds to the 1st sentence(beginning with "The clear desk") of the 1st(last) paragraph of the Implementation guidance of 11.2.9 in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.2.9.2	N/A	11.2.9.2 corresponds to the a) part of 11.2.9 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.2.9.3	N/A	The organization ensures that computers and terminals are kept in a logged-off state when away from the desk, or protected by a screen and keyboard lock feature controlled by a password, token or similar user authentication feature.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.2.9.4	N/A	The organization ensures that computers and terminals are protected by locks, passwords, or other control measures when not in use.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.2.9.5	N/A	11.2.9.5 corresponds to the c) part of 11.2.9 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
11.2.9.6	N/A	11.2.9.6 corresponds to the d) part of 11.2.9 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Physical Security of Offices, Rooms & Facilities	PES-04	Mechanisms exist to identify systems, equipment and respective operating environments that require limited physical access so that appropriate physical access controls are designed and implemented for offices, rooms and facilities.	5	Controls pattern 1
12	N/A	Operations security	Functional	Subset Of	Operations Security	OPS-01	Mechanisms exist to facilitate the implementation of operational security controls.	10	
12.1	N/A	Operational procedures and responsibilities Control Objective: To ensure correct and secure operations of information processing facilities.	Functional	Subset Of	Operations Security	OPS-01	Mechanisms exist to facilitate the implementation of operational security controls.	10	
12.1.1	N/A	12.1.1 corresponds to the part of 12.1.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	
12.1.1.1	N/A	The organization ensures that written procedures for operations related to information processing and communications equipment (for example, procedures for starting and stopping computers, installation, configuration, backup, equipment maintenance, handling of media, and management and security of computer rooms and email handling) are prepared, taking into account whether customers have privileges. The organization ensures that operating procedures related to information processing and communications equipment clearly state operating instructions, including pre-operational authorization, installation and configuration of the system (including baseline configuration), security functions, and known vulnerabilities for setting and use of management functions.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.2	N/A		Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.3	N/A	12.1.1.3 corresponds to the b) part of 12.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.4	N/A	12.1.1.4 corresponds to the c) part of 12.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.5	N/A	12.1.1.5 corresponds to the d) part of 12.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.6	N/A	12.1.1.6 corresponds to the e) part of 12.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.7	N/A	The organization ensures that operating procedures related to information processing and communications equipment specify operating instructions, including contact information for support and escalation, including contact information for external support in the event that necessary documentation is not available and in the event of unforeseen operational or technical problems.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.8	N/A	12.1.1.8 corresponds to the g) part of 12.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.9	N/A	12.1.1.9 corresponds to the h) part of 12.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.10	N/A	12.1.1.10 corresponds to the i) part of 12.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.11	N/A	12.1.1.11 corresponds to the j) part of 12.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.12	N/A	12.1.1.12 corresponds to the 1st sentence(beginning with "Operating procedures") of the 2nd(last) paragraph of the Implementation guidance of 12.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.1.13	N/A	12.1.1.13 corresponds to the 2nd(last) sentence(beginning with "Where technically") of the 2nd(last) paragraph of the Implementation guidance of 12.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 1
12.1.2	N/A	12.1.2 corresponds to the part of 12.1.2 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Change Management Program	CHO-01	Mechanisms exist to facilitate the implementation of a change management program.	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: Japan - Information System Security Management and Assessment Program (ISMAP)

Focal Document URL: https://www.ismap.go.jp/csm/?id-kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b0bf6d69e91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
12.1.2.1	N/A	The organization ensures that change management for organizations, business processes, information processing equipment, and systems includes developing, documenting, and implementing configuration management processes and management plans for information processing equipment and system components, and identifying and recording significant changes.	Functional	Subset Of	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	10	Controls pattern 1
12.1.2.2	N/A	12.1.2.2 corresponds to the b) part of 12.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
12.1.2.3	N/A	12.1.2.3 corresponds to the c) part of 12.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
12.1.2.4	N/A	12.1.2.4 corresponds to the d) part of 12.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
12.1.2.5	N/A	12.1.2.5 corresponds to the e) part of 12.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
12.1.2.6	N/A	12.1.2.6 corresponds to the f) part of 12.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
12.1.2.7	N/A	12.1.2.7 corresponds to the g) part of 12.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
12.1.2.8	N/A	12.1.2.8 corresponds to the h) part of 12.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
12.1.2.9	N/A	12.1.2.9 corresponds to the 1st sentence(beginning with "Formal management") of the 2nd(last) paragraph of the Implementation guidance of 12.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
12.1.2.10	N/A	12.1.2.10 corresponds to the 2nd(last) sentence(beginning with "When changes are") of the 2nd(last) paragraph of the Implementation guidance of 12.1.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	5	Controls pattern 1
12.1.2.11.PB	N/A	The cloud service provider provides cloud service customers with information about changes in cloud services that can adversely affect the information security of cloud service customers.	Functional	Subset Of	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	10	Controls pattern 3
12.1.2.13	N/A	The organization ensures that the change management of information processing equipment and systems includes the most restrictive configuration items that conform to operational requirements.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
12.1.2.14	N/A	The organization ensures that the change management of information processing equipment and systems includes the detection of unauthorized changes to software and firmware by integrity verification tools.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
12.1.3	N/A	12.1.3 corresponds to the part of 12.1.3 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	
12.1.3.1	N/A	12.1.3.1 corresponds to the 1st sentence(beginning with "Capacity requirements") of the 1st paragraph of the Implementation guidance of 12.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	Controls pattern 1
12.1.3.2	N/A	12.1.3.2 corresponds to the 2nd sentence(beginning with "System tuning and") of the 1st paragraph of the Implementation guidance of 12.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	Controls pattern 1
12.1.3.3	N/A	12.1.3.3 corresponds to the 3rd sentence(beginning with "Detective controls") of the 1st paragraph of the Implementation guidance of 12.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	Controls pattern 1
12.1.3.4	N/A	12.1.3.4 corresponds to the 4th(last) sentence(beginning with "Projections of") of the 1st paragraph of the Implementation guidance of 12.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	Controls pattern 1
12.1.3.5	N/A	12.1.3.5 corresponds to the 1st sentence(beginning with "therefore managers") of the 2nd paragraph of the Implementation guidance of 12.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	Controls pattern 1
12.1.3.6	N/A	12.1.3.6 corresponds to the 2nd(last) sentence(beginning with "They should identify") of the 2nd paragraph of the Implementation guidance of 12.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	Controls pattern 1
12.1.3.7	N/A	12.1.3.7 corresponds to the 1st(last) sentence(beginning with "Managers should") of the 3rd paragraph of the Implementation guidance of 12.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	Controls pattern 1
12.1.3.8	N/A	12.1.3.8 corresponds to the sentence(beginning with "Providing sufficient" & "Examples of managing") of the 4th & 5th(last) paragraph of the Implementation guidance of 12.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	Controls pattern 1
12.1.3.9.PB	N/A	12.1.3.9.PB corresponds to the 12.1. Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Subset Of	Operations Security	OPS-01	Mechanisms exist to facilitate the implementation of operational security controls.	10	Controls pattern 1
12.1.4	N/A	12.1.4 corresponds to the part of 12.1.4 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	
12.1.4.1	N/A	12.1.4.1 corresponds to the 1st(last) sentence(beginning with "The level of separation") of the 1st paragraph of the Implementation guidance of 12.1.4 in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
12.1.4.2	N/A	12.1.4.2 corresponds to the a) part of 12.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
12.1.4.3	N/A	12.1.4.3 corresponds to the b) part of 12.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
12.1.4.4	N/A	12.1.4.4 corresponds to the c) part of 12.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
12.1.4.5	N/A	12.1.4.5 corresponds to the d) part of 12.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
12.1.4.6	N/A	12.1.4.6 corresponds to the e) part of 12.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
12.1.4.7	N/A	Users use different user profiles for operational and test systems.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
12.1.4.8	N/A	The organization marks menus with appropriate identification messages to reduce the risk of incorrect operation.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
12.1.4.9	N/A	12.1.4.9 corresponds to the g) part of 12.1.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
12.1.5.P	N/A	12.1.5.P corresponds to the part of CLD.12.1.5 Control in ISO/IEC 27017:2015 Annex A.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	
12.1.5.1.PB	N/A	12.1.5.1.PB corresponds to the 1st(last) sentence(beginning with "The cloud service") of the 1st(last) paragraph of the Implementation guidance of CLD.12.1.5 in ISO/IEC 27017:2015 Annex A.	Functional	Subset Of	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	10	Controls pattern 3

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.gp.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b6fd69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
12.2	N/A	Protection from malware Control Objective: To ensure that information and information processing facilities are protected against malware.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	
12.2.1	N/A	12.2.1 corresponds to the part of 12.2.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	Controls pattern 1
12.2.1.1	N/A	Protection against malware should be based on malware detection and repair software, information security awareness, appropriate system access and change management controls, and controls for addressing such as blocking unauthorized communications with outside based on monitoring and analysis.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	Controls pattern 1
12.2.1.2	N/A	The organization establishes and periodically reviews a formal policy prohibiting the use of unauthorized software.	Functional	Subset Of	Endpoint Device Management (EDM)	END-01	Mechanisms exist to facilitate the implementation of Endpoint Device Management (EDM) controls.	10	Controls pattern 1
12.2.1.3	N/A	12.2.1.3 corresponds to the b) part of 12.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	Controls pattern 1
12.2.1.4	N/A	12.2.1.4 corresponds to the c) part of 12.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	Controls pattern 1
12.2.1.5	N/A	12.2.1.5 corresponds to the d) part of 12.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	Controls pattern 1
12.2.1.6	N/A	12.2.1.6 corresponds to the e) part of 12.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	Controls pattern 1
12.2.1.7	N/A	12.2.1.7 corresponds to the f) part of 12.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	Controls pattern 1
12.2.1.8	N/A	12.2.1.8 corresponds to the g) part of 12.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	Controls pattern 1
12.2.1.9	N/A	12.2.1.9 corresponds to the h) part of 12.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	Controls pattern 1
12.2.1.10	N/A	The organization develops an appropriate business continuity plan for recovering from malware attacks.	Functional	Intersects With	Business Continuity & Disaster Recovery (BC/DR) Plans	BCD-01.7	Mechanisms exist for process owners to establish and maintain formal Business Continuity & Disaster Recovery (BC/DR) plans to ensure information is detailed enough, accurate and representative of current operations in order to sustain and/or restore operations under adverse conditions.	5	Controls pattern 1
12.2.1.11	N/A	The organization ensures that adequate business continuity plans for recovery from malware attacks include procedures for backing up and recovering all necessary data and software.	Functional	Intersects With	Business Continuity & Disaster Recovery (BC/DR) Plans	BCD-01.7	Mechanisms exist for process owners to establish and maintain formal Business Continuity & Disaster Recovery (BC/DR) plans to ensure information is detailed enough, accurate and representative of current operations in order to sustain and/or restore operations under adverse conditions.	5	Controls pattern 1
12.2.1.12	N/A	12.2.1.12 corresponds to the j) part of 12.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	Controls pattern 1
12.2.1.13	N/A	12.2.1.13 corresponds to the k) part of 12.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	Controls pattern 1
12.2.1.14	N/A	12.2.1.14 corresponds to the l) part of 12.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Detonation Chambers (Sandboxes)	IRO-15	Mechanisms exist to utilize a detonation chamber capability to detect and/or block potentially-malicious files and email attachments.	5	Controls pattern 1
12.2.1.15	N/A	Implement means for improving the precision of detecting malware and reducing the risk of malware infection (for example, a machine-learning or sandbox-type anti-malware program).	Functional	Intersects With	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize antim malware technologies to detect and eradicate malicious code.	5	Controls pattern 1
12.3	N/A	Backup Control Objective: To protect against loss of data.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	
12.3.1	N/A	12.3.1 corresponds to the part of 12.3.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	
12.3.1.1	N/A	12.3.1.1 corresponds to the 1st(last) sentence(beginning with "A backup policy") of the 1st paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 1
12.3.1.2	N/A	12.3.1.2 corresponds to the 1st(last) sentence(beginning with "The backup policy") of the 2nd paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 1
12.3.1.3	N/A	12.3.1.3 corresponds to the 1st(last) sentence(beginning with "Adequate backup") of the 3rd paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 1
12.3.1.4	N/A	12.3.1.4 corresponds to the a) part of 12.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 1
12.3.1.5	N/A	12.3.1.5 corresponds to the b) part of 12.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 1
12.3.1.6	N/A	12.3.1.6 corresponds to the c) part of 12.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Separate Storage for Critical Information	BCD-11.2	Mechanisms exist to store backup copies of critical software and other security-related information in a separate facility or in a fire-rated container that is not collocated with the system being backed up.	5	Controls pattern 1
12.3.1.7	N/A	12.3.1.7 corresponds to the d) part of 12.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Separate Storage for Critical Information	BCD-11.2	Mechanisms exist to store backup copies of critical software and other security-related information in a separate facility or in a fire-rated container that is not collocated with the system being backed up.	5	Controls pattern 1
12.3.1.8	N/A	The organization ensures that the media used for backups is tested as specified to ensure that it can be relied upon for emergency use if the need arise.	Functional	Intersects With	Test Restoration Using Sampling	BCD-11.5	Mechanisms exist to utilize sampling of available backups to test recovery capabilities as part of business continuity plan testing.	5	Controls pattern 1
12.3.1.9	N/A	The organization ensures that the testing of the media used for backup is conducted in conjunction with testing of the data recovery procedures, and is checked against the required data recovery time.	Functional	Intersects With	Test Restoration Using Sampling	BCD-11.5	Mechanisms exist to utilize sampling of available backups to test recovery capabilities as part of business continuity plan testing.	5	Controls pattern 1
12.3.1.10	N/A	12.3.1.10 corresponds to the e) 2nd(last) sentence(beginning with "Testing the ability") of the 4th paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Test Restoration Using Sampling	BCD-11.5	Mechanisms exist to utilize sampling of available backups to test recovery capabilities as part of business continuity plan testing.	5	Controls pattern 1
12.3.1.11	N/A	12.3.1.11 corresponds to the f) part of 12.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 1
12.3.1.12	N/A	12.3.1.12 corresponds to the 1st(last) sentence(beginning with "Operational procedures") of the 5th paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 1
12.3.1.13	N/A	12.3.1.13 corresponds to the 1st sentence(beginning with "Backup arrangements") of the 6th paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 1
12.3.1.14	N/A	12.3.1.14 corresponds to the 2nd(last) sentence(beginning with "In the case of") of the 6th paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm/?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf6d9f91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
12.3.1.15	N/A	12.3.1.15 corresponds to the 1st(last) sentence(beginning with "The retention period") of the 7th paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
12.3.1.16.P	N/A	12.3.1.16.P corresponds to the 1st sentence(beginning with "The cloud service") of the 1st paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 2
12.3.1.17.P	N/A	12.3.1.17.P corresponds to the 1st of the 7 bullet points bullet points(beginning with "-- scope and schedule") in the 1st paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 2
12.3.1.18.P	N/A	12.3.1.18.P corresponds to the 2nd of the 7 bullet points bullet points(beginning with "-- backup methods") in the 1st paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 2
12.3.1.19.P	N/A	12.3.1.19.P corresponds to the 3rd of the 7 bullet points bullet points(beginning with "-- retention periods") in the 1st paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 2
12.3.1.20.P	N/A	12.3.1.20.P corresponds to the 4th of the 7 bullet points bullet points(beginning with "-- procedures for") in the 1st paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Test Restoration Using Sampling	BCD-11.5	Mechanisms exist to utilize sampling of available backups to test recovery capabilities as part of business continuity plan testing.	5	Controls pattern 2
12.3.1.21.P	N/A	12.3.1.21.P corresponds to the 5th of the 7 bullet points bullet points(beginning with "-- procedures and") in the 1st paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 2
12.3.1.22.P	N/A	12.3.1.22.P corresponds to the 6th of the 7 bullet points bullet points(beginning with "-- procedures to") in the 1st paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Test Restoration Using Sampling	BCD-11.5	Mechanisms exist to utilize sampling of available backups to test recovery capabilities as part of business continuity plan testing.	5	Controls pattern 2
12.3.1.23.P	N/A	12.3.1.23.P corresponds to the 7th of the 7 bullet points bullet points(beginning with "-- storage location") in the 1st paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Separate Storage for Critical Information	BCD-11.2	Mechanisms exist to store backup copies of critical software and other security-related information in a separate facility or in a fire-rated container that is not collocated with the system being backed up.	5	Controls pattern 2
12.3.1.24.P	N/A	12.3.1.24.P corresponds to the 2nd(last) sentence(beginning with "The cloud service") of the 1st(last) paragraph of the Implementation guidance of 12.3.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Controls pattern 2
12.4	N/A	Logging and monitoring Control Objective: To record events and generate evidence.	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10	
12.4.1	N/A	12.4.1 corresponds to the part of 12.4.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10	
12.4.1.1	N/A	12.4.1.1 corresponds to the a) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.2	N/A	12.4.1.2 corresponds to the b) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.3	N/A	12.4.1.3 corresponds to the c) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.4	N/A	12.4.1.4 corresponds to the d) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.5	N/A	12.4.1.5 corresponds to the e) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.6	N/A	12.4.1.6 corresponds to the f) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.7	N/A	12.4.1.7 corresponds to the g) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.8	N/A	12.4.1.8 corresponds to the h) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.9	N/A	12.4.1.9 corresponds to the i) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm/?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b6d69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
12.4.1.10	N/A	12.4.1.10 corresponds to the j) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.11	N/A	12.4.1.11 corresponds to the k) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.12	N/A	12.4.1.12 corresponds to the l) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.13	N/A	12.4.1.13 corresponds to the m) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.14	N/A	12.4.1.14 corresponds to the n) part of 12.4.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.15.PB	N/A	12.4.1.15.PB corresponds to the 12.4.1 Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10	Controls pattern 2
12.4.1.17	N/A	The organization ensures that event logs include records of important transactions obtained by monitoring devices installed as necessary.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.1.18	N/A	The organization ensures that event logs that record user activities, exceptions, errors, and information security events are obtained and retained, and periodically inspected or analyzed for the presence of unauthorized intrusion or manipulation by malicious third parties, etc.	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Controls pattern 1
12.4.2	N/A	12.4.2 corresponds to the part of 12.4.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5	
12.4.2.1	N/A	12.4.2.1 corresponds to the a) part of 12.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5	Controls pattern 1
12.4.2.2	N/A	12.4.2.2 corresponds to the b) part of 12.4.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5	Controls pattern 1
12.4.2.3	N/A	The organization ensures that procedures such as stopping the generation of event records are established to protect the records from problems such as excessive recording capacity of log file media, which can cause malfunction of event records or overwriting of past event records.	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5	Controls pattern 1
12.4.3	N/A	12.4.3 corresponds to the part of 12.4.3 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Privileged Functions Logging	MON-03.3	Mechanisms exist to log and review the actions of users and/or services with elevated privileges.	5	Controls pattern 1
12.4.3.1	N/A	To maintain accountability tracking for privileged customers (system administrators and operators), the organization records their work.	Functional	Intersects With	Privileged Functions Logging	MON-03.3	Mechanisms exist to log and review the actions of users and/or services with elevated privileges.	5	Controls pattern 1
12.4.3.2	N/A	The organization ensures that the work logs of customers are protected to maintain traceability of responsibilities for privileged customers (system administrators and operators).	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5	Controls pattern 1
12.4.3.3	N/A	The organization ensures that these work logs of customers are regularly reviewed to maintain traceability of responsibilities for privileged customers (system administrators and operators).	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5	Controls pattern 1
12.4.4	N/A	12.4.4 corresponds to the part of 12.4.4 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Clock Synchronization	SEA-20	Mechanisms exist to utilize time-synchronization technology to synchronize all critical system clocks.	5	
12.4.4.1	N/A	12.4.4.1 corresponds to the 1st sentence(beginning with "External and internal") of the 1st paragraph of the Implementation guidance of 12.4.4 in ISO/IEC 27002:2013.	Functional	Intersects With	Clock Synchronization	SEA-20	Mechanisms exist to utilize time-synchronization technology to synchronize all critical system clocks.	5	Controls pattern 1
12.4.4.2	N/A	The organization ensures that a reference time source for use within the organization has been established.	Functional	Intersects With	Clock Synchronization	SEA-20	Mechanisms exist to utilize time-synchronization technology to synchronize all critical system clocks.	5	Controls pattern 1
12.4.4.3	N/A	The organization ensures that the organization's efforts to obtain a reference time source from an external source and methods to ensure that internal clocks are synchronized are documented and implemented.	Functional	Intersects With	Clock Synchronization	SEA-20	Mechanisms exist to utilize time-synchronization technology to synchronize all critical system clocks.	5	Controls pattern 1
12.4.4.4.PB	N/A	12.4.4.4.PB corresponds to the 12.4. Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Intersects With	Clock Synchronization	SEA-20	Mechanisms exist to utilize time-synchronization technology to synchronize all critical system clocks.	5	Controls pattern 3
12.4.5.P	N/A	12.4.5.P corresponds to the part of CLD.12.4.5 Control in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5	
12.4.5.1.P	N/A	12.4.5.1.P corresponds to the 1st sentence(beginning with "The cloud service") of the 1st paragraph of the Implementation guidance of 12.4.5 in ISO/IEC 27017:2015.	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5	Controls pattern 2
12.4.5.2.P	N/A	12.4.5.2.P corresponds to the 1st sentence(beginning with "Appropriate access") of the 2nd paragraph of the Implementation guidance of 12.4.5 in ISO/IEC 27017:2015.	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5	Controls pattern 2
12.4.5.3.P	N/A	12.4.5.3.P corresponds to the 2nd(last) sentence(beginning with "The capabilities") of the 2nd paragraph of the Implementation guidance of 12.4.5 in ISO/IEC 27017:2015.	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5	Controls pattern 2
12.4.5.4.P	N/A	12.4.5.4.P corresponds to the 1st(last) sentence(beginning with "The cloud service") of the 3rd paragraph of the Implementation guidance of 12.4.5 in ISO/IEC 27017:2015.	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5	Controls pattern 3
12.4.5.5.P	N/A	12.4.5.5.P corresponds to the 1st(last) sentence(beginning with "Monitoring should") of the 4th(last) paragraph of the Implementation guidance of 12.4.5 in ISO/IEC 27017:2015.	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5	Controls pattern 2
12.5	N/A	Control of operational software Control Objective: To ensure the integrity of operational systems.	Functional	Intersects With	Restrict Roles Permitted To Install Software	CFG-05.2	Mechanisms exist to configure systems to prevent the installation of software, unless the action is performed by a privileged user or service.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bbfd69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
12.5.1	N/A	12.5.1 corresponds to the part of 12.5.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Restrict Roles Permitted To Install Software	CFG-05.2	Mechanisms exist to configure systems to prevent the installation of software, unless the action is performed by a privileged user or service.	5	
12.5.1.1	N/A	12.5.1.1 corresponds to the a) part of 12.5.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Restrict Roles Permitted To Install Software	CFG-05.2	Mechanisms exist to configure systems to prevent the installation of software, unless the action is performed by a privileged user or service.	5	Controls pattern 1
12.5.1.2	N/A	12.5.1.2 corresponds to the b) part of 12.5.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Restrict Roles Permitted To Install Software	CFG-05.2	Mechanisms exist to configure systems to prevent the installation of software, unless the action is performed by a privileged user or service.	5	Controls pattern 1
12.5.1.3	N/A	12.5.1.3 corresponds to the c) part of 12.5.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Restrict Roles Permitted To Install Software	CFG-05.2	Mechanisms exist to configure systems to prevent the installation of software, unless the action is performed by a privileged user or service.	5	Controls pattern 1
12.5.1.4	N/A	The organization ensures that application and operating system software testing includes usability, security, impact on other systems, and user friendliness testing.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.5	N/A	The organization ensures that application and operating system software testing is performed on a separate system from the operational system.	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	5	Controls pattern 1
12.5.1.6	N/A	The organization ensures that application and operating system software testing has mechanisms in place to ensure that the corresponding program source libraries have been updated.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.7	N/A	12.5.1.7 corresponds to the d) part of 12.5.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.8	N/A	12.5.1.8 corresponds to the e) part of 12.5.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.9	N/A	12.5.1.9 corresponds to the f) part of 12.5.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	5	Controls pattern 1
12.5.1.10	N/A	12.5.1.10 corresponds to the g) part of 12.5.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.11	N/A	12.5.1.11 corresponds to the h) part of 12.5.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.12	N/A	12.5.1.12 corresponds to the 1st sentence(beginning with "Vendor supplied") of the 2nd paragraph of the Implementation guidance of 12.5.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.13	N/A	12.5.1.13 corresponds to the 2nd(last) sentence(beginning with "The organization") of the 2nd paragraph of the Implementation guidance of 12.5.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.14	N/A	12.5.1.14 corresponds to the 1st sentence(beginning with "Any decision to") of the 3rd paragraph of the Implementation guidance of 12.5.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.15	N/A	12.5.1.15 corresponds to the 2nd(last) sentence(beginning with "Software patches") of the 3rd paragraph of the Implementation guidance of 12.5.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.16	N/A	12.5.1.16 corresponds to the 1st sentence(beginning with "Physical or logical") of the 4th paragraph of the Implementation guidance of 12.5.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.17	N/A	12.5.1.17 corresponds to the 2nd(last) sentence(beginning with "The supplier's") of the 4th paragraph of the Implementation guidance of 12.5.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.5.1.18	N/A	12.5.1.18 corresponds to the 1st(last) sentence(beginning with "Computer software") of the 5th paragraph of the Implementation guidance of 12.5.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Controls pattern 1
12.6	N/A	Technical vulnerability management Control Objective: To prevent exploitation of technical vulnerabilities.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	
12.6.1	N/A	12.6.1 corresponds to the part of 12.6.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	
12.6.1.1	N/A	The organization ensures that specific information needed to support the management of technical vulnerabilities (including software defects and incorrect settings) includes the software vendor, version number, deployment status (for example, which software is installed on which system), and the person in the organization responsible for the software.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.2	N/A	12.6.1.2 corresponds to the 1st sentence(beginning with "Appropriate and") of the 2nd paragraph of the Implementation guidance of 12.6.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.3	N/A	The organization defines the roles and responsibilities associated with the management of technical vulnerabilities.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.4	N/A	The organization ensures that technical vulnerability management includes vulnerability monitoring, vulnerability risk assessment, patching, asset movement tracking, and all required coordination responsibilities.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.5	N/A	The organization identifies information resources (such as vulnerability testing tools) that are used to identify technical vulnerabilities and to provide ongoing awareness of those vulnerabilities, corresponding to software and other technologies (based on the organization's asset inventory list).	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.6	N/A	The organization ensures that technical vulnerability information resources are updated when the asset inventory changes or when other new or useful resources are discovered.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.7	N/A	12.6.1.7 corresponds to the c) part of 12.6.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.8	N/A	12.6.1.8 corresponds to the d) part of 12.6.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.9	N/A	12.6.1.9 corresponds to the e) part of 12.6.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.10	N/A	12.6.1.10 corresponds to the f) part of 12.6.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	10	Controls pattern 1
12.6.1.11	N/A	12.6.1.11 corresponds to the g) part of 12.6.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.12	N/A	The organization maintains an audit log of all procedures performed, including the application of corrective patches.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.13	N/A	12.6.1.13 corresponds to the i) part of 12.6.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.14	N/A	12.6.1.14 corresponds to the j) part of 12.6.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Vulnerability Remediation Process	VPM-02	Mechanisms exist to ensure that vulnerabilities are properly identified, tracked and remediated.	10	Controls pattern 1
12.6.1.15	N/A	The organization ensures that an effective management process for technical vulnerabilities is aligned with incident management activities to communicate vulnerability data to the incident response department and prepare technical procedures to be implemented in the event of an incident, addressing vulnerabilities throughout the organization.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.16	N/A	12.6.1.16 corresponds to the l) 1st sentence(beginning with "define a procedure") of the 2nd paragraph of the Implementation guidance of 12.6.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.17	N/A	12.6.1.17 corresponds to the l) 2nd(last) sentence(beginning with "In this situation,") of the 2nd paragraph of the Implementation guidance of 12.6.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 1
12.6.1.18.PB	N/A	12.6.1.18.PB corresponds to the 12.6.1 Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Controls pattern 3

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
12.6.2	N/A	12.6.2 corresponds to the part of 12.6.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Restrict Roles Permitted To Install Software	CFG-05.2	Mechanisms exist to configure systems to prevent the installation of software, unless the action is performed by a privileged user or service.	5	
12.6.2.1	N/A	12.6.2.1 corresponds to the 1st sentence(beginning with "The organization") of the 1st paragraph of the Implementation guidance of 12.6.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Restrict Roles Permitted To Install Software	CFG-05.2	Mechanisms exist to configure systems to prevent the installation of software, unless the action is performed by a privileged user or service.	5	Controls pattern 1
12.6.2.2	N/A	12.6.2.2 corresponds to the 2nd(last) sentence(beginning with "The principle of") of the 1st paragraph of the Implementation guidance of 12.6.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Restrict Roles Permitted To Install Software	CFG-05.2	Mechanisms exist to configure systems to prevent the installation of software, unless the action is performed by a privileged user or service.	5	Controls pattern 1
12.6.2.3	N/A	12.6.2.3 corresponds to the 3rd sentence(beginning with "The organization") of the 2nd(last) paragraph of the Implementation guidance of 12.6.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Restrict Roles Permitted To Install Software	CFG-05.2	Mechanisms exist to configure systems to prevent the installation of software, unless the action is performed by a privileged user or service.	5	Controls pattern 1
12.6.2.4	N/A	12.6.2.4 corresponds to the 4th(last) sentence(beginning with "These privileges") of the 2nd(last) paragraph of the Implementation guidance of 12.6.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Restrict Roles Permitted To Install Software	CFG-05.2	Mechanisms exist to configure systems to prevent the installation of software, unless the action is performed by a privileged user or service.	5	Controls pattern 1
12.7	N/A	Information systems audit considerations Control Objective: To minimise the impact of audit activities on operational systems.	Functional	Subset Of	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	10	
12.7.1	N/A	12.7.1 corresponds to the part of 12.7.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	
12.7.1.1	N/A	12.7.1.1 corresponds to the a) part of 12.7.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	Controls pattern 1
12.7.1.2	N/A	12.7.1.2 corresponds to the b) part of 12.7.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	Controls pattern 1
12.7.1.3	N/A	12.7.1.3 corresponds to the c) part of 12.7.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	Controls pattern 1
12.7.1.4	N/A	12.7.1.4 corresponds to the d) part of 12.7.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	Controls pattern 1
12.7.1.5	N/A	The organization identifies and agrees on the requirements for any special or additional treatment (including actions to be taken if anomalies are found) for conducting tests in the assessment.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	Controls pattern 1
12.7.1.6	N/A	12.7.1.6 corresponds to the f) part of 12.7.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	Controls pattern 1
12.7.1.7	N/A	12.7.1.7 corresponds to the g) part of 12.7.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	Controls pattern 1
12.7.1.8	N/A	The organization ensures that the information system provide a warning when testing fails in an assessment.	Functional	Subset Of	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	10	Controls pattern 1
12.7.1.9	N/A	The organization ensures that any test failures in the assessment are communicated to internal personnel or the organization.	Functional	Subset Of	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	10	Controls pattern 1
13	N/A	Communications security	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	
13.1	N/A	Network security management Control Objective: To ensure the protection of information in networks and its supporting information processing facilities.	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	
13.1.1	N/A	13.1.1 corresponds to the part of 13.1.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	
13.1.1.1	N/A	13.1.1.1 corresponds to the 1st sentence(beginning with "Controls should") of the 1st paragraph of the Implementation guidance of 13.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	Controls pattern 1
13.1.1.2	N/A	13.1.1.2 corresponds to the a) part of 13.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	Controls pattern 1
13.1.1.3	N/A	13.1.1.3 corresponds to the b) part of 13.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	Controls pattern 1
13.1.1.4	N/A	The organization establishes special controls to protect the confidentiality and integrity of data traversing public or wireless networks, and to protect systems and applications connected via the network.	Functional	Intersects With	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	5	Controls pattern 1
13.1.1.5	N/A	The organization establishes special controls to maintain the availability of network services and the availability of computers connected via the network.	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	Controls pattern 1
13.1.1.6	N/A	13.1.1.6 corresponds to the d) part of 13.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	Controls pattern 1
13.1.1.7	N/A	13.1.1.7 corresponds to the e) part of 13.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	Controls pattern 1
13.1.1.8	N/A	The organization ensures that systems (including devices) on the network are authenticated prior to connection.	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	Controls pattern 1
13.1.1.9	N/A	13.1.1.9 corresponds to the g) part of 13.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	Controls pattern 1
13.1.1.10	N/A	The organization ensures that requirements, the nature of the information to be transferred, and procedures are established and documented to authorize internal network connections from peripheral devices of the information system to the information system.	Functional	Intersects With	Internal System Connections	NET-05.2	Mechanisms exist to control internal system connections through authorizing internal connections of systems and documenting, for each internal connection, the interface characteristics, security requirements and the nature of the information communicated.	5	Controls pattern 1
13.1.1.11.P	N/A	The cloud service provider provides information to cloud service customers on the status of IPv6 support in the services provided by the cloud service provider.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	5	
13.1.2	N/A	13.1.2 corresponds to the part of 13.1.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Business Process Definition	PRM-06	Mechanisms exist to define business processes with consideration for security, compliance and resilience that determines: (1) The resulting risk to organizational operations, assets, individuals and other organizations; and (2) Information protection needs arising from the defined business processes and revises the processes as necessary, until an achievable set of protection needs is obtained.	5	
13.1.2	N/A	13.1.2 corresponds to the part of 13.1.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	8	
13.1.2	N/A	13.1.2 corresponds to the part of 13.1.2 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	
13.1.2.1	N/A	13.1.2.1 corresponds to the 1st(last) sentence(beginning with "The ability of") of the 1st paragraph of the Implementation guidance of 13.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
13.1.2.2	N/A	13.1.2.2 corresponds to the 1st sentence(beginning with "The security arrangements") of the 2nd(last) paragraph of the Implementation guidance of 13.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
13.1.3	N/A	13.1.3 corresponds to the part of 13.1.3 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
13.1.3.1	N/A	One method of managing the security of large networks is to divide them into separate network domains (for example, dividing them into segments).	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.3.2	N/A	13.1.3.2 corresponds to the 1st sentence(beginning with "The domains can") of the 1st paragraph of the Implementation guidance of 13.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.3.3	N/A	13.1.3.3 corresponds to the 2nd(last) sentence(beginning with "The segregation") of the 1st paragraph of the Implementation guidance of 13.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.3.4	N/A	13.1.3.4 corresponds to the 1st sentence(beginning with "The perimeter of") of the 2nd paragraph of the Implementation guidance of 13.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.3.5	N/A	Access between network areas shall be controlled by gateways (such as firewalls, WAFs, proxies, reverse proxies, next-generation firewalls, or filtering routers) installed at area boundaries.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.3.6	N/A	13.1.3.6 corresponds to the 3rd sentence(beginning with "The criteria for") of the 2nd paragraph of the Implementation guidance of 13.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.3.7	N/A	13.1.3.7 corresponds to the 4th(last) sentence(beginning with "The assessment") of the 2nd paragraph of the Implementation guidance of 13.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.3.8	N/A	13.1.3.8 corresponds to the 1st sentence(beginning with "Wireless networks") of the 3rd paragraph of the Implementation guidance of 13.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.3.9	N/A	13.1.3.9 corresponds to the 2nd(last) sentence(beginning with "For sensitive environments,") of the 3rd paragraph of the Implementation guidance of 13.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.3.10.P	N/A	13.1.3.10.P corresponds to the 1st of the 2 bullet points bullet points(beginning with "- segregation between") in the 1st paragraph of the Implementation guidance of 13.1.3 in ISO/IEC 27017:2015.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.3.11.P	N/A	13.1.3.11.P corresponds to the 2nd of the 2 bullet points bullet points(beginning with "- segregation between") in the 1st paragraph of the Implementation guidance of 13.1.3 in ISO/IEC 27017:2015.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.3.12.P	N/A	13.1.3.12.P corresponds to the 1st(last) sentence(beginning with "Where appropriate,") of the 2nd paragraph of the Implementation guidance of 13.1.3 in ISO/IEC 27017:2015.	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	Controls pattern 1
13.1.4.P	N/A	13.1.4.P corresponds to the part of CLD.13.1.4 Control in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	5	
13.1.4.P	N/A	13.1.4.P corresponds to the part of CLD.13.1.4 Control in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Security Management Subnets	NET-06.1	Mechanisms exist to implement security management subnets to isolate security tools and support components from other internal system components by implementing separate subnetworks with managed interfaces to other components of the system.	5	
13.1.4.P	N/A	13.1.4.P corresponds to the part of CLD.13.1.4 Control in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Virtual Local Area Network (VLAN) Separation	NET-06.2	Mechanisms exist to enable Virtual Local Area Networks (VLANs) to limit the ability of devices on a network to directly communicate with other devices on the subnet and limit an attacker's ability to laterally move to compromise neighboring systems.	5	
13.1.4.P	N/A	13.1.4.P corresponds to the part of CLD.13.1.4 Control in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Sensitive / Regulated Data Enclave (Secure Zone)	NET-06.3	Mechanisms exist to implement segmentation controls to restrict inbound and outbound connectivity for sensitive and/or regulated data enclaves (secure zones).	5	
13.1.4.1.P	N/A	13.1.4.1.P corresponds to the 1st sentence(beginning with "The cloud service") of the 1st paragraph of the Implementation guidance of CLD.13.1.4 in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	5	Controls pattern 1
13.1.4.2.P	N/A	13.1.4.2.P corresponds to the 2nd(last) sentence(beginning with "The cloud service") of the 1st paragraph of the Implementation guidance of CLD.13.1.4 in ISO/IEC 27017:2015 Annex A.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	5	Controls pattern 1
13.2	N/A	Information transfer Control Objective: To maintain the security of information transferred within an organization and with any external entity.	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	
13.2.1	N/A	13.2.1 corresponds to the part of 13.2.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	
13.2.1.1	N/A	13.2.1.1 corresponds to the a) part of 13.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Technology Use Restrictions	HRS-05.3	Mechanisms exist to establish usage restrictions and implementation guidance for organizational technologies based on the potential to cause damage to Technology Assets, Applications and/or Services (TAAS), if used maliciously.	5	Controls pattern 1
13.2.1.2	N/A	13.2.1.2 corresponds to the b) part of 13.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Technology Use Restrictions	HRS-05.3	Mechanisms exist to establish usage restrictions and implementation guidance for organizational technologies based on the potential to cause damage to Technology Assets, Applications and/or Services (TAAS), if used maliciously.	5	Controls pattern 1
13.2.1.3	N/A	13.2.1.3 corresponds to the c) part of 13.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Technology Use Restrictions	HRS-05.3	Mechanisms exist to establish usage restrictions and implementation guidance for organizational technologies based on the potential to cause damage to Technology Assets, Applications and/or Services (TAAS), if used maliciously.	5	Controls pattern 1
13.2.1.4	N/A	The organization reflects policies or guidelines governing the acceptable use of telecommunications facilities (including physical handling) in procedures and controls followed when using telecommunications facilities for the transfer of information.	Functional	Intersects With	Technology Use Restrictions	HRS-05.3	Mechanisms exist to establish usage restrictions and implementation guidance for organizational technologies based on the potential to cause damage to Technology Assets, Applications and/or Services (TAAS), if used maliciously.	5	Controls pattern 1
13.2.1.5	N/A	13.2.1.5 corresponds to the e) part of 13.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Information Sharing	DCH-14	Mechanisms exist to utilize a process to assist users in making information sharing decisions to ensure data is appropriately protected.	5	Controls pattern 1
13.2.1.6	N/A	13.2.1.6 corresponds to the f) part of 13.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
13.2.1.7	N/A	13.2.1.7 corresponds to the g) part of 13.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
13.2.1.8	N/A	13.2.1.8 corresponds to the h) part of 13.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Technology Use Restrictions	HRS-05.3	Mechanisms exist to establish usage restrictions and implementation guidance for organizational technologies based on the potential to cause damage to Technology Assets, Applications and/or Services (TAAS), if used maliciously.	5	Controls pattern 1
13.2.1.9	N/A	13.2.1.9 corresponds to the i) part of 13.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Information Sharing	DCH-14	Mechanisms exist to utilize a process to assist users in making information sharing decisions to ensure data is appropriately protected.	5	Controls pattern 1
13.2.1.10	N/A	13.2.1.10 corresponds to the j) part of 13.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	Controls pattern 1
13.2.1.11	N/A	13.2.1.11 corresponds to the k) part of 13.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Technology Use Restrictions	HRS-05.3	Mechanisms exist to establish usage restrictions and implementation guidance for organizational technologies based on the potential to cause damage to Technology Assets, Applications and/or Services (TAAS), if used maliciously.	5	Controls pattern 1
13.2.1.12	N/A	13.2.1.12 corresponds to the 1st(last) sentence(beginning with "In addition, personnel") of the 2nd paragraph of the Implementation guidance of 13.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	Controls pattern 1
13.2.1.13	N/A	13.2.1.13 corresponds to the 1st(last) sentence(beginning with "Information transfer") of the 3rd(last) paragraph of the Implementation guidance of 13.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	Controls pattern 1
13.2.1.14	N/A	This includes taking appropriate precautions to prevent unauthorized or accidental transfer of information through shared system resources.	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	Controls pattern 1
13.2.2	N/A	13.2.2 corresponds to the part of 13.2.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Adequate Security for Sensitive / Regulated Data in Support of Contracts	IAO-03.2	Mechanisms exist to protect sensitive and/or regulated data that is collected, developed, received, transmitted, used or stored in support of the performance of a contract.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b0bf6d99e91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
13.2.2.1	N/A	13.2.2.1 corresponds to the a) part of 13.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Management Approval For External Media Transfer	AST-05.1	Mechanisms exist to obtain management approval for any sensitive and/or regulated media that is transferred outside of the organization's facilities.	5	Controls pattern 1
13.2.2.2	N/A	13.2.2.2 corresponds to the b) part of 13.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Adequate Security for Sensitive / Regulated Data In Support of Contracts	IAO-03.2	Mechanisms exist to protect sensitive and/or regulated data that is collected, developed, received, transmitted, used or stored in support of the performance of a contract.	5	Controls pattern 1
13.2.2.3	N/A	13.2.2.3 corresponds to the c) part of 13.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Adequate Security for Sensitive / Regulated Data In Support of Contracts	IAO-03.2	Mechanisms exist to protect sensitive and/or regulated data that is collected, developed, received, transmitted, used or stored in support of the performance of a contract.	5	Controls pattern 1
13.2.2.4	N/A	13.2.2.4 corresponds to the d) part of 13.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Adequate Security for Sensitive / Regulated Data In Support of Contracts	IAO-03.2	Mechanisms exist to protect sensitive and/or regulated data that is collected, developed, received, transmitted, used or stored in support of the performance of a contract.	5	Controls pattern 1
13.2.2.5	N/A	13.2.2.5 corresponds to the e) part of 13.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Media Transportation	DCH-07	Mechanisms exist to protect and control digital and non-digital media during transport outside of controlled areas using appropriate security measures.	5	Controls pattern 1
13.2.2.6	N/A	13.2.2.6 corresponds to the f) part of 13.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Adequate Security for Sensitive / Regulated Data In Support of Contracts	IAO-03.2	Mechanisms exist to protect sensitive and/or regulated data that is collected, developed, received, transmitted, used or stored in support of the performance of a contract.	5	Controls pattern 1
13.2.2.7	N/A	13.2.2.7 corresponds to the g) part of 13.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Adequate Security for Sensitive / Regulated Data In Support of Contracts	IAO-03.2	Mechanisms exist to protect sensitive and/or regulated data that is collected, developed, received, transmitted, used or stored in support of the performance of a contract.	5	Controls pattern 1
13.2.2.8	N/A	13.2.2.8 corresponds to the h) part of 13.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Adequate Security for Sensitive / Regulated Data In Support of Contracts	IAO-03.2	Mechanisms exist to protect sensitive and/or regulated data that is collected, developed, received, transmitted, used or stored in support of the performance of a contract.	5	Controls pattern 1
13.2.2.9	N/A	13.2.2.9 corresponds to the i) part of 13.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Adequate Security for Sensitive / Regulated Data In Support of Contracts	IAO-03.2	Mechanisms exist to protect sensitive and/or regulated data that is collected, developed, received, transmitted, used or stored in support of the performance of a contract.	5	Controls pattern 1
13.2.2.10	N/A	13.2.2.10 corresponds to the j) part of 13.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Adequate Security for Sensitive / Regulated Data In Support of Contracts	IAO-03.2	Mechanisms exist to protect sensitive and/or regulated data that is collected, developed, received, transmitted, used or stored in support of the performance of a contract.	5	Controls pattern 1
13.2.2.11	N/A	13.2.2.11 corresponds to the k) part of 13.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Adequate Security for Sensitive / Regulated Data In Support of Contracts	IAO-03.2	Mechanisms exist to protect sensitive and/or regulated data that is collected, developed, received, transmitted, used or stored in support of the performance of a contract.	5	Controls pattern 1
13.2.2.12	N/A	13.2.2.12 corresponds to the 1st(last) sentence(beginning with "Policies, procedures") of the 2nd paragraph of the Implementation guidance of 13.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	10	Controls pattern 1
13.2.2.13	N/A	13.2.2.13 corresponds to the 1st(last) sentence(beginning with "The information") of the 3rd(last) paragraph of the Implementation guidance of 13.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	10	Controls pattern 1
13.2.3	N/A	13.2.3 corresponds to the part of 13.2.3 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	10	Controls pattern 1
13.2.3.1	N/A	13.2.3.1 corresponds to the a) part of 13.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	10	Controls pattern 1
13.2.3.2	N/A	13.2.3.2 corresponds to the b) part of 13.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	10	Controls pattern 1
13.2.3.3	N/A	13.2.3.3 corresponds to the c) part of 13.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	10	Controls pattern 1
13.2.3.4	N/A	13.2.3.4 corresponds to the d) part of 13.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	10	Controls pattern 1
13.2.3.5	N/A	13.2.3.5 corresponds to the e) part of 13.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	10	Controls pattern 1
13.2.3.6	N/A	13.2.3.6 corresponds to the f) part of 13.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	10	Controls pattern 1
13.2.3.7.P		Cloud service providers shall provide users with functions for or information on configuring sending side measures via DMARC and measures based on sending domain authentication technology using SPF and/or DKIM in electronic messaging communication via e-mail.	Functional	Subset Of	Electronic Messaging	NET-13	Mechanisms exist to protect the confidentiality, integrity and availability of electronic messaging communications.	10	Controls pattern 3
13.2.4	N/A	13.2.4 corresponds to the part of 13.2.4 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.1	N/A	13.2.4.1 corresponds to the 1st sentence(beginning with "Confidentiality") of the 1st paragraph of the Implementation guidance of 13.2.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.2	N/A	13.2.4.2 corresponds to the 2nd sentence(beginning with "Confidentiality") of the 1st paragraph of the Implementation guidance of 13.2.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.3	N/A	13.2.4.3 corresponds to the 3rd sentence(beginning with "Elements should") of the 1st paragraph of the Implementation guidance of 13.2.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.4	N/A	13.2.4.4 corresponds to the a) part of 13.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.5	N/A	13.2.4.5 corresponds to the b) part of 13.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.6	N/A	13.2.4.6 corresponds to the c) part of 13.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.7	N/A	13.2.4.7 corresponds to the d) part of 13.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.8	N/A	13.2.4.8 corresponds to the e) part of 13.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.9	N/A	13.2.4.9 corresponds to the f) part of 13.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.10	N/A	13.2.4.10 corresponds to the g) part of 13.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.11	N/A	13.2.4.11 corresponds to the h) part of 13.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.12	N/A	13.2.4.12 corresponds to the i) part of 13.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.13	N/A	13.2.4.13 corresponds to the j) part of 13.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.14	N/A	13.2.4.14 corresponds to the 1st(last) sentence(beginning with "Based on an organization's") of the 2nd paragraph of the Implementation guidance of 13.2.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.15	N/A	13.2.4.15 corresponds to the 1st(last) sentence(beginning with "Confidentiality") of the 3rd paragraph of the Implementation guidance of 13.2.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
13.2.4.16	N/A	13.2.4.16 corresponds to the 1st(last) sentence(beginning with "Requirements for") of the 4th(last) paragraph of the Implementation guidance of 13.2.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	10	Controls pattern 1
14	N/A	System acquisition, development and maintenance	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
14.1	N/A	Security requirements of information systems Control Objective: To ensure that information security is an integral part of information systems across the entire lifecycle. This also includes the requirements for information systems which provide services over public networks.	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	5	
14.1.1	N/A	14.2 Security in development and support processes Objective: To ensure that information security is designed and implemented within the development lifecycle of information systems.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and (4) Conform with applicable statutory, regulatory and/or contractual obligations.	5	
14.1.1.1	N/A	b) guidance on the security in the software development lifecycle: 1) security in the software development methodology; 2) secure coding guidelines for each programming language used;	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	5	Controls pattern 1
14.1.1.2	N/A	The organization ensures that the results of the work to identify information security requirements are documented, reviewed by all stakeholders, and updated.	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and	5	Controls pattern 1
14.1.1.2	N/A	The organization ensures that the results of the work to identify information security requirements are documented, reviewed by all stakeholders, and updated.	Functional	Intersects With	Business Process Definition	PRM-06	Mechanisms exist to define business processes with consideration for security, compliance and resilience that determines: (1) The resulting risk to organizational operations, assets, individuals and other organizations; and (2) Information protection needs arising from the defined business processes and revises the processes as necessary, until an achievable set of protection needs is obtained.	5	Controls pattern 1
14.1.1.2	N/A	The organization ensures that the results of the work to identify information security requirements are documented, reviewed by all stakeholders, and updated.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	8	Controls pattern 1
14.1.1.3	N/A	14.1.1.3 corresponds to the 1st(last) sentence(beginning with "information security") of the 2nd paragraph of the Implementation guidance of 14.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Controls pattern 1
14.1.1.4	N/A	14.1.1.4 corresponds to the 1st sentence(beginning with "identification") of the 3rd paragraph of the Implementation guidance of 14.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Controls pattern 1
14.1.1.5	N/A	14.1.1.5 corresponds to the a) part of 14.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Controls pattern 1
14.1.1.6	N/A	14.1.1.6 corresponds to the b) part of 14.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Controls pattern 1
14.1.1.7	N/A	14.1.1.7 corresponds to the c) part of 14.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Controls pattern 1
14.1.1.8	N/A	14.1.1.8 corresponds to the d) part of 14.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Controls pattern 1
14.1.1.9	N/A	14.1.1.9 corresponds to the e) part of 14.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Controls pattern 1
14.1.1.10	N/A	14.1.1.10 corresponds to the f) part of 14.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Controls pattern 1
14.1.1.11	N/A	14.1.1.11 corresponds to the 1st(last) sentence(beginning with "For applications") of the 5th paragraph of the Implementation guidance of 14.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Controls pattern 1
14.1.1.12	N/A	14.1.1.12 corresponds to the 1st sentence(beginning with "If products are") of the 6th paragraph of the Implementation guidance of 14.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	10	Controls pattern 1
14.1.1.13	N/A	14.1.1.13 corresponds to the 2nd sentence(beginning with "Contracts with") of the 6th paragraph of the Implementation guidance of 14.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Controls pattern 1
14.1.1.14	N/A	If the security functionality of a proposed product does not meet the specified requirements, the organization reconsiders the risks that occur and associated controls before purchasing or modifying the product.	Functional	Intersects With	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
14.1.1.15	N/A	14.1.1.15 corresponds to the 1st(last) sentence(beginning with "Available guidance") of the 7th paragraph of the Implementation guidance of 14.1.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Documentation Requirements	TDA-04	Mechanisms exist to obtain, protect and distribute administrator documentation for Technology Assets, Applications and/or Services (TAAS) that describe: (1) Secure configuration, installation and operation of the TAAS; (2) Effective use and maintenance of security features/functions; and (3) Known vulnerabilities regarding configuration and use of administrative (e.g., privileged) functions.	5	Controls pattern 1
14.1.1.16	N/A	The organization defines product acceptance criteria in terms of functionality that provides assurance that the specified security requirements are met.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Controls pattern 1
14.1.1.17	N/A	The organization evaluates products based on product acceptance criteria before they are acquired.	Functional	Subset Of	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	10	Controls pattern 1
14.1.1.18	N/A	14.1.1.18 corresponds to the 2nd & 3rd(last) sentence(beginning with "Products should" & "Additional functionality should") of the 8th(last) paragraph of the Implementation guidance of 14.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	10	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm/?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd7a2b5fa250f0bbfd69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
14.1.1.19.P	N/A	14.1.1.19.P corresponds to the 1st sentence(beginning with "The cloud service") of the 1st(last) paragraph of the Implementation guidance of 14.1.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	5	Controls pattern 3
14.1.1.20.P	N/A	The cloud service provider ensures that useful information provided to cloud service customers about information security functions used by cloud service customers does not result in the disclosure of information that is useful to malicious parties.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	5	Controls pattern 3
14.1.1.23	N/A	The organization ensures that information system error messages do not result in the disclosure of information that is useful to malicious parties.	Functional	Intersects With	Prevent Discovery of Internal Information	NET-03.3	Mechanisms exist to prevent the public disclosure of internal network information.	5	Controls pattern 1
14.1.1.24	N/A	The organization ensures that error messages in information systems are disclosed only to specific customers.	Functional	No Relationship	N/A	N/A	N/A	0	
14.1.2	N/A	14.1.2 corresponds to the part of 14.1.2 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	
14.1.2.1	N/A	14.1.2.1 corresponds to the a) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.2	N/A	14.1.2.2 corresponds to the b) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.3	N/A	14.1.2.3 corresponds to the c) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.4	N/A	14.1.2.4 corresponds to the d) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.5	N/A	14.1.2.5 corresponds to the e) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.6	N/A	14.1.2.6 corresponds to the f) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.7	N/A	14.1.2.7 corresponds to the g) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.8	N/A	14.1.2.8 corresponds to the h) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.9	N/A	14.1.2.9 corresponds to the i) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.10	N/A	14.1.2.10 corresponds to the j) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.11	N/A	14.1.2.11 corresponds to the k) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.12	N/A	14.1.2.12 corresponds to the l) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.13	N/A	14.1.2.13 corresponds to the m) part of 14.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.14	N/A	14.1.2.14 corresponds to the 1st(last) sentence(beginning with "Application service") of the 3rd paragraph of the Implementation guidance of 14.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.2.15	N/A	14.1.2.15 corresponds to the 1st(last) sentence(beginning with "Resilience requirements") of the 4th(last) paragraph of the Implementation guidance of 14.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Safeguarding Data Over Open Networks	NET-12	Cryptographic mechanisms exist to implement strong cryptography and security protocols to safeguard sensitive and/or regulated data during transmission over open, public networks.	10	Controls pattern 1
14.1.3	N/A	14.1.3 corresponds to the part of 14.1.3 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	
14.1.3.1	N/A	14.1.3.1 corresponds to the a) part of 14.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
14.1.3.2	N/A	14.1.3.2 corresponds to the b) part of 14.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
14.1.3.3	N/A	14.1.3.3 corresponds to the c) part of 14.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
14.1.3.4	N/A	14.1.3.4 corresponds to the d) part of 14.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
14.1.3.5	N/A	14.1.3.5 corresponds to the e) part of 14.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
14.1.3.6	N/A	14.1.3.6 corresponds to the f) part of 14.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Controls pattern 1
14.2	N/A	Security in development and support processes Control Objective: To ensure that information security is designed and implemented within the development lifecycle of information systems.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	
14.2.1	N/A	14.2.1 corresponds to the part of 14.2.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	
14.2.1.1	N/A	14.2.1.1 corresponds to the a) part of 14.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	5	Controls pattern 1
14.2.1.2	N/A	14.2.1.2 corresponds to the b) part of 14.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	5	Controls pattern 1
14.2.1.3	N/A	14.2.1.3 corresponds to the c) part of 14.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	Controls pattern 1
14.2.1.4	N/A	14.2.1.4 corresponds to the d) part of 14.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	Controls pattern 1
14.2.1.5	N/A	14.2.1.5 corresponds to the e) part of 14.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	Controls pattern 1
14.2.1.6	N/A	14.2.1.6 corresponds to the f) part of 14.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Release Integrity Verification	TDA-20.1	Mechanisms exist to publish integrity verification information for software releases.	5	Controls pattern 1
14.2.1.7	N/A	14.2.1.7 corresponds to the g) part of 14.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	5	Controls pattern 1

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
14.2.1.8	N/A	14.2.1.8 corresponds to the h) part of 14.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	5	Controls pattern 1
14.2.1.9	N/A	14.2.1.9 corresponds to the 1st sentence(beginning with "Secure programming") of the 2nd paragraph of the Implementation guidance of 14.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	5	Controls pattern 1
14.2.1.10	N/A	14.2.1.10 corresponds to the 2nd sentence(beginning with "Secure coding standards") of the 2nd paragraph of the Implementation guidance of 14.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	5	Controls pattern 1
14.2.1.11	N/A	14.2.1.11 corresponds to the 3rd(last) sentence(beginning with "Developers should") of the 2nd paragraph of the Implementation guidance of 14.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	5	Controls pattern 1
14.2.1.12	N/A	14.2.1.12 corresponds to the 1st(last) sentence(beginning with "If development") of the 3rd(last) paragraph of the Implementation guidance of 14.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Controls pattern 1
14.2.1.13.PB	N/A	14.2.1.13.PB corresponds to the 14.2.1 Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	Controls pattern 3
14.2.2	N/A	14.2.2 corresponds to the part of 14.2.2 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	
14.2.2.1	N/A	14.2.2.1 corresponds to the 1st(last) sentence(beginning with "Formal change control") of the 1st paragraph of the Implementation guidance of 14.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.2	N/A	14.2.2.2 corresponds to the 1st(last) sentence(beginning with "Introduction of") of the 2nd paragraph of the Implementation guidance of 14.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.3	N/A	14.2.2.3 corresponds to the 1st sentence(beginning with "This process should") of the 3rd paragraph of the Implementation guidance of 14.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.4	N/A	14.2.2.4 corresponds to the 2nd(last) sentence(beginning with "This process should") of the 3rd paragraph of the Implementation guidance of 14.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.5	N/A	14.2.2.5 corresponds to the 1st sentence(beginning with "Wherever practicable," of the 4th paragraph of the Implementation guidance of 14.2.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.6	N/A	14.2.2.6 corresponds to the a) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.7	N/A	14.2.2.7 corresponds to the b) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.8	N/A	14.2.2.8 corresponds to the c) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.9	N/A	14.2.2.9 corresponds to the d) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.10	N/A	14.2.2.10 corresponds to the e) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.11	N/A	14.2.2.11 corresponds to the f) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.12	N/A	14.2.2.12 corresponds to the g) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.13	N/A	14.2.2.13 corresponds to the h) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.14	N/A	14.2.2.14 corresponds to the i) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.15	N/A	14.2.2.15 corresponds to the j) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.16	N/A	14.2.2.16 corresponds to the k) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.2.17	N/A	14.2.2.17 corresponds to the l) part of 14.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.3	N/A	14.2.3 corresponds to the part of 14.2.3 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	10	
14.2.3.1	N/A	14.2.3.1 corresponds to the a) part of 14.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	10	Controls pattern 1
14.2.3.2	N/A	14.2.3.2 corresponds to the b) part of 14.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	10	Controls pattern 1
14.2.3.3	N/A	14.2.3.3 corresponds to the c) part of 14.2.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	10	Controls pattern 1
14.2.4	N/A	14.2.4 corresponds to the part of 14.2.4 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	10	
14.2.4.1	N/A	14.2.4.1 corresponds to the 1st sentence(beginning with "As far as possible") of the 1st paragraph of the Implementation guidance of 14.2.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	10	Controls pattern 1
14.2.4.2	N/A	14.2.4.2 corresponds to the a) part of 14.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	10	Controls pattern 1
14.2.4.3	N/A	14.2.4.3 corresponds to the b) part of 14.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	10	Controls pattern 1
14.2.4.4	N/A	14.2.4.4 corresponds to the c) part of 14.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	10	Controls pattern 1
14.2.4.5	N/A	14.2.4.5 corresponds to the d) part of 14.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	10	Controls pattern 1
14.2.4.6	N/A	14.2.4.6 corresponds to the e) part of 14.2.4 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	10	Controls pattern 1
14.2.4.7	N/A	14.2.4.7 corresponds to the 1st sentence(beginning with "If changes are") of the 2nd(last) paragraph of the Implementation guidance of 14.2.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.4.8	N/A	14.2.4.8 corresponds to the 2nd sentence(beginning with "A software update") of the 2nd(last) paragraph of the Implementation guidance of 14.2.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.4.9	N/A	14.2.4.9 corresponds to the 3rd sentence(beginning with "All changes should") of the 2nd(last) paragraph of the Implementation guidance of 14.2.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.4.10	N/A	14.2.4.10 corresponds to the 4th(last) sentence(beginning with "If required, the") of the 2nd(last) paragraph of the Implementation guidance of 14.2.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	10	Controls pattern 1
14.2.5	N/A	14.2.5 corresponds to the part of 14.2.5 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	
14.2.5.1	N/A	14.2.5.1 corresponds to the 1st sentence(beginning with "Secure information") of the 1st paragraph of the Implementation guidance of 14.2.5 in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
14.2.5.2	N/A	14.2.5.2 corresponds to the 2nd sentence(beginning with "Security should") of the 1st paragraph of the Implementation guidance of 14.2.5 in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
14.2.5.3	N/A	14.2.5.3 corresponds to the 3rd(last) sentence(beginning with "New technology") of the 1st paragraph of the Implementation guidance of 14.2.5 in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
14.2.5.4	N/A	14.2.5.4 corresponds to the 1st sentence(beginning with "These principles") of the 2nd paragraph of the Implementation guidance of 14.2.5 in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
14.2.5.5	N/A	14.2.5.5 corresponds to the 2nd(last) sentence(beginning with "They should also") of the 2nd paragraph of the Implementation guidance of 14.2.5 in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
14.2.5.6	N/A	14.2.5.6 corresponds to the 1st sentence(beginning with "The established") of the 3rd(last) paragraph of the Implementation guidance of 14.2.5 in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
14.2.5.7	N/A	14.2.5.7 corresponds to the 2nd(last) sentence(beginning with "The organization") of the 3rd(last) paragraph of the Implementation guidance of 14.2.5 in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	Controls pattern 1
14.2.5.8	N/A	The organization maintains the authenticity of communication sessions based on the principles for building security-conscious systems.	Functional	Intersects With	Transmission Integrity	CRY-04	Cryptographic mechanisms exist to protect the integrity of data being transmitted.	5	Controls pattern 1
14.2.5.9	N/A	The organization verifies the validity of information input to the system, based on the principles for building a security-conscious system.	Functional	Intersects With	Input Data Validation	TDA-18	Mechanisms exist to check the validity of information inputs.	5	Controls pattern 1
14.2.6	N/A	14.2.6 corresponds to the part of 14.2.6 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	
14.2.6.1	N/A	14.2.6.1 corresponds to the 1st(last) sentence(beginning with "A secure development") of the 1st paragraph of the Implementation guidance of 14.2.6 in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.6.2	N/A	14.2.6.2 corresponds to the a) part of 14.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.6.3	N/A	14.2.6.3 corresponds to the b) part of 14.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.6.4	N/A	14.2.6.4 corresponds to the c) part of 14.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.6.5	N/A	14.2.6.5 corresponds to the d) part of 14.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.6.6	N/A	14.2.6.6 corresponds to the e) part of 14.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.6.7	N/A	14.2.6.7 corresponds to the f) part of 14.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.6.8	N/A	14.2.6.8 corresponds to the g) part of 14.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.6.9	N/A	14.2.6.9 corresponds to the h) part of 14.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.6.10	N/A	14.2.6.10 corresponds to the i) part of 14.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.6.11	N/A	14.2.6.11 corresponds to the j) part of 14.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Secure Migration Practices	TDA-08.1	Mechanisms exist to ensure secure migration practices purge Technology Assets, Applications and/or Services (TAAS) of test/development/staging data and accounts before it is migrated into a production environment.	5	Controls pattern 1
14.2.6.11	N/A	14.2.6.11 corresponds to the j) part of 14.2.6 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.6.12	N/A	14.2.6.12 corresponds to the 1st(last) sentence(beginning with "Once the level") of the 3rd(last) paragraph of the Implementation guidance of 14.2.6 in ISO/IEC 27002:2013.	Functional	Subset Of	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	10	Controls pattern 1
14.2.7	N/A	14.2.7 corresponds to the part of 14.2.7 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	
14.2.7.1	N/A	14.2.7.1 corresponds to the a) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
14.2.7.1	N/A	14.2.7.1 corresponds to the a) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Controls pattern 1
14.2.7.2	N/A	14.2.7.2 corresponds to the b) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Controls pattern 1
14.2.7.3	N/A	14.2.7.3 corresponds to the c) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Threat Modeling	TDA-06.2	Mechanisms exist to perform threat modelling and other secure design techniques, to ensure that threats to software and solutions are identified and accounted for.	5	Controls pattern 1
14.2.7.4	N/A	14.2.7.4 corresponds to the d) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	Controls pattern 1
14.2.7.5	N/A	14.2.7.5 corresponds to the e) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	Controls pattern 1
14.2.7.6	N/A	14.2.7.6 corresponds to the f) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	Controls pattern 1
14.2.7.7	N/A	14.2.7.7 corresponds to the g) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	Controls pattern 1
14.2.7.8	N/A	14.2.7.8 corresponds to the h) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Escrow	TDA-20.3	Mechanisms exist to escrow source code and supporting documentation to ensure software availability in the event the software provider goes out of business or is unable to provide support.	5	Controls pattern 1
14.2.7.9	N/A	14.2.7.9 corresponds to the i) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Controls pattern 1
14.2.7.10	N/A	14.2.7.10 corresponds to the j) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Documentation Requirements	TDA-04	Mechanisms exist to obtain, protect and distribute administrator documentation for Technology Assets, Applications and/or Services (TAAS) that describe: (1) Secure configuration, installation and operation of the TAAS; (2) Effective use and maintenance of security features/functions; and (3) Known vulnerabilities regarding configuration and use of administrative (e.g., privileged) functions.	5	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm/?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf6d9e91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
14.2.7.11	N/A	14.2.7.11 corresponds to the k) part of 14.2.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and (4) Conform with applicable statutory, regulatory and/or contractual obligations.	5	Controls pattern 1
14.2.8	N/A	14.2.8 corresponds to the part of 14.2.8 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	Controls pattern 1
14.2.8.1	N/A	14.2.8.1 corresponds to the 1st & 2nd sentence(beginning with "New and updated" & "For in-house developments") of the 1st(last) paragraph of the Implementation guidance of 14.2.8 in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	Controls pattern 1
14.2.8.2	N/A	14.2.8.2 corresponds to the 3rd sentence(beginning with "Independent acceptance") of the 1st(last) paragraph of the Implementation guidance of 14.2.8 in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	Controls pattern 1
14.2.8.3	N/A	14.2.8.3 corresponds to the 4th(last) sentence(beginning with "The extent of testing") of the 1st(last) paragraph of the Implementation guidance of 14.2.8 in ISO/IEC 27002:2013.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	Controls pattern 1
14.2.9	N/A	14.2.9 corresponds to the part of 14.2.9 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	Controls pattern 1
14.2.9.1	N/A	14.2.9.1 corresponds to the 1st sentence(beginning with "System acceptance") of the 1st paragraph of the Implementation guidance of 14.2.9 in ISO/IEC 27002:2013.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	Controls pattern 1
14.2.9.2	N/A	14.2.9.2 corresponds to the 2nd sentence(beginning with "The testing should") of the 1st paragraph of the Implementation guidance of 14.2.9 in ISO/IEC 27002:2013.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	Controls pattern 1
14.2.9.3	N/A	14.2.9.3 corresponds to the 3rd(last) sentence(beginning with "Organizations can") of the 1st paragraph of the Implementation guidance of 14.2.9 in ISO/IEC 27002:2013.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	Controls pattern 1
14.2.9.4	N/A	14.2.9.4 corresponds to the 1st(last) sentence(beginning with "Testing should") of the 2nd(last) paragraph of the Implementation guidance of 14.2.9 in ISO/IEC 27002:2013.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	Controls pattern 1
14.3	N/A	Test data Control Objective: To ensure the protection of data used for testing.	Functional	Intersects With	Use of Live Data	TDA-10	Mechanisms exist to approve, document and control the use of live data in development and test environments.	5	Controls pattern 1
14.3.1	N/A	14.3.1 corresponds to the part of 14.3.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Live Data	TDA-10	Mechanisms exist to approve, document and control the use of live data in development and test environments.	5	Controls pattern 1
14.3.1.1	N/A	14.3.1.1 corresponds to the 1st sentence(beginning with "The use of operational") of the 1st paragraph of the Implementation guidance of 14.3.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Live Data	TDA-10	Mechanisms exist to approve, document and control the use of live data in development and test environments.	5	Controls pattern 1
14.3.1.2	N/A	14.3.1.2 corresponds to the 2nd(last) sentence(beginning with "If personally identifiable") of the 1st paragraph of the Implementation guidance of 14.3.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Live Data	TDA-10	Mechanisms exist to approve, document and control the use of live data in development and test environments.	5	Controls pattern 1
14.3.1.3	N/A	14.3.1.3 corresponds to the a) part of 14.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Live Data	TDA-10	Mechanisms exist to approve, document and control the use of live data in development and test environments.	5	Controls pattern 1
14.3.1.4	N/A	14.3.1.4 corresponds to the b) part of 14.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Live Data	TDA-10	Mechanisms exist to approve, document and control the use of live data in development and test environments.	5	Controls pattern 1
14.3.1.5	N/A	14.3.1.5 corresponds to the c) part of 14.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Live Data	TDA-10	Mechanisms exist to approve, document and control the use of live data in development and test environments.	5	Controls pattern 1
14.3.1.6	N/A	14.3.1.6 corresponds to the d) part of 14.3.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Use of Live Data	TDA-10	Mechanisms exist to approve, document and control the use of live data in development and test environments.	5	Controls pattern 1
15	N/A	Supplier relationships	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1	N/A	Information security in supplier relationships Control Objective: To ensure protection of the organization's assets that is accessible by suppliers.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1	N/A	15.1.1 corresponds to the part of 15.1.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.1	N/A	15.1.1.1 corresponds to the 1st sentence(beginning with "The organization") of the 1st paragraph of the Implementation guidance of 15.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.2	N/A	15.1.1.2 corresponds to the a) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.3	N/A	15.1.1.3 corresponds to the b) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.4	N/A	15.1.1.4 corresponds to the c) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.5	N/A	15.1.1.5 corresponds to the d) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.6	N/A	15.1.1.6 corresponds to the e) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.7	N/A	15.1.1.7 corresponds to the f) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.8	N/A	15.1.1.8 corresponds to the g) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.9	N/A	15.1.1.9 corresponds to the h) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.10	N/A	15.1.1.10 corresponds to the i) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.11	N/A	15.1.1.11 corresponds to the j) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.12	N/A	15.1.1.12 corresponds to the k) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf69e91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
15.1.1.13	N/A	15.1.1.13 corresponds to the l) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.14.B	N/A	15.1.1.14.B corresponds to the m) part of 15.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	Controls pattern 1
15.1.1.16.B	N/A	The cloud service provider evaluates the risk of information handled in the service provided by the cloud service provider being accessed or processed without the cloud service customer's intention as a result of the application of laws and regulations other than domestic laws to the information handled. Based on this evaluations, the cloud service provider selects an external contractor and, if necessary, specify the location where the information handled by the cloud service customer is handled and the governing law and jurisdiction as stipulated in the contract.	Functional	Intersects With	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	5	Controls pattern 1
15.1.2	N/A	15.1.2 corresponds to the part of 15.1.2 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	
15.1.2.1	N/A	15.1.2.1 corresponds to the 1st sentence(beginning with "Supplier agreements") of the 1st paragraph of the Implementation guidance of 15.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.2	N/A	15.1.2.2 corresponds to the a) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.3	N/A	15.1.2.3 corresponds to the b) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.4	N/A	15.1.2.4 corresponds to the c) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.5	N/A	15.1.2.5 corresponds to the d) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.6	N/A	15.1.2.6 corresponds to the e) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.7	N/A	To meet the identified information security requirements, the organization ensures that agreements with suppliers include a clear list of the supplier's personnel authorized to access or receive the organization's information, or the procedures and conditions for authorizing or terminating the authorization of the supplier's personnel to access or receive the organization's information, and informing the organization of any changes to the list or termination of the authorization.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.8	N/A	15.1.2.8 corresponds to the g) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.9	N/A	15.1.2.9 corresponds to the h) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.10	N/A	15.1.2.10 corresponds to the i) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.11	N/A	15.1.2.11 corresponds to the j) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.12	N/A	15.1.2.12 corresponds to the k) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.13	N/A	15.1.2.13 corresponds to the l) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.14	N/A	15.1.2.14 corresponds to the m) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.15	N/A	15.1.2.15 corresponds to the n) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.16	N/A	15.1.2.16 corresponds to the o) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.17	N/A	15.1.2.17 corresponds to the p) part of 15.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.2.18.PB	N/A	The cloud service provider defines, as part of the agreement, appropriate information security measures to be implemented by the cloud service provider to avoid misunderstandings between the cloud service provider and cloud service customers.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.3	N/A	15.1.3 corresponds to the part of 15.1.3 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	
15.1.3.1	N/A	15.1.3.1 corresponds to the a) part of 15.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.3.2	N/A	15.1.3.2 corresponds to the b) part of 15.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.3.3	N/A	15.1.3.3 corresponds to the c) part of 15.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.3.4	N/A	15.1.3.4 corresponds to the d) part of 15.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.3.5	N/A	15.1.3.5 corresponds to the e) part of 15.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.3.6	N/A	15.1.3.6 corresponds to the f) part of 15.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: Japan - Information System Security Management and Assessment Program (ISMAP)

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
15.1.3.7	N/A	15.1.3.7 corresponds to the g) part of 15.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.3.8	N/A	15.1.3.8 corresponds to the h) part of 15.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.3.9	N/A	15.1.3.9 corresponds to the i) part of 15.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.3.10.P	N/A	15.1.3.10.P corresponds to the 1st(last) sentence(beginning with "If a cloud service") of the 1st paragraph of the Implementation guidance of 15.1.3 in ISO/IEC 27017:2015.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.1.3.11.P	N/A	15.1.3.11.P corresponds to the 1st(last) sentence(beginning with "When the cloud") of the 2nd paragraph of the Implementation guidance of 15.1.3 in ISO/IEC 27017:2015.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Controls pattern 1
15.2	N/A	Supplier service delivery management Control Objective: To maintain an agreed level of information security and service delivery in line with supplier agreements.	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	
15.2.1	N/A	15.2.1 corresponds to the part of 15.2.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	
15.2.1.1	N/A	15.2.1.1 corresponds to the 1st(last) sentence(beginning with "Monitoring and") of the 1st paragraph of the Implementation guidance of 15.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.2	N/A	15.2.1.2 corresponds to the a) part of 15.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.3	N/A	15.2.1.3 corresponds to the b) part of 15.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.4	N/A	15.2.1.4 corresponds to the c) part of 15.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.5	N/A	15.2.1.5 corresponds to the d) part of 15.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.6	N/A	15.2.1.6 corresponds to the e) part of 15.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.7	N/A	15.2.1.7 corresponds to the f) part of 15.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.8	N/A	15.2.1.8 corresponds to the g) part of 15.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.9	N/A	15.2.1.9 corresponds to the h) part of 15.2.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.10	N/A	15.2.1.10 corresponds to the 1st sentence(beginning with "The responsibility") of the 3rd paragraph of the Implementation guidance of 15.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.11	N/A	15.2.1.11 corresponds to the 2nd sentence(beginning with "In addition, the") of the 3rd paragraph of the Implementation guidance of 15.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.12	N/A	15.2.1.12 corresponds to the 3rd sentence(beginning with "Sufficient technical") of the 3rd paragraph of the Implementation guidance of 15.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.13	N/A	15.2.1.13 corresponds to the 4th(last) sentence(beginning with "Appropriate action") of the 3rd paragraph of the Implementation guidance of 15.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	10	Controls pattern 1
15.2.1.14	N/A	15.2.1.14 corresponds to the 1st sentence(beginning with "The organization") of the 4th(last) paragraph of the Implementation guidance of 15.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Managing Changes To Third-Party Services	TPM-10	Mechanisms exist to control changes to services by suppliers, taking into account the criticality of business Technology Assets, Applications, Services and/or Data (TAASD) that are in scope by the third-party.	10	Controls pattern 1
15.2.1.15	N/A	15.2.1.15 corresponds to the 2nd(last) sentence(beginning with "The organization") of the 4th(last) paragraph of the Implementation guidance of 15.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Managing Changes To Third-Party Services	TPM-10	Mechanisms exist to control changes to services by suppliers, taking into account the criticality of business Technology Assets, Applications, Services and/or Data (TAASD) that are in scope by the third-party.	10	Controls pattern 1
15.2.2	N/A	15.2.2 corresponds to the part of 15.2.2 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Managing Changes To Third-Party Services	TPM-10	Mechanisms exist to control changes to services by suppliers, taking into account the criticality of business Technology Assets, Applications, Services and/or Data (TAASD) that are in scope by the third-party.	10	
15.2.2.1	N/A	15.2.2.1 corresponds to the a) part of 15.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Managing Changes To Third-Party Services	TPM-10	Mechanisms exist to control changes to services by suppliers, taking into account the criticality of business Technology Assets, Applications, Services and/or Data (TAASD) that are in scope by the third-party.	10	Controls pattern 1
15.2.2.2	N/A	15.2.2.2 corresponds to the b) part of 15.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Managing Changes To Third-Party Services	TPM-10	Mechanisms exist to control changes to services by suppliers, taking into account the criticality of business Technology Assets, Applications, Services and/or Data (TAASD) that are in scope by the third-party.	10	Controls pattern 1
15.2.2.3	N/A	15.2.2.3 corresponds to the c) part of 15.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Managing Changes To Third-Party Services	TPM-10	Mechanisms exist to control changes to services by suppliers, taking into account the criticality of business Technology Assets, Applications, Services and/or Data (TAASD) that are in scope by the third-party.	10	Controls pattern 1
16	N/A	Information security incident management	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	
16.1	N/A	Management of information security incidents and improvements Control Objective: To ensure a consistent and effective approach to the management of information security incidents, including communication on security events and weaknesses.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	
16.1.1	N/A	16.1.1 corresponds to the part of 16.1.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b6fd69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
16.1.1.1	N/A	16.1.1.1 corresponds to the a) part of 16.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.1.2	N/A	The organization ensures the following four points in the procedures to be established for the responsibilities and procedures of the management team regarding information security incident management. 1. Matters related to information security incidents in the organization are handled by competent personnel. 2. Advice and assistance are provided on responding to and reporting security incidents. 3. Establish contact information for detecting and reporting security incidents. 4. Maintain appropriate communication (including warnings, recommendations, and instructions) with relevant authorities, external interest groups, or conferences that handle matters related to information security incidents.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Controls pattern 1
16.1.1.3	N/A	16.1.1.3 corresponds to the c) part of 16.1.1 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.1.4	N/A	The organization obtains the agreement of the governing body on the objectives of information security incident management.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Controls pattern 1
16.1.1.5	N/A	The organization ensures that the people responsible for information security incident management understand the organization's established priorities for handling information security incidents.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Controls pattern 1
16.1.1.6.P	N/A	16.1.1.6.P corresponds to the 1st(last) sentence(beginning with "As a part of the") of the 1st paragraph of the Implementation guidance of 16.1.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Controls pattern 1
16.1.1.7.P	N/A	16.1.1.7.P corresponds to the 1st of the 6 bullet points bullet points(beginning with "- the scope of") in the 2nd paragraph of the Implementation guidance of 16.1.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Controls pattern 3
16.1.1.8.P	N/A	16.1.1.8.P corresponds to the 2nd of the 6 bullet points bullet points(beginning with "- the level of") in the 2nd paragraph of the Implementation guidance of 16.1.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Controls pattern 3
16.1.1.9.P	N/A	16.1.1.9.P corresponds to the 3rd of the 6 bullet points bullet points(beginning with "- the target timeframe") in the 2nd paragraph of the Implementation guidance of 16.1.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Controls pattern 3
16.1.1.10.P	N/A	16.1.1.10.P corresponds to the 4th of the 6 bullet points bullet points(beginning with "- the procedure") in the 2nd paragraph of the Implementation guidance of 16.1.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Controls pattern 3
16.1.1.11.P	N/A	16.1.1.11.P corresponds to the 5th of the 6 bullet points bullet points(beginning with "- contact information") in the 2nd paragraph of the Implementation guidance of 16.1.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Controls pattern 3
16.1.1.12.P	N/A	16.1.1.12.P corresponds to the 4th of the 6 bullet points bullet points(beginning with "- any remedies") in the 2nd paragraph of the Implementation guidance of 16.1.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Controls pattern 3
16.1.1.14	N/A	To ensure information security incident management, the organization periodically reviews incident response capabilities to determine the effectiveness of incident response and to document the results.	Functional	Intersects With	Continuous Incident Response Improvements	IRO-04.3	Mechanisms exist to use qualitative and quantitative data from incident response testing to: (1) Determine the effectiveness of incident response processes; (2) Continuously improve incident response processes; and (3) Provide incident response measures and metrics that are accurate, consistent and in a reproducible format.	5	Controls pattern 1
16.1.1.15.P	N/A	The cloud service provider provides the cloud service customer with the information to develop an emergency contact network including emergency contact information, contact methods, and contact details, in preparation for information security incidents.	Functional	Intersects With	Supply Chain Coordination	IRO-10.4	Mechanisms exist to provide cybersecurity and data protection incident information to the provider of the Technology Assets, Applications and/or Services (TAAS) and other organizations involved in the supply chain for TAAS related to the incident.	5	Controls pattern 3
16.1.2	N/A	16.1.2 corresponds to the part of 16.1.2 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	
16.1.2.1	N/A	16.1.2.1 corresponds to the 1st sentence(beginning with "All employees and") of the 3rd paragraph of the Implementation guidance of 16.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.2.2	N/A	16.1.2.2 corresponds to the 2nd sentence(beginning with "They should also") of the 3rd paragraph of the Implementation guidance of 16.1.2 in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.2.3	N/A	16.1.2.3 corresponds to the a) part of 16.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.2.4	N/A	16.1.2.4 corresponds to the b) part of 16.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.2.5	N/A	16.1.2.5 corresponds to the c) part of 16.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.2.6	N/A	16.1.2.6 corresponds to the d) part of 16.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.2.7	N/A	16.1.2.7 corresponds to the e) part of 16.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bdf6d9e91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
16.1.2.8	N/A	16.1.2.8 corresponds to the f) part of 16.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.2.9	N/A	16.1.2.9 corresponds to the g) part of 16.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.2.10	N/A	16.1.2.10 corresponds to the h) part of 16.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.2.11.P	N/A	The cloud service provider provides a mechanism for external parties (including cloud service customers) to report information security incidents to the cloud service provider.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 3
16.1.2.12.P	N/A	16.1.2.12.P corresponds to the 2nd of the 3 bullet points bullet points(beginning with "the cloud service") in the 1st paragraph of the Implementation guidance of 16.1.2 in ISO/IEC 27017:2015.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 3
16.1.2.13.P	N/A	16.1.2.13.P corresponds to the 3rd of the 3 bullet points bullet points(beginning with "the cloud service") in the 1st paragraph of the Implementation guidance of 16.1.2 in ISO/IEC 27017:2015.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 3
16.1.3	N/A	16.1.3 corresponds to the part of 16.1.3 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	
16.1.3.1	N/A	16.1.3.1 corresponds to the 1st sentence(beginning with "All employees and") of the 1st(last) paragraph of the Implementation guidance of 16.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.3.2	N/A	16.1.3.2 corresponds to the 2nd(last) sentence(beginning with "The reporting mechanism") of the 1st(last) paragraph of the Implementation guidance of 16.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.4	N/A	16.1.4 corresponds to the part of 16.1.4 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Incident Classification & Prioritization	IRO-02.4	Mechanisms exist to identify classes of incidents and actions to take to ensure the continuation of organizational missions and business functions.	5	
16.1.4.1	N/A	16.1.4.1 corresponds to the 1st sentence(beginning with "The point of contact") of the 1st paragraph of the Implementation guidance of 16.1.4 in ISO/IEC 27002:2013.	Functional	Intersects With	Incident Classification & Prioritization	IRO-02.4	Mechanisms exist to identify classes of incidents and actions to take to ensure the continuation of organizational missions and business functions.	5	Controls pattern 1
16.1.4.2	N/A	16.1.4.2 corresponds to the 1st(last) sentence(beginning with "Results of the") of the 3rd(last) paragraph of the Implementation guidance of 16.1.4 in ISO/IEC 27002:2013.	Functional	Intersects With	Incident Classification & Prioritization	IRO-02.4	Mechanisms exist to identify classes of incidents and actions to take to ensure the continuation of organizational missions and business functions.	5	Controls pattern 1
16.1.5	N/A	16.1.5 corresponds to the part of 16.1.5 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	10	
16.1.5.1	N/A	16.1.5.1 corresponds to the 1st(last) sentence(beginning with "Information security") of the 1st paragraph of the Implementation guidance of 16.1.5 in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	10	Controls pattern 1
16.1.5.2	N/A	16.1.5.2 corresponds to the a) part of 16.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	10	Controls pattern 1
16.1.5.3	N/A	16.1.5.3 corresponds to the b) part of 16.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	10	Controls pattern 1
16.1.5.4	N/A	16.1.5.4 corresponds to the c) part of 16.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	10	Controls pattern 1
16.1.5.5	N/A	16.1.5.5 corresponds to the d) part of 16.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	10	Controls pattern 1
16.1.5.6	N/A	16.1.5.6 corresponds to the e) part of 16.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	10	Controls pattern 1
16.1.5.7	N/A	16.1.5.7 corresponds to the f) part of 16.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	10	Controls pattern 1
16.1.5.8	N/A	16.1.5.8 corresponds to the g) part of 16.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	10	Controls pattern 1
16.1.5.9	N/A	16.1.5.9 corresponds to the 1st(last) sentence(beginning with "Post-incident analysis") of the 3rd(last) paragraph of the Implementation guidance of 16.1.5 in ISO/IEC 27002:2013.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	Controls pattern 1
16.1.5.10	N/A	Measures shall include investigations and checks on the possibility of similar information security incidents affecting other information systems and functions in the organization, as required.	Functional	Intersects With	Recurring Incident Analysis	IRO-09.2	Mechanisms exist to periodically review incident response activities for the existence of recurring incidents.	5	Controls pattern 1
16.1.6	N/A	16.1.6 corresponds to the part of 16.1.6 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	10	
16.1.6.1	N/A	16.1.6.1 corresponds to the 1st sentence(beginning with "There should be") of the 1st(last) paragraph of the Implementation guidance of 16.1.6 in ISO/IEC 27002:2013.	Functional	Subset Of	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	10	Controls pattern 1
16.1.6.2	N/A	16.1.6.2 corresponds to the 2nd(last) sentence(beginning with "The information") of the 1st(last) paragraph of the Implementation guidance of 16.1.6 in ISO/IEC 27002:2013.	Functional	Subset Of	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	10	Controls pattern 1
16.1.7	N/A	16.1.7 corresponds to the part of 16.1.7 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	
16.1.7.1	N/A	16.1.7.1 corresponds to the 1st(last) sentence(beginning with "Internal procedures") of the 1st paragraph of the Implementation guidance of 16.1.7 in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
16.1.7.2	N/A	16.1.7.2 corresponds to the 1st sentence(beginning with "In general, these") of the 2nd paragraph of the Implementation guidance of 16.1.7 in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: Japan - Information System Security Management and Assessment Program (ISMAP)

Focal Document URL: https://www.ismap.go.jp/csm/?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250fbbfd69f91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
16.1.7.3	N/A	16.1.7.3 corresponds to the a) part of 16.1.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
16.1.7.4	N/A	16.1.7.4 corresponds to the b) part of 16.1.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
16.1.7.5	N/A	16.1.7.5 corresponds to the c) part of 16.1.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
16.1.7.6	N/A	16.1.7.6 corresponds to the d) part of 16.1.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
16.1.7.7	N/A	16.1.7.7 corresponds to the e) part of 16.1.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
16.1.7.8	N/A	16.1.7.8 corresponds to the f) part of 16.1.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
16.1.7.9	N/A	16.1.7.9 corresponds to the g) part of 16.1.7 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
16.1.7.10	N/A	16.1.7.10 corresponds to the 1st(last) sentence(beginning with "Where available,") of the 3rd paragraph of the Implementation guidance of 16.1.7 in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
16.1.7.11	N/A	16.1.7.11 corresponds to the 1st & 2nd sentence(beginning with "Forensic evidence" & "In such cases") of the 4th(last) paragraph of the Implementation guidance of 16.1.7 in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
16.1.7.12	N/A	16.1.7.12 corresponds to the 3rd(last) sentence(beginning with "The requirements") of the 4th(last) paragraph of the Implementation guidance of 16.1.7 in ISO/IEC 27002:2013.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
16.1.7.13.PB	N/A	16.1.7.13.PB corresponds to the 16.1.7 Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Subset Of	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	10	Controls pattern 1
17	N/A	Information security aspects of business continuity management	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
17.1	N/A	Information security continuity Control Objective: Information security continuity should be embedded in the organization's business continuity management systems.	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
17.1.1	N/A	17.1.1 corresponds to the part of 17.1.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
17.1.1.1	N/A	17.1.1.1 corresponds to the 1st sentence(beginning with "An organization") of the 1st paragraph of the Implementation guidance of 17.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	Controls pattern 1
17.1.1.2	N/A	17.1.1.2 corresponds to the 2nd(last) sentence(beginning with "Information security") of the 1st paragraph of the Implementation guidance of 17.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	Controls pattern 1
17.1.1.3	N/A	17.1.1.3 corresponds to the 1st sentence(beginning with "In the absence") of the 2nd(last) paragraph of the Implementation guidance of 17.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	Controls pattern 1
17.1.1.4	N/A	17.1.1.4 corresponds to the 2nd(last) sentence(beginning with "Alternatively,") of the 2nd(last) paragraph of the Implementation guidance of 17.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	Controls pattern 1
17.1.2	N/A	17.1.2 corresponds to the part of 17.1.2 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity & Disaster Recovery (BC/DR) Plans	BCD-01.7	Mechanisms exist for process owners to establish and maintain formal Business Continuity & Disaster Recovery (BC/DR) plans to ensure information is detailed enough, accurate and representative of current operations in order to sustain and/or restore operations under adverse conditions.	10	
17.1.2.1	N/A	17.1.2.1 corresponds to the 1st paragraph a) part of 17.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity & Disaster Recovery (BC/DR) Plans	BCD-01.7	Mechanisms exist for process owners to establish and maintain formal Business Continuity & Disaster Recovery (BC/DR) plans to ensure information is detailed enough, accurate and representative of current operations in order to sustain and/or restore operations under adverse conditions.	10	Controls pattern 1
17.1.2.2	N/A	17.1.2.2 corresponds to the 1st paragraph b) part of 17.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity & Disaster Recovery (BC/DR) Plans	BCD-01.7	Mechanisms exist for process owners to establish and maintain formal Business Continuity & Disaster Recovery (BC/DR) plans to ensure information is detailed enough, accurate and representative of current operations in order to sustain and/or restore operations under adverse conditions.	10	Controls pattern 1
17.1.2.3	N/A	17.1.2.3 corresponds to the 1st paragraph c) part of 17.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity & Disaster Recovery (BC/DR) Plans	BCD-01.7	Mechanisms exist for process owners to establish and maintain formal Business Continuity & Disaster Recovery (BC/DR) plans to ensure information is detailed enough, accurate and representative of current operations in order to sustain and/or restore operations under adverse conditions.	10	Controls pattern 1
17.1.2.4	N/A	17.1.2.4 corresponds to the 2nd paragraph a) part of 17.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity & Disaster Recovery (BC/DR) Plans	BCD-01.7	Mechanisms exist for process owners to establish and maintain formal Business Continuity & Disaster Recovery (BC/DR) plans to ensure information is detailed enough, accurate and representative of current operations in order to sustain and/or restore operations under adverse conditions.	10	Controls pattern 1
17.1.2.5	N/A	17.1.2.5 corresponds to the 2nd paragraph b) part of 17.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity & Disaster Recovery (BC/DR) Plans	BCD-01.7	Mechanisms exist for process owners to establish and maintain formal Business Continuity & Disaster Recovery (BC/DR) plans to ensure information is detailed enough, accurate and representative of current operations in order to sustain and/or restore operations under adverse conditions.	10	Controls pattern 1
17.1.2.6	N/A	17.1.2.6 corresponds to the 2nd paragraph c) part of 17.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity & Disaster Recovery (BC/DR) Plans	BCD-01.7	Mechanisms exist for process owners to establish and maintain formal Business Continuity & Disaster Recovery (BC/DR) plans to ensure information is detailed enough, accurate and representative of current operations in order to sustain and/or restore operations under adverse conditions.	10	Controls pattern 1
17.1.3	N/A	17.1.3 corresponds to the part of 17.1.3 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
17.1.3.1	N/A	17.1.3.1 corresponds to the 1st sentence(beginning with "Organizational,") of the 1st paragraph of the Implementation guidance of 17.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	Controls pattern 1
17.1.3.2	N/A	17.1.3.2 corresponds to the a) part of 17.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Contingency Plan Testing & Exercises	BCD-04	Mechanisms exist to conduct tests and/or exercises to evaluate the contingency plan's effectiveness and the organization's readiness to execute the plan.	8	Controls pattern 1
17.1.3.3	N/A	17.1.3.3 corresponds to the b) part of 17.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Contingency Plan Testing & Exercises	BCD-04	Mechanisms exist to conduct tests and/or exercises to evaluate the contingency plan's effectiveness and the organization's readiness to execute the plan.	8	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**

Focal Document URL: https://www.ismap.go.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bbfd69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
17.1.3.4	N/A	17.1.3.4 corresponds to the c) part of 17.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	Controls pattern 1
17.2	N/A	Redundancies Control Objective: To ensure availability of information processing facilities.	Functional	Subset Of	Alternate Processing Site	BCD-09	Mechanisms exist to establish an alternate processing site that provides security measures equivalent to that of the primary site.	10	
17.2.1	N/A	17.2.1 corresponds to the part of 17.2.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Alternate Processing Site	BCD-09	Mechanisms exist to establish an alternate processing site that provides security measures equivalent to that of the primary site.	10	
17.2.1.1	N/A	17.2.1.1 corresponds to the 1st sentence(beginning with "Organizations should") of the 1st paragraph of the Implementation guidance of 17.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Alternate Processing Site	BCD-09	Mechanisms exist to establish an alternate processing site that provides security measures equivalent to that of the primary site.	10	Controls pattern 1
17.2.1.2	N/A	17.2.1.2 corresponds to the 2nd(last) sentence(beginning with "Where the availability") of the 1st paragraph of the Implementation guidance of 17.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Alternate Processing Site	BCD-09	Mechanisms exist to establish an alternate processing site that provides security measures equivalent to that of the primary site.	10	Controls pattern 1
17.2.1.3	N/A	17.2.1.3 corresponds to the 1st(last) sentence(beginning with "Where applicable,") of the 2nd paragraph of the Implementation guidance of 17.2.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Alternate Processing Site	BCD-09	Mechanisms exist to establish an alternate processing site that provides security measures equivalent to that of the primary site.	10	Controls pattern 1
18	N/A	Compliance	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
18.1	N/A	Compliance with legal and contractual requirements Control Objective: To avoid breaches of legal, statutory, regulatory or contractual obligations related to information security and of any security requirements.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
18.1.1	N/A	18.1.1 corresponds to the part of 18.1.1 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
18.1.1.1	N/A	18.1.1.1 corresponds to the 1st(last) sentence(beginning with "The specific controls") of the 1st paragraph of the Implementation guidance of 18.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	Controls pattern 1
18.1.1.2	N/A	18.1.1.2 corresponds to the 1st sentence(beginning with "Managers should") of the 2nd(last) paragraph of the Implementation guidance of 18.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	Controls pattern 1
18.1.1.3	N/A	18.1.1.3 corresponds to the 2nd(last) sentence(beginning with "If the organization") of the 2nd(last) paragraph of the Implementation guidance of 18.1.1 in ISO/IEC 27002:2013.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	Controls pattern 1
18.1.1.4.P	N/A	18.1.1.4.P corresponds to the 1st(last) sentence(beginning with "The cloud service") of the 1st paragraph of the Implementation guidance of 18.1.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	Controls pattern 3
18.1.1.5.P	N/A	18.1.1.5.P corresponds to the 1st sentence(beginning with "The cloud service") of the 2nd paragraph of the Implementation guidance of 18.1.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	Controls pattern 1
18.1.1.6.P	N/A	The cloud service provider provides information that identifies their relevant legal requirements to a requesting cloud service customer.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	Controls pattern 3
18.1.1.7.P	N/A	18.1.1.7.P corresponds to the 1st(last) sentence(beginning with "The cloud service") of the 3rd(last) paragraph of the Implementation guidance of 18.1.1 in ISO/IEC 27017:2015.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	Controls pattern 3
18.1.2	N/A	18.1.2 corresponds to the part of 18.1.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	AI & Autonomous Technologies Intellectual Property Infringement Protections	AAT-12	Mechanisms exist to prevent third-party Intellectual Property (IP) rights infringement by Artificial Intelligence (AI) and Autonomous Technologies (AAT).	5	
18.1.2	N/A	18.1.2 corresponds to the part of 18.1.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	
18.1.2.1	N/A	18.1.2.1 corresponds to the a) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.2	N/A	18.1.2.2 corresponds to the b) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.3	N/A	18.1.2.3 corresponds to the c) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.4	N/A	18.1.2.4 corresponds to the d) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.5	N/A	18.1.2.5 corresponds to the e) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.6	N/A	18.1.2.6 corresponds to the f) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.7	N/A	18.1.2.7 corresponds to the g) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.8	N/A	18.1.2.8 corresponds to the h) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.9	N/A	18.1.2.9 corresponds to the i) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.10	N/A	18.1.2.10 corresponds to the j) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.11	N/A	18.1.2.11 corresponds to the k) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.12	N/A	18.1.2.12 corresponds to the l) part of 18.1.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Software Licensing Restrictions	AST-02.7	Mechanisms exist to protect Intellectual Property (IP) rights with software licensing restrictions.	5	Controls pattern 1
18.1.2.13.PB	N/A	18.1.2.13.PB corresponds to the 18.1.2 Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Intersects With	AI & Autonomous Technologies Intellectual Property Infringement Protections	AAT-12	Mechanisms exist to prevent third-party Intellectual Property (IP) rights infringement by Artificial Intelligence (AI) and Autonomous Technologies (AAT).	5	Controls pattern 1
18.1.2.13.PB	N/A	18.1.2.13.PB corresponds to the 18.1.2 Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Intersects With	Grievances	CPL-07	Mechanisms exist to govern the intake and analysis of grievances related to the organization's cybersecurity and/or data protection practices.	5	Controls pattern 1
18.1.3	N/A	18.1.3 corresponds to the part of 18.1.3 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	
18.1.3.1	N/A	18.1.3.1 corresponds to the 1st sentence(beginning with "When deciding upon") of the 1st paragraph of the Implementation guidance of 18.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.3.2	N/A	18.1.3.2 corresponds to the 2nd sentence(beginning with "Records should") of the 1st paragraph of the Implementation guidance of 18.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.3.3	N/A	18.1.3.3 corresponds to the 3rd(last) sentence(beginning with "Any related cryptographic") of the 1st paragraph of the Implementation guidance of 18.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.3.4	N/A	18.1.3.4 corresponds to the 1st sentence(beginning with "Consideration should") of the 2nd paragraph of the Implementation guidance of 18.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.3.5	N/A	18.1.3.5 corresponds to the 2nd(last) sentence(beginning with "Storage and handling") of the 2nd paragraph of the Implementation guidance of 18.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Japan - Information System Security Management and Assessment Program (ISMAP)**
Focal Document URL: https://www.ismap.go.jp/csm/?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0bbfd69fe91bf93&spa=1
Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
18.1.3.6	N/A	18.1.3.6 corresponds to the 1st(last) sentence(beginning with "Where electronic") of the 3rd paragraph of the Implementation guidance of 18.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.3.7	N/A	18.1.3.7 corresponds to the 1st(last) sentence(beginning with "Data storage systems") of the 4th paragraph of the Implementation guidance of 18.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.3.8	N/A	18.1.3.8 corresponds to the 1st sentence(beginning with "The system of storage") of the 5th paragraph of the Implementation guidance of 18.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.3.9	N/A	18.1.3.9 corresponds to the 2nd(last) sentence(beginning with "This system should") of the 5th paragraph of the Implementation guidance of 18.1.3 in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.3.10	N/A	18.1.3.10 corresponds to the a) part of 18.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.3.11	N/A	18.1.3.11 corresponds to the b) part of 18.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.3.12	N/A	18.1.3.12 corresponds to the c) part of 18.1.3 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.3.13.PB	N/A	18.1.3.13.PB corresponds to the 18.1.3 Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	Controls pattern 1
18.1.4	N/A	18.1.4 corresponds to the part of 18.1.4 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Data Privacy Program	PRI-01	Mechanisms exist to facilitate the implementation and operation of data protection controls throughout the data lifecycle to ensure all forms of Personal Data (PD) are processed lawfully, fairly and transparently.	10	
18.1.4	N/A	18.1.4 corresponds to the part of 18.1.4 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	8	
18.1.4.1	N/A	18.1.4.1 corresponds to the 1st sentence(beginning with "An organization's") of the 1st paragraph of the Implementation guidance of 18.1.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	10	Controls pattern 1
18.1.4.2	N/A	18.1.4.2 corresponds to the 2nd(last) sentence(beginning with "This policy should") of the 1st paragraph of the Implementation guidance of 18.1.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	10	Controls pattern 1
18.1.4.3	N/A	18.1.4.3 corresponds to the 1st sentence(beginning with "Compliance with") of the 2nd(last) paragraph of the Implementation guidance of 18.1.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	10	Controls pattern 1
18.1.4.4	N/A	18.1.4.4 corresponds to the 2nd sentence(beginning with "Often this is best") of the 1st paragraph of the Implementation guidance of 18.1.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	10	Controls pattern 1
18.1.4.5	N/A	18.1.4.5 corresponds to the 3rd sentence(beginning with "Responsibility") of the 2nd(last) paragraph of the Implementation guidance of 18.1.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	10	Controls pattern 1
18.1.4.6	N/A	18.1.4.6 corresponds to the 4th(last) sentence(beginning with "Appropriate technical") of the 2nd(last) paragraph of the Implementation guidance of 18.1.4 in ISO/IEC 27002:2013.	Functional	Subset Of	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	10	Controls pattern 1
18.1.5	N/A	18.1.5 corresponds to the part of 18.1.5 Control in ISO/IEC 27002:2013.	Functional	Subset Of	Export-Controlled Cryptography	CRY-01.2	Mechanisms exist to address the exporting of cryptographic technologies in compliance with relevant statutory and regulatory requirements.	10	
18.1.5.1	N/A	18.1.5.1 corresponds to the a) part of 18.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Export-Controlled Cryptography	CRY-01.2	Mechanisms exist to address the exporting of cryptographic technologies in compliance with relevant statutory and regulatory requirements.	10	Controls pattern 1
18.1.5.2	N/A	18.1.5.2 corresponds to the b) part of 18.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Export-Controlled Cryptography	CRY-01.2	Mechanisms exist to address the exporting of cryptographic technologies in compliance with relevant statutory and regulatory requirements.	10	Controls pattern 1
18.1.5.3	N/A	18.1.5.3 corresponds to the c) part of 18.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Export-Controlled Cryptography	CRY-01.2	Mechanisms exist to address the exporting of cryptographic technologies in compliance with relevant statutory and regulatory requirements.	10	Controls pattern 1
18.1.5.4	N/A	18.1.5.4 corresponds to the d) part of 18.1.5 Implementation guidance in ISO/IEC 27002:2013.	Functional	Subset Of	Export-Controlled Cryptography	CRY-01.2	Mechanisms exist to address the exporting of cryptographic technologies in compliance with relevant statutory and regulatory requirements.	10	Controls pattern 1
18.1.5.5	N/A	18.1.5.5 corresponds to the 1st sentence(beginning with "Legal advice should") of the 2nd(last) paragraph of the Implementation guidance of 18.1.5 in ISO/IEC 27002:2013.	Functional	Subset Of	Export-Controlled Cryptography	CRY-01.2	Mechanisms exist to address the exporting of cryptographic technologies in compliance with relevant statutory and regulatory requirements.	10	Controls pattern 1
18.1.5.6	N/A	18.1.5.6 corresponds to the 2nd(last) sentence(beginning with "Before encrypted") of the 2nd(last) paragraph of the Implementation guidance of 18.1.5 in ISO/IEC 27002:2013.	Functional	Subset Of	Export-Controlled Cryptography	CRY-01.2	Mechanisms exist to address the exporting of cryptographic technologies in compliance with relevant statutory and regulatory requirements.	10	Controls pattern 1
18.1.5.7.PB	N/A	18.1.5.7.PB corresponds to the 18.1. Implementation guidance for Cloud service provider in ISO/IEC 27017:2015.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	Controls pattern 3
18.2	N/A	Information security reviews Control Objective: To ensure that information security is implemented and operated in accordance with the organizational policies and procedures.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	
18.2.1	N/A	18.2.1 corresponds to the part of 18.2.1 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	
18.2.1.1	N/A	The governing body initiates and conducts an independent review to ensure that the organization's efforts to manage information security remain relevant, reasonable, and effective.	Functional	No Relationship	N/A	N/A	N/A	0	
18.2.1.2	N/A	The independent review includes an assessment of opportunities for improvement.	Functional	No Relationship	N/A	N/A	N/A	0	
18.2.1.3	N/A	18.2.1.3 corresponds to the 2nd(last) sentence(beginning with "The review should") of the 1st paragraph of the Implementation guidance of 18.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	Controls pattern 1
18.2.1.4	N/A	18.2.1.4 corresponds to the 1st sentence(beginning with "Such a review should") of the 2nd paragraph of the Implementation guidance of 18.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	Controls pattern 1
18.2.1.5	N/A	18.2.1.5 corresponds to the 2nd(last) sentence(beginning with "Individuals carrying") of the 2nd paragraph of the Implementation guidance of 18.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	Controls pattern 1
18.2.1.6	N/A	18.2.1.6 corresponds to the 1st sentence(beginning with "The results of") of the 3rd paragraph of the Implementation guidance of 18.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	Controls pattern 1
18.2.1.7	N/A	18.2.1.7 corresponds to the 2nd(last) sentence(beginning with "These records should") of the 3rd paragraph of the Implementation guidance of 18.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	Controls pattern 1
18.2.1.8	N/A	18.2.1.8 corresponds to the 1st(last) sentence(beginning with "If the independent") of the 4th(last) paragraph of the Implementation guidance of 18.2.1 in ISO/IEC 27002:2013.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	Controls pattern 1
18.2.1.9.P	N/A	18.2.1.9.P corresponds to the 1st(last) sentence(beginning with "The cloud service") of the 1st paragraph of the Implementation guidance of 18.2.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	Controls pattern 3
18.2.1.10.P	N/A	18.2.1.10.P corresponds to the 1st sentence(beginning with "Where individual") of the 2nd(last) paragraph of the Implementation guidance of 18.2.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	Controls pattern 3

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: Japan - Information System Security Management and Assessment Program (ISMAMP)

Focal Document URL: https://www.ismap.gp.jp/csm?id=kb_article_view&sysparm_article=KB0010301&sys_kb_id=a00cd78a2b5fa250f0b0bdf69fe91bf93&spa=1

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-jpn-ismap.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
18.2.1.11.P	N/A	The cloud service provider makes independent evidence that information security is implemented and operated in accordance with the cloud service provider's policies and procedures available to a prospective cloud service customer upon request and prior to contracting.	Functional	Intersects With	Ability To Demonstrate Conformity	CPL-01.3	Mechanisms exist to ensure the organization is able to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	Controls pattern 3
18.2.1.12.P	N/A	An appropriate independent assessment selected by the cloud service provider is a generally acceptable means of satisfying the cloud service customer's interest in a review of the cloud service provider's operations, provided that sufficient transparency is provided.	Functional	Intersects With	Ability To Demonstrate Conformity	CPL-01.3	Mechanisms exist to ensure the organization is able to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	Controls pattern 3
18.2.1.13.P	N/A	18.2.1.13.P corresponds to the 4th(last) sentence(beginning with "When the independent") of the 2nd(last) paragraph of the Implementation guidance of 18.2.1 in ISO/IEC 27017:2015.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	Controls pattern 3
18.2.2	N/A	18.2.2 corresponds to the part of 18.2.2 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	
18.2.2.1	N/A	18.2.2.1 corresponds to the 1st sentence(beginning with "Managers should") of the 1st paragraph of the Implementation guidance of 18.2.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	Controls pattern 1
18.2.2.2	N/A	18.2.2.2 corresponds to the 2nd(last) sentence(beginning with "Automatic measurement") of the 1st paragraph of the Implementation guidance of 18.2.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	Controls pattern 1
18.2.2.3	N/A	18.2.2.3 corresponds to the a) part of 18.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	Controls pattern 1
18.2.2.4	N/A	18.2.2.4 corresponds to the b) part of 18.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	Controls pattern 1
18.2.2.5	N/A	18.2.2.5 corresponds to the c) part of 18.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	Controls pattern 1
18.2.2.6	N/A	18.2.2.6 corresponds to the d) part of 18.2.2 Implementation guidance in ISO/IEC 27002:2013.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	Controls pattern 1
18.2.2.7	N/A	18.2.2.7 corresponds to the 1st sentence(beginning with "Results of reviews") of the 2nd(last) paragraph of the Implementation guidance of 18.2.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	Controls pattern 1
18.2.2.8	N/A	18.2.2.8 corresponds to the 2nd(last) sentence(beginning with "Managers should") of the 2nd(last) paragraph of the Implementation guidance of 18.2.2 in ISO/IEC 27002:2013.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	Controls pattern 1
18.2.3	N/A	18.2.3 corresponds to the part of 18.2.3 Control in ISO/IEC 27002:2013.	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5	
18.2.3.1	N/A	18.2.3.1 corresponds to the 1st sentence(beginning with "Technical compliance") of the 1st paragraph of the Implementation guidance of 18.2.3 in ISO/IEC 27002:2013.	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5	Controls pattern 1
18.2.3.2	N/A	18.2.3.2 corresponds to the 2nd(last) sentence(beginning with "Alternatively,") of the 1st paragraph of the Implementation guidance of 18.2.3 in ISO/IEC 27002:2013.	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5	Controls pattern 1
18.2.3.3	N/A	18.2.3.3 corresponds to the 1st sentence(beginning with "If penetration") of the 2nd paragraph of the Implementation guidance of 18.2.3 in ISO/IEC 27002:2013.	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5	Controls pattern 1
18.2.3.4	N/A	The organization ensures that penetration tests or vulnerability assessments are planned, documented, and repeated, as well as performed when new vulnerabilities are identified and reported.	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5	Controls pattern 1
18.2.3.5	N/A	18.2.3.5 corresponds to the 1st(last) sentence(beginning with "Any technical compliance") of the 3rd(last) paragraph of the Implementation guidance of 18.2.3 in ISO/IEC 27002:2013.	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5	Controls pattern 1